資安科技與管理

Module 3. 零信任架構



簡報大綱

- 零信任架構的本質與核心概念
- 從美國的要求來看各項資安控制的意義
- 零信任架構的實作架構
- AI 代理人與零信任架構
- 結論

- 零信任架構的本質與核心概念
- 從美國的要求來看各項資安控制的意義
- 零信任架構的實作架構
- AI 代理人與零信任架構
- 結論

在開始前，我分享一下我在看零信任架構時的階段

聽說有零信任架構，開始從 NIST SP 800-207 思考這在講甚麼？

從零信任架構的發展歷史，去釐清他的核心概念

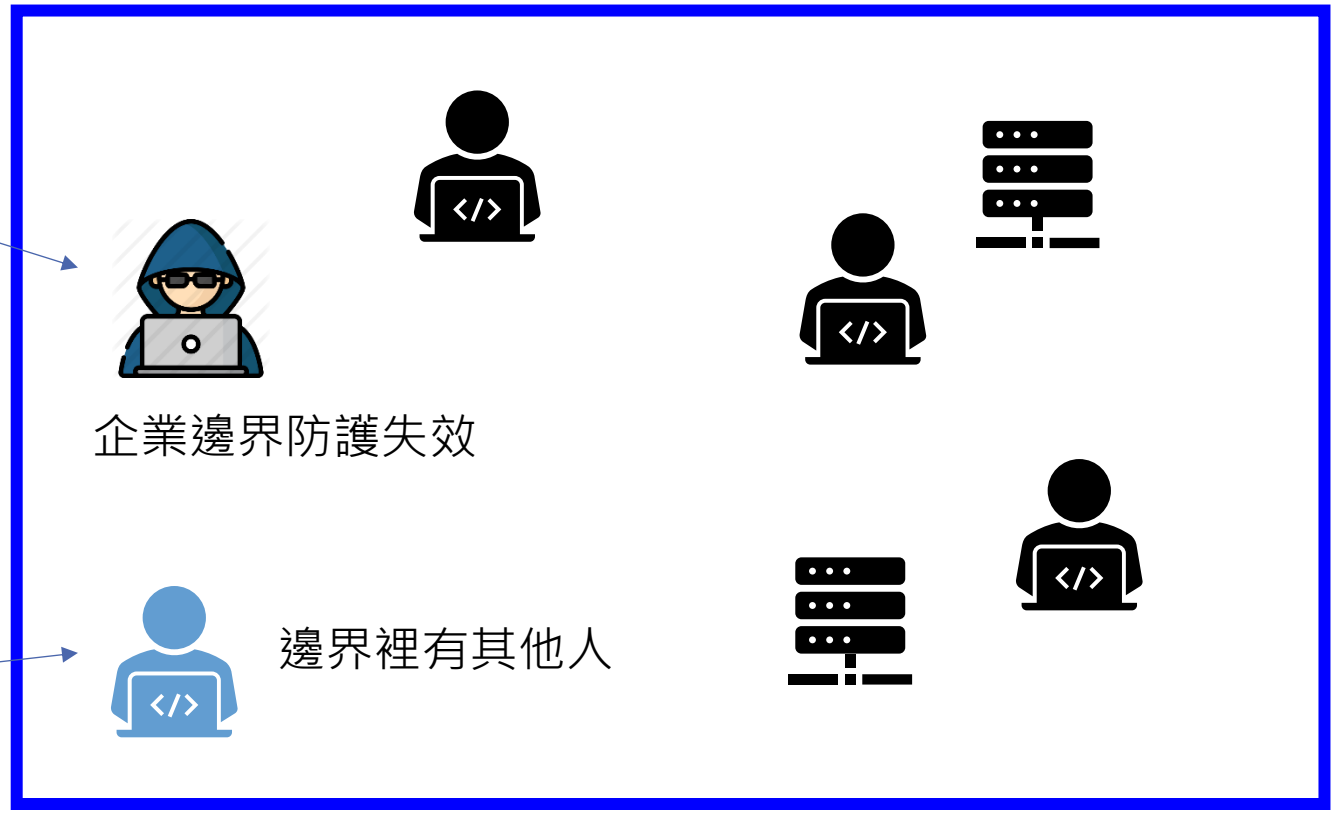
構思如何基於零信任架構，建立企業的資訊安全骨幹

思考導入的方法和可能遇到的問題

企業存取環境發生變化

APT、BYOD ...

委外、維修廠商、訪客



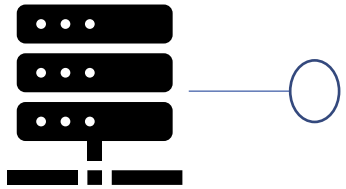
遠端工作、使用雲端服務

有些資料沒有在企業邊界內

資訊系統安全不是一勞永逸的事

一個資訊系統，即便現在沒有弱點，只要未來有弱點被發現，則就有可能找到利用方法

目前雖然禁止外部連線，總有可能有人有辦法存取



值得信賴的員工，可能電腦被駭客利用

資料雖然加密，可能會因為未來資訊技術的進步，資料很容易被解密

系統放久了被人遺忘，也忘了防護

每年花好多資安預算，好像看不到成果？

零信任發展的過程與概念的演進

2004: 傑里科論壇(Jericho Forum)與去週邊概念

萬一防火牆失效被移除的因應

2007: 美國國防部資訊局提出軟體定義邊界

SDP 為目前一種零信任架構的實作技術

2010: John Kindervag 提出零信任網路

分區防護 + 集中控管 + 不可有預設的信任

2014: Google BeyondCorp

存取時的情境考量與裝置鑑別

2017: Forrester ZTX

從資料、網路、人員、工作，裝置等角度來限制存取

2020: NIST SP800-207

零信任架構的七原則

2021/2022: 美國政府對零信任策略的要求

從身分識別與鑑別、裝置安全、網路安全、應用程式、資料等構面的要求

2023: 美國 CISA ZTMM

效率的考量+控制措施的韌性

零信任概念的起源

- 傑里科論壇 (Jericho Forum) 與去周邊化 (de-perimeterization) 概念
  - 其實這概念是要消除邊界，當然在消除邊界後會有很多需要解決的資安議題
- 比較具體的概念是 2010 年由 John Kindervag 所提出
  - 裝置不再有信賴與不信賴的邊界 There are no longer a trusted and an untrusted interface on our security devices
  - 不再有信賴與不信賴的網路 There are no longer a trusted and an untrusted network
  - 不再有信賴與不信賴的使用者 There are no longer trusted and untrusted users

Jericho Forum

From Wikipedia, the free encyclopedia

The **Jericho Forum** was an international group working to define and promote de-perimeterisation. It was initiated by David Lacey from the Royal Mail, and grew out of a loose affiliation of interested corporate CISOs (Chief Information Security Officers), discussing the topic from the summer of 2003, after an initial meeting hosted by Cisco, but was officially founded in January 2004. It declared success, and merged with The Open Group industry consortium's Security Forum in 2014.[1]

https://en.wikipedia.org/wiki/Jericho_Forum



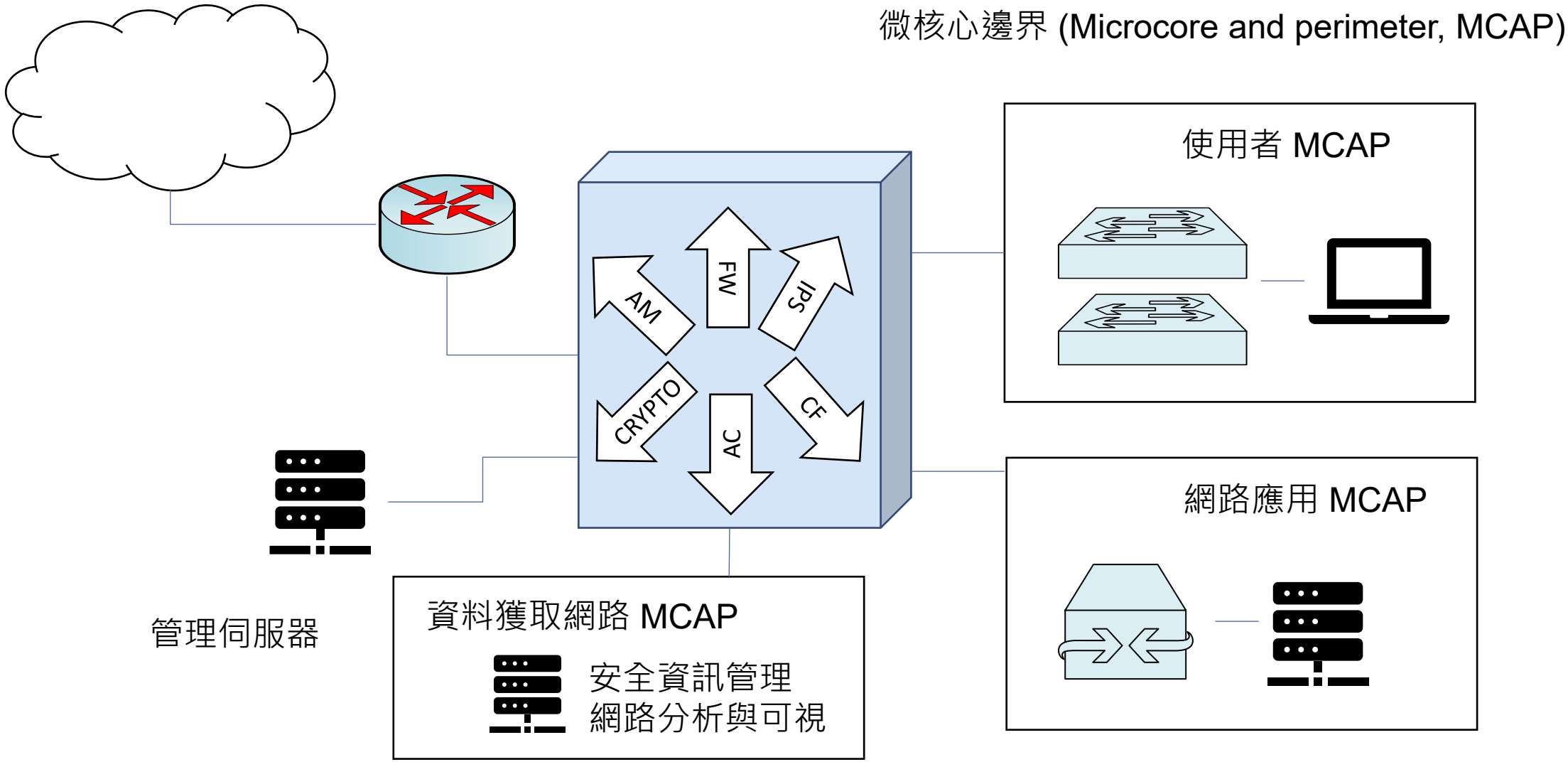
November 5, 2010

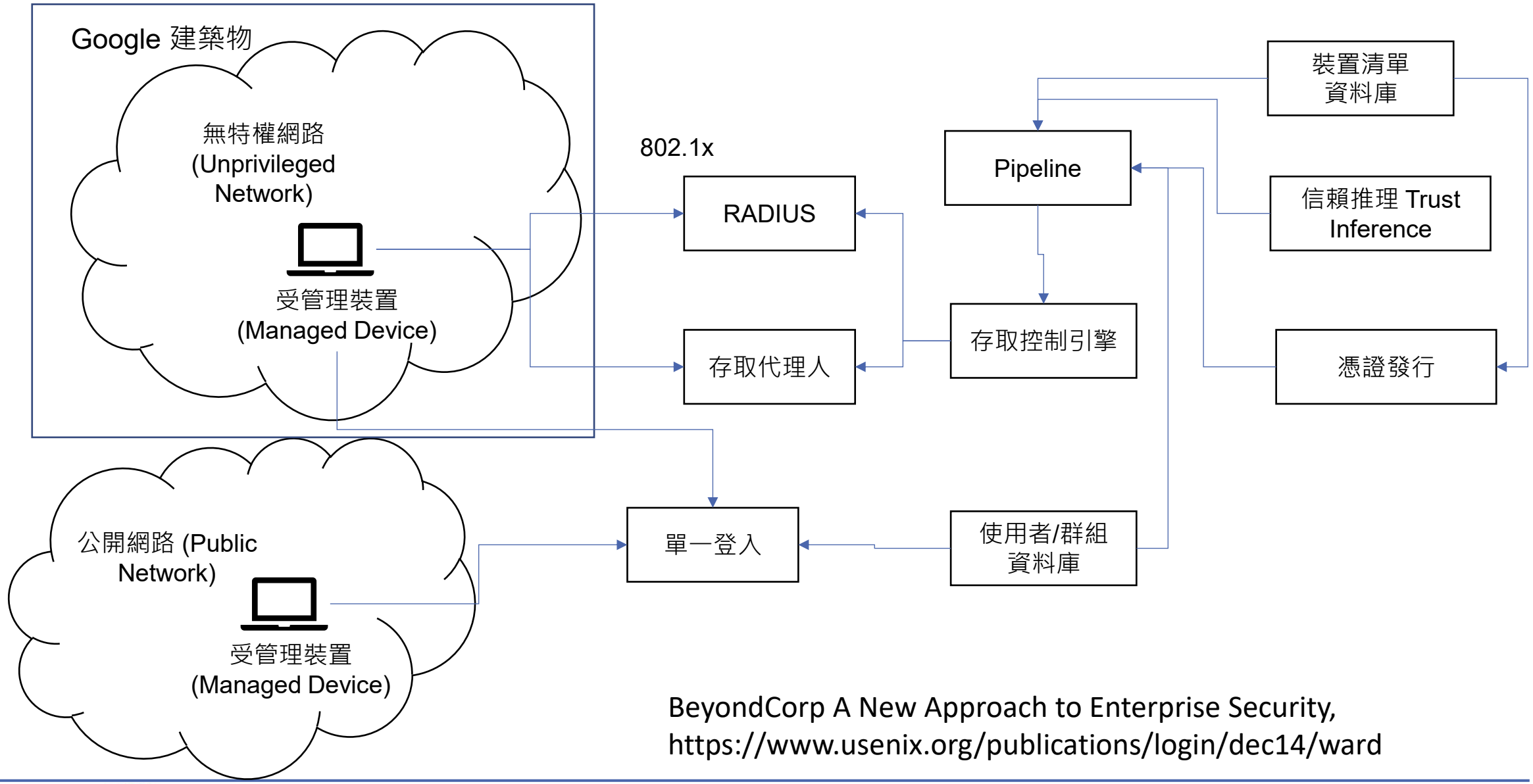
Build Security Into Your Network's DNA: The Zero Trust Network Architecture

by John Kindervag

with Stephanie Balaouras and Lindsey Coit

John Kindervag 的零信賴網路架構





BeyondCorp A New Approach to Enterprise Security,
https://www.usenix.org/publications/login/dec14/ward

- Forrester 在 2018 提出零信任延伸 (Zero Trusted eXtended, ZTX) 生態系，在該生態系中，是以如何限制存取的角度來區分成：

零信任資料	可透過資料加密等技術來限制資料不被沒有金鑰的人存取。
零信任網路	就是傳統透過網路分割的方式來限制存取。
零信任人員	透過身分鑑別等技術，確認只有許可的人才能進行存取。
零信任工作	透過一些防呆的機制，去避免人員不熟悉作業所造成的錯誤。
零信任裝置	綁定裝置以限定存取。

NIST SP 800-207 的零信任原則

- 所有資料源和計算服務均被視為資源。
- 無論網路位置如何，所有通信均受到安全保護。
- 各別企業資源的訪問是基於每個連線為基礎的。
- 由動態策略來決定是否可以存取。
- 企業監控和測量所擁有的資產與相關資產的完整性和安全性狀態。
- 在存取被許可前，要進行動態的身分鑑別與授權，並且要嚴格落實
- 儘可能收集有關資產、網路基礎設施和通信的現況資訊，並使用它來改善其安全狀態。

掌握所有可被存取資源並加以保護

存取控制政策要考慮到存取者的當下狀態

對所有存取進行身分鑑別與存取控制

了解是否有被入侵以趕快防護

情境資訊的掌握與因應

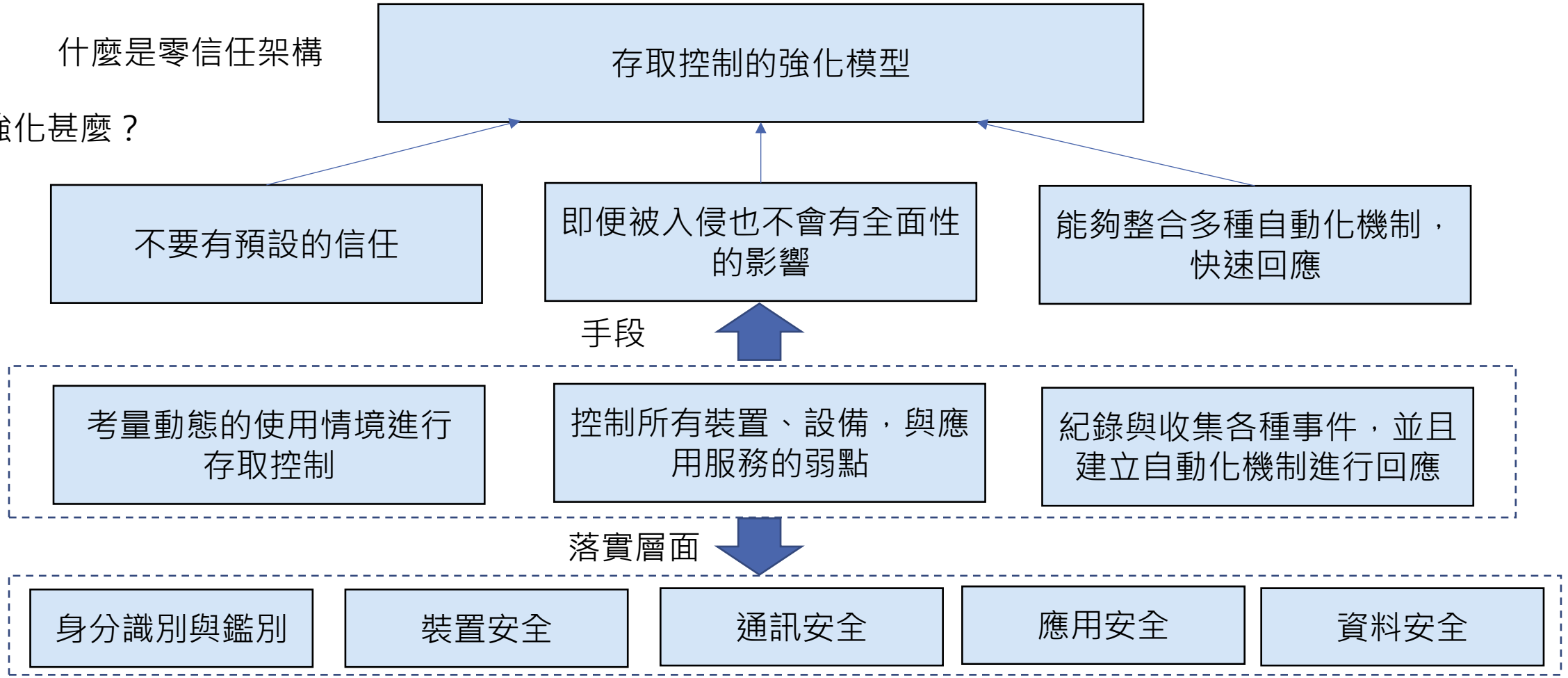
適度的持續進行安全檢查

小心，駭客就在你身邊

零信任架構

什麼是零信任架構

強化甚麼？



三大核心概念

要知道是誰存取

對所有資源存取前，都要確認存取者的身分。

動態存取控制

對於存取者，能夠按照存取的情境與狀態，動態決定存取控制權限。

取得相關資源的威脅情資或風險狀態，並且持續進行因應。

監控與掌握風險

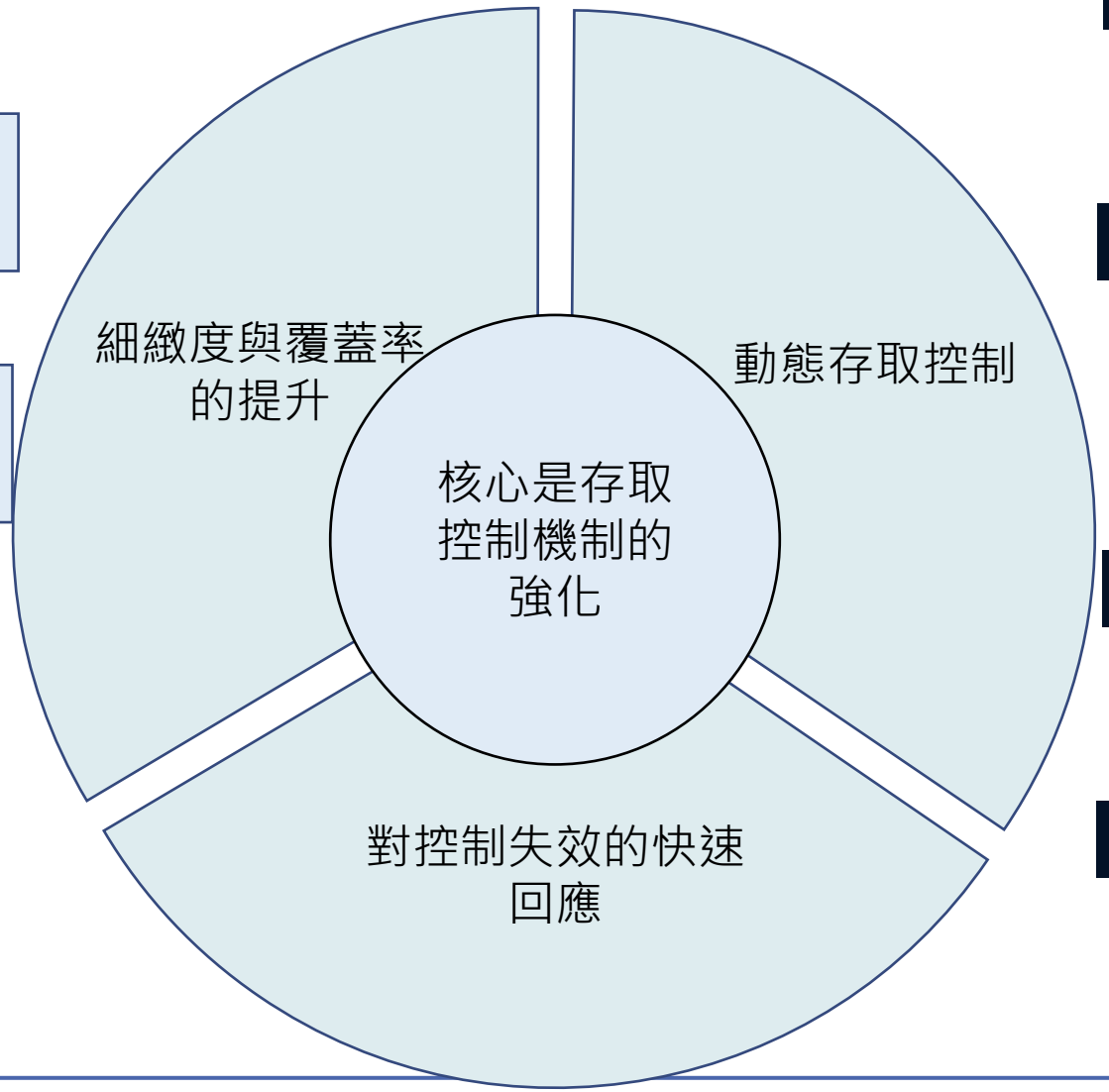
從傳統資安控制到零信任架構的主要演進

傳統

在網路邊緣進行防護

零信任

無論資源所處何地，從點對點的方式管控存取



傳統

基於靜態的條件，一但允許存取，一直可存取

零信任

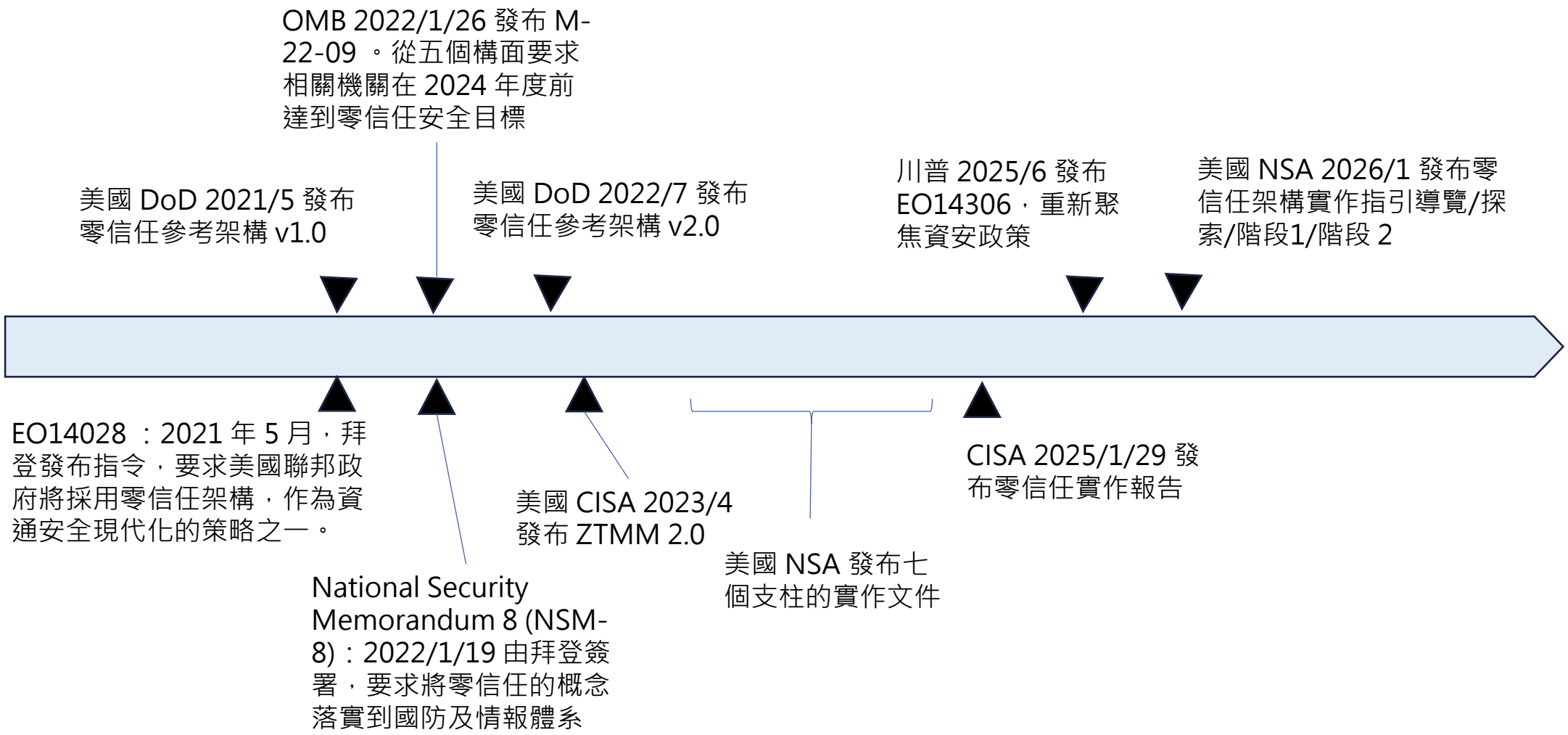
基於存取情境與風險動態調整

傳統

只在網路邊界進行監控

零信任

能快速發現入侵，限制影響範圍


OMB 2022/1/26 發布 M-22-09 。從五個構面要求相關機關在 2024 年度前達到零信任安全目標
美國 DoD 2021/5 發布零信任參考架構 v1.0
美國 DoD 2022/7 發布零信任參考架構 v2.0
川普 2025/6 發布 EO14306，重新聚焦資安政策
美國 NSA 2026/1 發布零信任架構實作指引導覽/探索/階段1/階段 2
EO14028 ：2021 年 5 月，拜登發布指令，要求美國聯邦政府將採用零信任架構，作為資通安全現代化的策略之一。
National Security Memorandum 8 (NSM-8)：2022/1/19 由拜登簽署，要求將零信任的概念落實到國防及情報體系
美國 CISA 2023/4 發布 ZTMM 2.0
美國 NSA 發布七個支柱的實作文件
CISA 2025/1/29 發布零信任實作報告

美國政策延續，但現在沒有特別強調零信任的名詞

- EO 14144：拜登離任前擴大資安、AI、軟體、身份與加密要求
- 2025/6/6 川普簽屬 EO14306
  - 透過 EO 14306 修正拜登的 EO 14144，刪改部分拜登時期延伸資安要求，政策語氣從「聯邦統一資安現代化要求」轉向「選擇性保留、風險導向、聚焦外國威脅、AI、軟體安全與量子安全」。
- 2026/1/23 OMB M-26-05 (Adopting a Risk-based Approach to Software and Hardware Security)
  - 明確撤銷：OMB M-22-18 與 M-23-16 這兩份是拜登時期軟體供應鏈安全與軟體開發安全的配套。
  - M-26-05 批評舊政策：*imposed unproven and burdensome software accounting processes that prioritized compliance over genuine security investments.*
  - 改成：自行依風險判斷保證等級，但保留 可要求 SBOM，但不再用一體適用方式強制推

Administration of Donald J. Trump, 2025

Executive Order 14306—Sustaining Select Efforts To Strengthen the Nation's Cybersecurity and Amending Executive Order 13694 and Executive Order 14144
June 6, 2025

By the authority vested in me as President by the Constitution and the laws of the United States of America, including the International Emergency Economic Powers Act (50 U.S.C. 1701 *et seq.*), the National Emergencies Act (50 U.S.C. 1601 *et seq.*), section 212(f) of the Immigration and Nationality Act of 1952 (8 U.S.C. 1182(f)), and section 301 of title 3, United States Code, it is hereby ordered:

Section 1. Amendments to Executive Order 14144. Executive Order 14144 of January 16, 2025 (Strengthening and Promoting Innovation in the Nation's Cybersecurity), is hereby amended by:

(a) striking subsections 2(a)–(b) and redesignating subsections 2(c), 2(d), and 2(e) as subsections 2(a), 2(b), and 2(c), respectively;

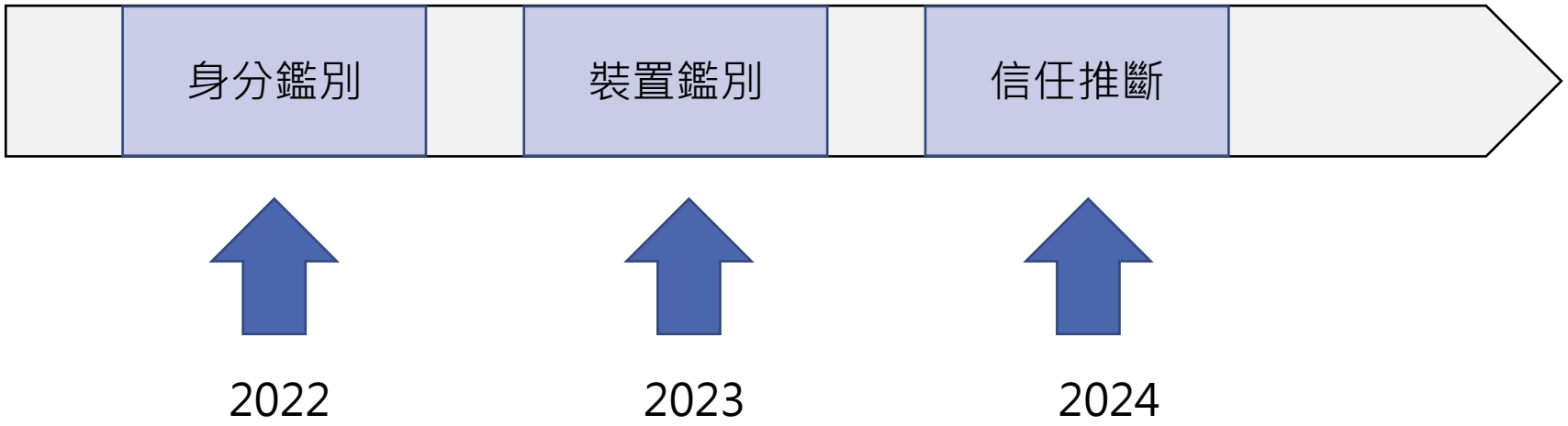
(b) striking the first sentence of subsection 2(e);

(c) striking subsections 3(a)–(b) and redesignating subsections 3(c), 3(d), and 3(e) as subsections 3(a), 3(b), and 3(c), respectively;

https://www.govinfo.gov/content/pkg/DCPD-202500669/pdf/DCPD-202500669.pdf

零信任在川普政府下不是被推翻，而是從「政策主標題」退到「聯邦資安現代化的底層能力」。

我國政府零信任的要求



這都沒有不好，重要的是要知道如何被用來達成零信任架構的目的

為了技術而做技術，很容易在串接上發生資安問題，反而沒有達到目的

由金融零信任架構參考指引來看零信任推動的成熟度概念

項次	功能	原則	等級
1.1	身分認證	採用多因子驗證機制，降低帳號密碼遭破解、 竊聽等風險。	Ⅰ
1.2	身分認證	採用包含綁定實體載具(如 FIDO、動態密碼產 生器、晶片卡、綁定手機且具數字配對 APP 等，排除簡訊、語音及電子郵件 OTP)的多因子驗證機制，可抗網路釣魚風險。	Ⅱ
1.3	身分互通	對外部使用者(如服務供應商或跨機構協作)提供或採用不低於內部使用者信賴等級之身分鑑別機制。(參照 ISO 29115 評估身分登錄、信物 管理與身分驗證三階段)	Ⅰ
1.4	身分互通	如具多元身分鑑別機制且有互通之必要，其信賴等級應具一致性之標準。(參照 ISO 29115 評估身分登錄、信物管理與身分驗證三階段)	Ⅰ
1.5	權限存取	完成身分鑑別後，除依角色屬性存取控制 (RBAC)落實最小授權原則外，並具基於屬性存取控制 (ABAC) 機制，可將每個工作階段(Session)之動態屬性(如時間、地點等) 納為授權審核條件，動態撤銷、限縮存取授權或即時告警。	Ⅱ
1.6	可視性分析	整合或收容事件日誌，建立定期審查及異常行 為之偵測、告警及回應機制，如集中收容於 SIEM 平台並與資安監控機制(SOC)整合，針對 入侵指標(IOC)或攻擊行為樣態(MITRE ATT&CK TTP)進行即時的判斷與應處(如事件單或 SOAR Playbook 等)。(參照 F-ISAC 威脅情資及金融資 安監控組態基準)	Ⅲ
1.7	自動化治理	建立可依資安政策快速調適之一致性且自動化之管理機制，確保於帳號生命週期之安全性及合規性。	Ⅳ

由金融零信任架構參考指引來看零信任推動的成熟度概念(續)

項次	功能	原則	等級
2.1	設備合規	具有效盤點且可唯一識別(如 TPM 等)納管設備機制，並對其安全要求(如病毒碼、作業系統狀態等)之判斷及應處機制；對未納管設備具有即時偵測及風險控管(如強制隔離)機制。	Ⅰ
2.2	設備合規	具納管設備合規檢測及弱點管理機制(如未更新或具已知資安漏洞)，可持續監控不合規設備並 及時採行風險控管措施(如強制更新、修補弱點、強制隔離或即時告警等)。	Ⅱ
2.3	供應鏈風險	對外部設備(如 BYOD、服務供應商或跨機構協作等)，應建立不低於內部設備防護基準之管控 措施；或限制需經由可控之合規中繼閘道(如 VDI 等)存取。	Ⅰ
2.4	資源存取	可將設備之動態屬性(如是否納管及合規、設備位址、或是否屬外部設備等)納為每個工作階段(Session)之授權審核條件，動態撤銷、限縮存 取授權或即時告警；或具備隔離機制，可即時 偵測並阻斷未合規設備之連線；或於資源存取路徑限制須經可控之合規中繼閘道(如 VDI 等) 存取。	Ⅱ
2.5	威脅防護	對設備活動紀錄具有即時偵測及回應機制 (EDR)，在偵測到威脅指標(IOC)時，可自動隔離或即時應處(如發出事件單即時追蹤處置)。	Ⅲ
2.6	可視性分析	整合或收容事件日誌，建立定期審查及異常行 為之偵測、告警及回應機制，如集中收容於 SIEM 平台並與資安監控機制(SOC)整合，針對 入侵指標(IOC)或攻擊行為樣態(MITRE ATT&CK TTP)進行即時的判斷與應處(如事件單或 SOAR Playbook 等)。(參照 F-ISAC 威脅情資及金融資 安監控組態基準)	Ⅲ
2.7	自動化治理	可依資安政策快速調適之一致性且自動化管理 機制，確保於設備生命週期之安全性及合規性。	Ⅳ

由金融零信任架構參考指引來看零信任推動的成熟度概念(續)

項次	功能	原則	等級
3.1	網路區隔	具網段隔離機制，採最小需求原則限制存取資源之網路連線，並得限制同網段主機間連線及資源存取，防止攻擊者利用遭入侵的主機作為 跳板機進行橫向擴散。	Ⅰ
3.2	網路區隔	具軟體定義網路 (SDN) 或網路微分段 (Micro Segmentation)機制，可以依據業務需求或動態屬性(如人員身分、設備樣態及連線時間等)調 整網路防護邊界；並可以個別主機或個別系統為獨立網路區隔，縮小攻擊表面。	Ⅱ
3.3	流量管理	呈現對系統、端點與網路間連線的相依性關 係，可以單一設備為單位延伸看到相關系統、 端點與網路之狀態，並具備流量異常監控及應 處機制。	Ⅱ
3.4	流量加密	於資源存取路徑之資料傳輸加密 (如採 https 等 加密協定)。	Ⅰ
3.5	網路韌性	對網路連線紀錄具有即時偵測及回應機制(如 NDR)，可因應業務需求、偵測到入侵指標 (IOC)或遭受攻擊時，動態調整網路設定(如調 整網路防護邊界即時隔離、切換備援路由或資 源配置等)或即時告警，以維持網路服務，將對 業務影響最小化。	Ⅲ
3.6	可視性分析	整合或收容事件日誌，建立定期審查及異常行 為之偵測、告警及回應機制，如集中收容於 SIEM 平台並與資安監控機制(SOC)整合，針對 入侵指標(IOC)或攻擊行為樣態(MITRE ATT&CK TTP)進行即時的判斷與應處(如事件單或 SOAR Playbook 等)。(參照 F-ISAC 威脅情資及金融資 安監控組態基準)	Ⅲ
3.7	自動化治理	具可依資安政策、工作流程情境及網路態勢快速調適之網路管理機制。	Ⅳ

由金融零信任架構參考指引來看零信任推動的成熟度概念(續)

項次	功能	原則	等級
4.1	存取授權	以作業屬性及風險區隔角色，並依角色風險等級定義授權條件(如身分及設備鑑別之等級)， 採最小授權原則定義授權範圍；並針對特權作業採獨立角色授權(不混用於非特權作業)，減少特權帳號之濫用及風險。	Ⅰ
4.2	存取授權	可將帳號動態屬性(如 MFA 強度、設備合規、連線時間及地點等)納為每個工作階段(Session) 之授權審核條件；並針對特權作業採即時存取(Just-in-Time Access)機制，可動態撤銷、限縮存取授權或即時告警。	Ⅱ
4.3	威脅防護	對應用程式活動紀錄具有即時偵測及回應機 制，並可依據使用者行為或使用模式等因素評 估風險(如雖屬授權範圍但不符作業常規等)， 動態撤銷、限縮存取授權或即時告警。	Ⅲ
4.4	程式安全	從網際網路及防護邊界內部對應用程式執行資 安檢測(如源碼檢測、弱點掃描、滲透測試 等)，確保應用程式本身安全性，具直接開放經 Internet 存取之防護能力。	Ⅱ
4.5	程式部署	為應用程式開發、測試及部署建立持續整合及部署(CI/CD) 通道，分階段採最小授權原則，並評估採自動化機制減少人員介入誤失，或由 不同團隊執行落實權責分離。	Ⅱ
4.6	可視性分析	整合或收容事件日誌，建立定期審查及異常行 為之偵測、告警及回應機制，如集中收容於 SIEM 平台並與資安監控機制(SOC)整合，針對 入侵指標(IOC)或攻擊行為樣態(MITRE ATT&CK TTP)進行即時的判斷與應處(如事件單或 SOAR Playbook 等)。(參照 F-ISAC 威脅情資及金融資 安監控組態基準)	Ⅲ
4.7	自動化治理	可依資安政策快速調適之一致性且自動化管理機制，確保於應用程式生命週期之安全性及合 規性。	Ⅳ

由金融零信任架構參考指引來看零信任推動的成熟度概念(續)

項次	功能	原則	等級
5.1	外洩防護	針對機敏資料部署防止資料外洩防護機制，如 依據資料特徵之 DLP、資料不落地等。	I
5.2	外洩防護	具監控資料存取和使用情況機制，可依據資料 存取行為或資料處理模式等因素評估風險(如雖 屬授權範圍但不符作業常規等)，動態撤銷、限 縮存取授權或即時告警，偵測及阻止疑似資料 外洩之行為。	III
5.2	資料分類	建立資料盤點、分類及、標籤機制，確保依資 料分類分級落實資料保護政策，並支援最小授權規則。	I
5.3	資料可用性	建立本地端高可用性、異地端備份，並確保備 份資料可被有效保護(如離線備份、儲存於隔離環境、防止寫入等)及有效還原。	I
5.4	資料存取	可將資料存取的動態屬性(如 MFA 強度、設備 合規、時間、地點等) 納為每個工作階段 (Session)之授權審核條件，並具啟動重新驗證 之機制，可動態撤銷、限縮存取授權或即時告警。	II
5.5	資料加密	依資料分級對機敏性資料加密儲存，並確保加密金鑰的安全管理。	I
5.6	可視性分析	整合或收容事件日誌，建立定期審查及異常行 為之偵測、告警及回應機制，如集中收容於 SIEM 平台並與資安監控機制(SOC)整合，針對 入侵指標(IOC)或攻擊行為樣態(MITRE ATT&CK TTP)進行即時的判斷與應處(如事件單或 SOAR Playbook 等)。(參照 F-ISAC 威脅情資及金融資 安監控組態基準)	III
5.7	自動化治理	可依資安政策快速調適之一致性且自動化管理 機制，確保於資料生命週期之安全性及合規 性。	IV

英國網路安全中心：如何推動零信任網路

階段	原則	目的
建立安全通道	1. 確保網路流量安全傳輸	建立可信的通訊基礎，例如 TLS、mTLS、加密通道。
做出存取決策	2. 先執行政策，再授予存取 3. 以多重訊號進行存取決策	在授權前，依據身分、裝置、位置、風險等資訊做決策。
降低風險與持續驗證	4. 降低應用程式暴露面 5. 限制遭入侵後的影響範圍 6. 持續依情境重新評估存取	假設攻擊可能成功，因此減少暴露面、限制橫向移動，並持續重新驗證。
維運與韌性	7. 確保 ZTNA 架構具備可觀測性 8. 兼顧韌性與高可用性設計	確保系統可監控、可稽核、可恢復，不因單點故障影響服務。

https://www.ncsc.gov.uk/collection/zero-trust/zero-trust-network-access-ztna/how-to-implement-ztna

歐盟的情況

- 並沒有特別要求執行零信任，但有作為資安最佳實務的例子：
  - Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union, amending Regulation (EU) No 910/2014 and Directive (EU) 2018/1972, and repealing Directive (EU) 2016/1148 (NIS 2 Directive) 中有作為網路健康實務的範例：
    - Essential and important entities should adopt a wide range of basic cyber hygiene practices, such as *zero-trust principles*, software updates, device configuration, network segmentation, identity and access management or user awareness, organise training for their staff and raise awareness concerning cyber threats, phishing or social engineering techniques.
- 零信任的相關要求會以實際的資安要求而呈現

NIS2 (Network and Information Security Directive 2)

- 是歐盟的網路與資訊安全指令
- 目的
  - 提升歐盟整體資安韌性
  - 建立一致的最低資安要求
  - 強化跨國合作
- 最核心的資安要求在第 21 條，要求可以透過以下方法控管風險：
  - 建立風險分析及資訊系統安全政策
  - 資安事件處理
  - 業務持續營運
  - 強化供應鏈安全
  - 網路與資訊系統之取得、開發及維護安全
  - 評估資安風險管理措施有效性之政策與程序
  - 基本資安衛生措施及資安教育訓練。
  - 密碼學及適當情況下之加密政策與程序
  - 人力資源安全
  - 存取控制政策及資產管理
  - 視情況採用：多因驗證或持續性身分驗證方案；安全之語音、視訊及文字通訊；安全之緊急通訊系統。

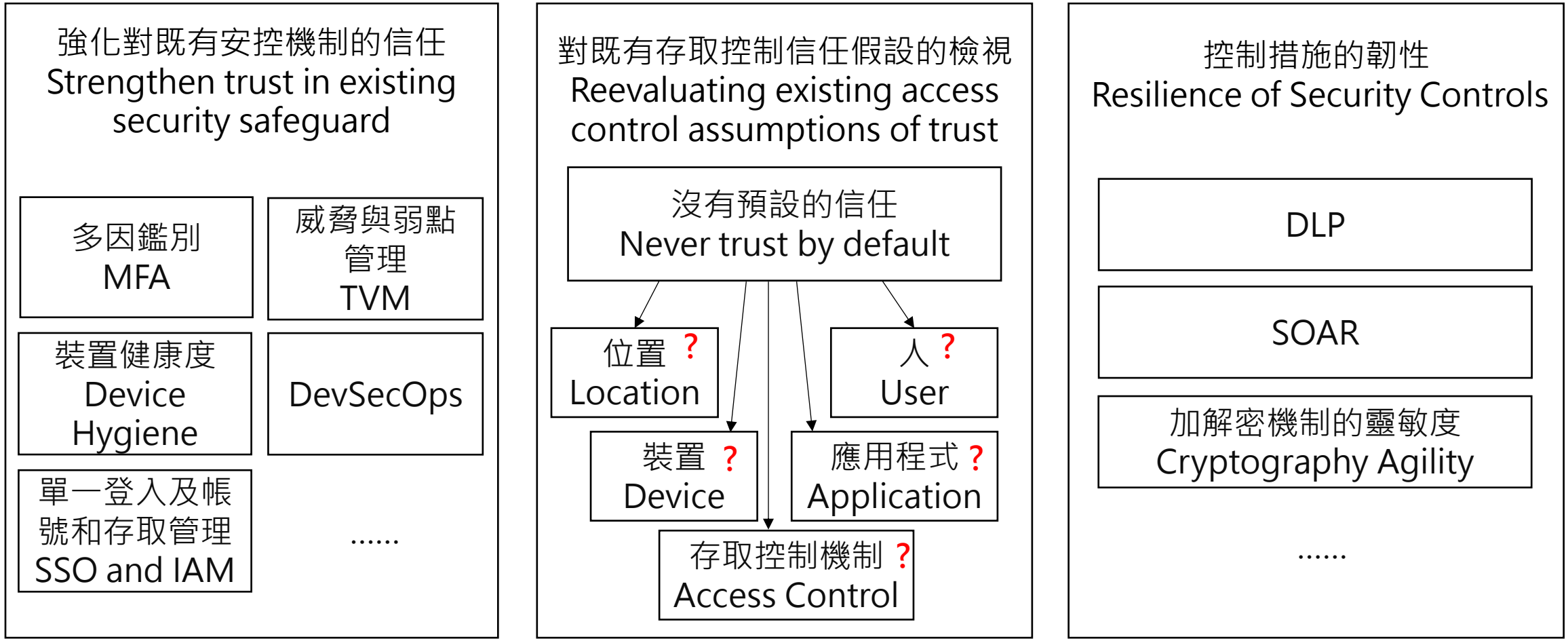
歐盟金融業數位營運韌性法規 (Digital Operational Resilience Act, DORA) EU 2022/2554

- 希望建立金融業一致的資安與營運韌性要求，以因應：
  - 勒索病毒
  - 供應鏈攻擊
  - 雲端服務中斷
  - 第三方風險
- 2023/1/16 生效，2025/1/17 全面適用
- 有強化
  - 身分鑑別機制
    - 沒有強調持續身分鑑別
  - 持續監控
  - 快速事件回應
    - 但沒有到自動回應 (如 SOAR)

歐盟網路韌性法案 (Cyber Resilience Act, CRA) (EU 2024/2847)

- 歐盟制定 CRA，希望：所有具有數位元件的產品，從設計開始就具備資安能力
- 針對產品，要求所有具有數位元件的產品，從設計開始就具備資安能力。
- CRA 並非零信任法規，而是產品安全法規。
  - 透過「從設計就考慮到安全」、「安全開發」、「弱點管理」及「安全更新」等要求，提升產品本身的可信度

目前零信任架構的發展上，有以下重點 The development of zero trust architecture focuses on the following key points



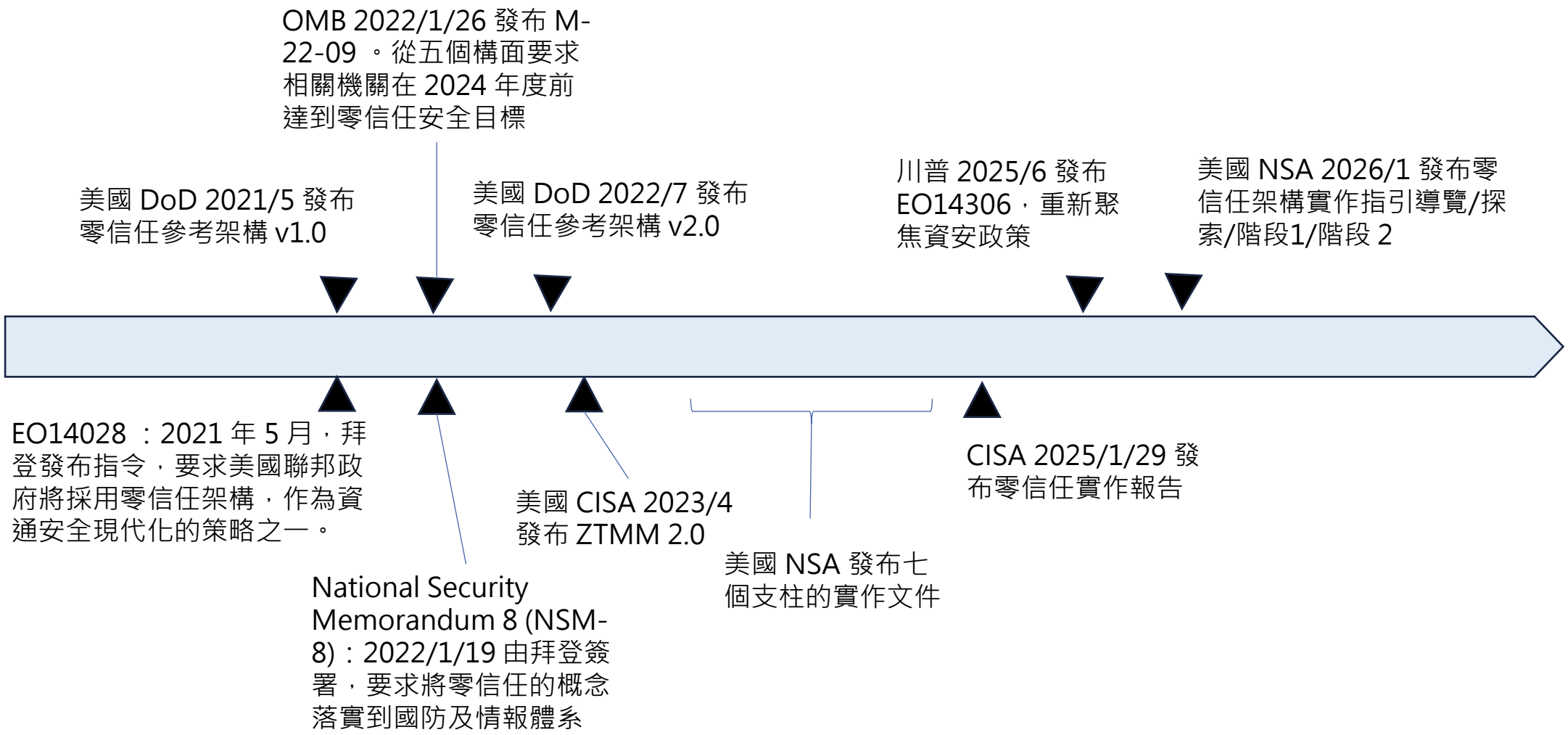
零信任架構的本質與核心概念

從美國的要求來看各項資安控制的意義

零信任架構的實作架構

AI 代理人與零信任架構

結論


OMB 2022/1/26 發布 M-22-09 。從五個構面要求相關機關在 2024 年度前達到零信任安全目標
美國 DoD 2021/5 發布零信任參考架構 v1.0
美國 DoD 2022/7 發布零信任參考架構 v2.0
川普 2025/6 發布 EO14306，重新聚焦資安政策
美國 NSA 2026/1 發布零信任架構實作指引導覽/探索/階段1/階段 2
EO14028 ：2021 年 5 月，拜登發布指令，要求美國聯邦政府將採用零信任架構，作為資通安全現代化的策略之一。
National Security Memorandum 8 (NSM-8)：2022/1/19 由拜登簽署，要求將零信任的概念落實到國防及情報體系
美國 CISA 2023/4 發布 ZTMM 2.0
美國 NSA 發布七個支柱的實作文件
CISA 2025/1/29 發布零信任實作報告

EO 14028

- 各機關要提出 ZTA 實作計畫 → OMB M-22-09
- 基於 NIST 的標準
  - NIST SP 800-207
  - NIST SP 1800-35
- CISA CISA 必須把既有聯邦資安服務現代化，使其能支援雲端運算環境與零信任架構。
  - CISA ZTMM
- 國防系統要依此建立更具體策略
  - DoD ZTA Strategy

Administration of Joseph R. Biden, Jr., 2021

Executive Order 14028—Improving the Nation's Cybersecurity
May 12, 2021

By the authority vested in me as President by the Constitution and the laws of the United States of America, it is hereby ordered as follows:

Section 1. Policy. The United States faces persistent and increasingly sophisticated malicious cyber campaigns that threaten the public sector, the private sector, and ultimately the American people's security and privacy. The Federal Government must improve its efforts to identify, deter, protect against, detect, and respond to these actions and actors. The Federal Government must also carefully examine what occurred during any major cyber incident and apply lessons learned. But cybersecurity requires more than government action. Protecting our Nation from malicious cyber actors requires the Federal Government to partner with the private sector. The private sector must adapt to the continuously changing threat environment, ensure its products are built and operate securely, and partner with the Federal Government to foster a more secure cyberspace. In the end, the trust we place in our digital infrastructure should be proportional to how trustworthy and transparent that infrastructure is, and to the consequences we will incur if that trust is misplaced.

Incremental improvements will not give us the security we need; instead, the Federal Government needs to make bold changes and significant investments in order to defend the vital institutions that underpin the American way of life. The Federal Government must bring to bear the full scope of its authorities and resources to protect and secure its computer systems, whether they are cloud-based, on-premises, or hybrid. The scope of protection and security must include systems that process data (information technology (IT)) and those that run the vital machinery that ensures our safety (operational technology (OT)).

https://www.govinfo.gov/content/pkg/DCPD-202100401/pdf/DCPD-202100401.pdf

由美國 OMB 的要求來看對於零信任架構遵循的要求

EXECUTIVE OFFICE OF THE PRESIDENT
OFFICE OF MANAGEMENT AND BUDGET
WASHINGTON, D.C. 20503

要求美國政府單位在 2024 年底前實現零信任的目標

January 26, 2022

M-22-09

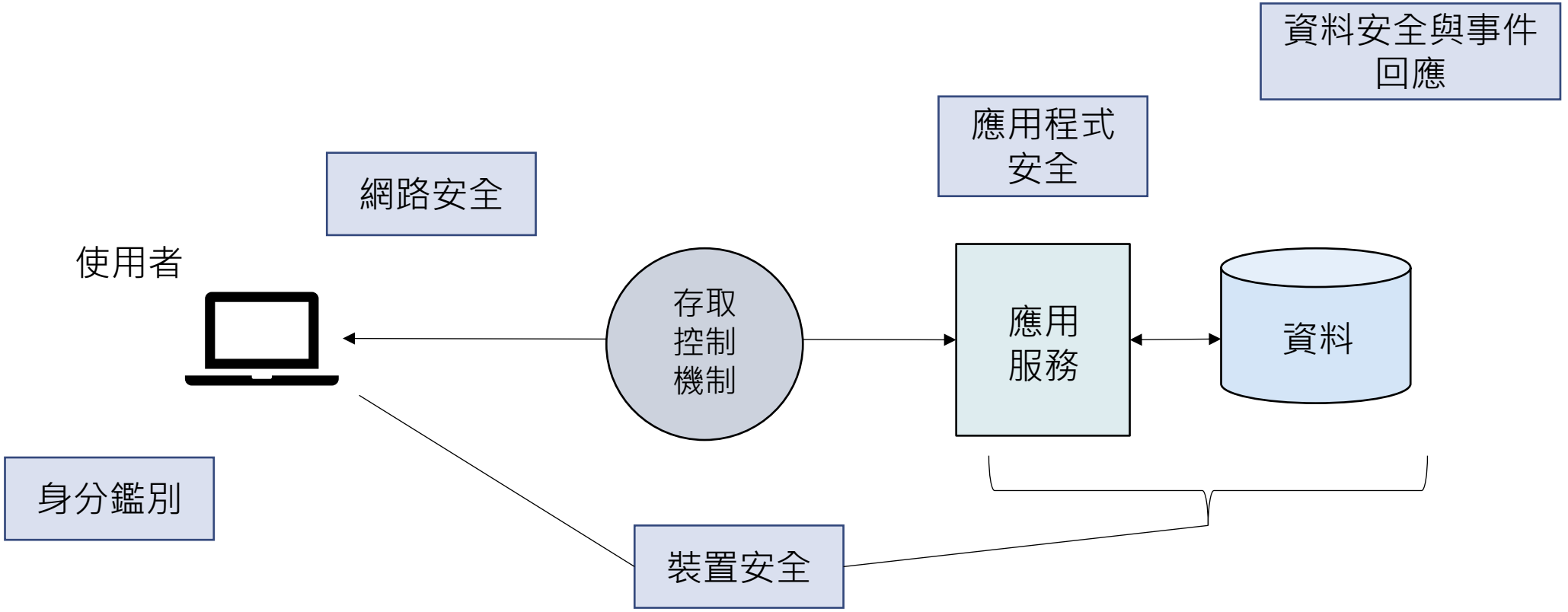
MEMORANDUM FOR THE HEADS OF EXECUTIVE DEPARTMENTS AND AGENCIES

FROM: Shalanda D. Young
Acting Director

SUBJECT: Moving the U.S. Government Toward Zero Trust Cybersecurity Principles

This memorandum sets forth a Federal zero trust architecture (ZTA) strategy, requiring agencies to meet specific cybersecurity standards and objectives by the end of Fiscal Year (FY) 2024 in order to reinforce the Government's defenses against increasingly sophisticated and persistent threat campaigns. Those campaigns target Federal technology infrastructure, threatening public safety and privacy, damaging the American economy, and weakening trust in

OMB 備忘錄當中的五個要求類別



OMB M-22-09 的要求構面

- 備忘錄要求相關機關在 2024 年度前達到特定零信任安全目標
- 目標可以分成五類：

採用統一身分識別，並且用多因認證來減少被釣魚的機會

將網路傳輸加密

按照資料分類進行保護

識別

裝置

網路

應用程式

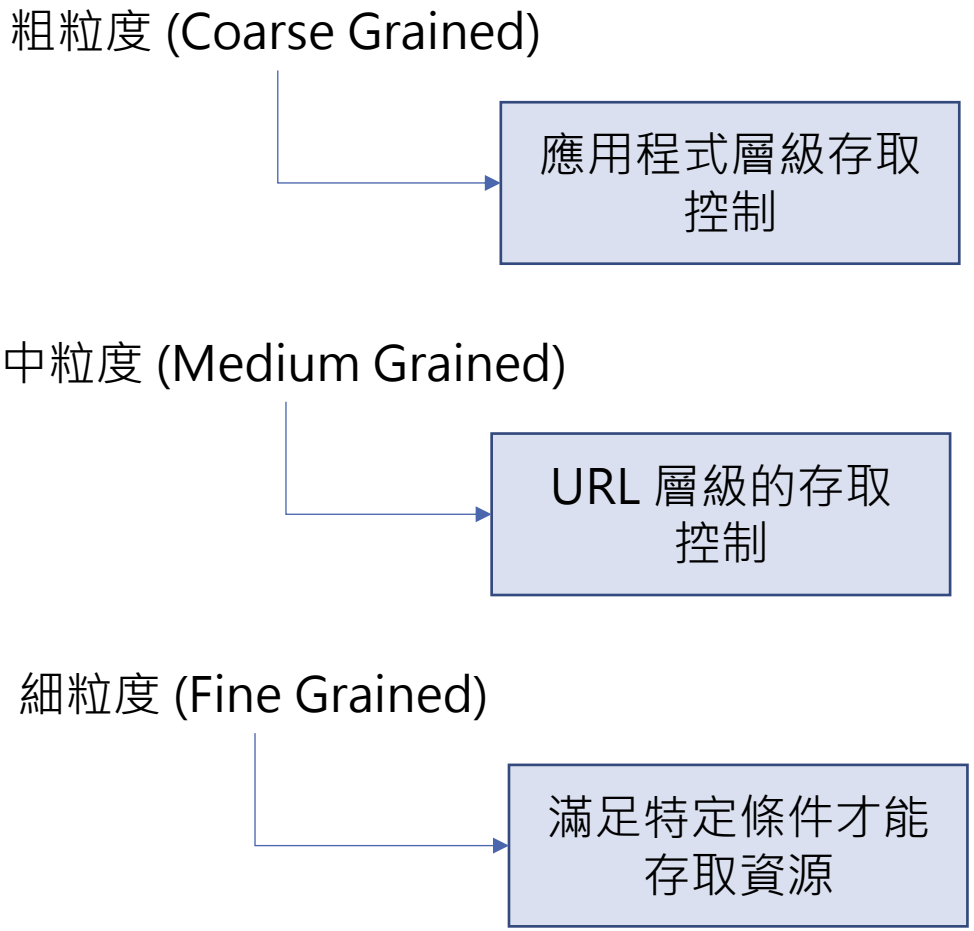
資料

掌握所有裝置

對所有程式進行測試

OMB M-22-09的要求–身分識別

- 目標：員工使用全企業通用的身分識別去存取工作時所用的應用程式。使用避免釣魚的多因鑑別來避免個人收到複雜的線上攻擊
  - 減少使用者因為被釣魚而被當作跳板攻擊的機率與影響
- 動作：
  - 建立採用集中化的企業身分識別
    - Silo 與集中化的管理
  - 使用多因鑑別
    - 身分鑑別不是網路層級，而是要對各別使用者身分
    - 建議移除密碼中要使用特殊字元以及定期更新密碼的要求
  - 存取控制能夠更細膩 (具粒度)
    - 至少要能針對存取裝置進行限制



OMB M-22-09的要求–裝置管理

- 目標：聯邦政府有其所使用與授權供政府作業用的裝置清單。並且能夠偵測對於這些裝置的意外事件並做出回應。
- 動作：
  - 建立資產清單
  - 參加美國網路與骨幹安全司(Cybersecurity and Infrastructure Security Agency, CISA)的 CDM (Continuous Diagnostics and Mitigation) 計畫
  - 確保每個使用者所操作的公發裝置都有安裝機構選擇的端點監控與回應工具(Endpoint Detection and Response, EDR)

資產管理 – 了解哪些東西可被網路連結 (What is on the network?)

身分與存取管理 – 了解哪些人在網路上 (Who is on the network?)

網路安全管理– 了解網路上發生什麼 (What is happening on the network?) 與如何保護網路 (How to protect the network?)

資料保護管理 – 了解如何保護資料 (How is data protected?)

OMB M-22-09的要求—網路

- 目標：機關對所有 DNS 與 HTTP 交通加密，並且按照應用切割網路。聯邦政府應該要找出傳輸電子郵件時有效的電子郵件加密方法。
- 動作：
  - 加密 DNS 流量 (DNS over HTTPS 或 DNS over TLS)
  - 強制使用 HTTPS
  - 加密電子郵件流量
  - 依應用切割網路



5625	70.908591	31.13.87.1	192.168.0.16	TLSv1.2	100 Application Data
5626	70.911097	192.168.0.16	1.1.1.1	TLSv1.2	95 Application Data
5627	70.911189	192.168.0.16	1.1.1.1	TLSv1.2	118 Application Data
5628	70.918173	1.1.1.1	192.168.0.16	TLSv1.2	89 Application Data
5629	70.919454	1.1.1.1	192.168.0.16	TLSv1.2	252 Application Data

OMB M-22-09的要求–應用程式

- 目標：機關應該對於像是網路連線的應用程式進行嚴格的實務測試，並且安排好定期檢測的時程，並且歡迎外部的弱點報告
- 動作：
  - 應用程式安全測試
  - 善用第三方進行測試
  - 歡迎外部應用程式弱點報告
  - 確保可網際網路存取之應用程式的安全性
  - 發覺可被網際網路存取的應用程式
  - 建立 DevSecOps 的程序，而避免安全檢查工作被繞過

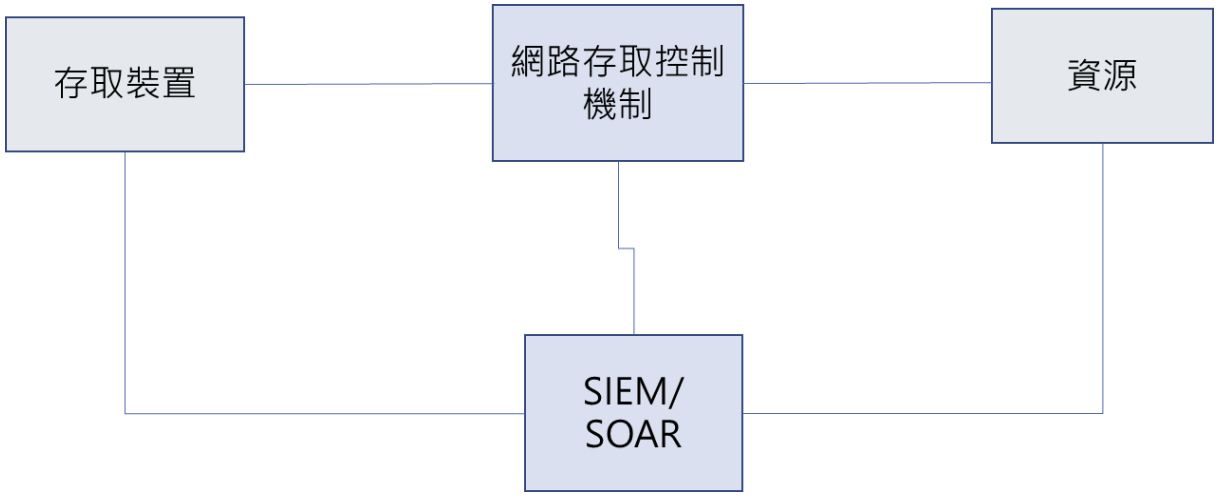
確保系統不具備常見的弱點

能利用多方觀點來協助促進系統安全

減少系統被入侵的機率

OMB M-22-09的要求 – 資料

- 目標：
  - 機關依照資料分類，掌控資料流，並對資料進行保護。並且運用雲端安全服務與工具，去偵測、分類，與保護敏感資料，並且實作全企業得記錄與資訊分享控制機制。
- 動作：
  - 符合聯邦資料安全策略
  - 採用 SOAR 等自動化安全回應機制
  - 對於存取雲端服務上的敏感服務進行稽核
  - 及時對記錄進行評估





Zero Trust Architecture Implementation

January 29, 2025

Fiscal Year 2024 Report to Congress

Homeland Security

Cybersecurity and Infrastructure Security Agency

- CISA 負責提供 Zero Trust Maturity Model (ZTMM) 與技術協助。
- 美國國會要求行政部門定期回報 Zero Trust 推動成果，因此發布本報告。
- 主要目的：
  - 彙整 Federal Civilian Executive Branch (FCEB) 各機關截至 FY2024 的零信任推動成果。
  - 評估各機關對 OMB M-22-09 要求的落實情形。
  - 分析導入過程中的最佳實務、經驗學習 (Lessons Learned)，與挑戰。作為後續 FY2026 零信任規劃與跨機關合作的重要依據。
- 總體發現：CISA 認為聯邦民用行政機關在過去三年已有明顯進展，尤其是 Identity、Device、Network 三個領域。但整體仍未達到真正「整合式零信任能力」的狀態。主要瓶頸是 legacy 系統、預算、人力、治理分散，以及資料治理成熟度不足。

身分

- 主要進展：
  - Phishing-resistant MFA 的導入大幅增加。
  - 許多機關開始集中化 ICAM
  - 成功機關通常有高層支持、集中治理、跨部門協作
- 主要挑戰：
  - 身分管理系統分散，尤其大型機關底下有許多 bureau，各自有不同架構。
  - Legacy/mainframe 系統難以補上現代 MFA 與授權機制。
  - 小型機關缺乏 Identity-as-a-Service、PAM、IGA 等共享服務與專業人力。
  - 跨機關身分互信與 federation 還不成熟。

是進展最快的領域，但真正困難不只是開 MFA，而是建立全機關一致、可互通、可持續授權的 ICAM 架構。

裝置

- 主要進展：
  - 越來越多機關使用 CDM 能力建立資產盤點。
  - 軟硬體覆蓋率明顯提升。
  - EDR 部署大幅擴展；
  - CDM dashboard 開始支援漏洞管理、事件應變與已知遭利用漏洞 KEV 的風險分析。
- 主要挑戰：
  - Legacy IT、OT、ICS、IoT 等非傳統資產難以納入完整盤點。
  - 高度分散的 IT 環境讓全企業層級的可視性落實困難。
  - 有些舊系統無法整合 EDR、現代化資產管理或零信任訊號。

裝置領域已從「看不見」走向「逐步可盤點」，但 OT、IoT、老舊系統仍是零信任可視性的缺口。

網路

- 主要進展：
  - CISA Protective DNS 上線
  - HTTPS / HSTS compliance 長期維持在 90% 以上。
  - CISA 與 OMB 建立 DNS Modernization Community of Action，推動 encrypted DNS。
  - 部分 SASE vendor 已整合 CISA Protective DNS。
- 主要挑戰：
  - 許多單位機制原本不支援 encrypted DNS。
  - 機關知道要做 ZTNA、SASE、SSE、network segmentation，但不知道從哪裡開始。
  - 環境隔離 migration plan 很難

網路領域在 DNS/HTTPS 加密上進展顯著，但從傳統邊界網路轉向環境隔離與 ZTNA，仍需要架構路線圖與供應商支援。

應用與工作負載

- 主要進展：
  - 機關開始建立 應用程式安全測試與弱點掃描計畫。
  - 51 個 agencies onboard CISA 的 VDP platform。47 個 agencies 建立自己的弱點發覺。
  - CISA 已將 26 個 agencies 納入持續滲透測試。
- 主要挑戰：
  - 這一領域成熟度低於其他。
  - 需要改造開發流程，導入 DevSecOps、Secure by Design、immutable workloads。
  - Legacy code 數量龐大，改造成本高。
  - 商用應用與 SaaS 本身漏洞多

應用領域已開始補上測試與漏洞揭露能力，但要走向 DevSecOps、immutable workloads 和 secure-by-design，仍是較長期的工程轉型。

資料

- 主要進展：
  - Data at rest 與 data in transit encryption 持續改善。
  - OMB、CISA 與聯邦機關成立工作小組。
  - 2024 年發布 Federal Zero Trust Data Security Guide，作為資料安全策略基礎。
- 主要挑戰：
  - 是最困難、也最不成熟的領域之一。
  - 資料分類、標籤等都還缺乏一致方法。
  - 結構化與非結構化資料量龐大，
  - legacy data 更難處理。現有資料盤點細緻度不足，無法支援真正物件層級的存取控制與監控。

資料領域是零信任能否真正降低企業風險的關鍵，但目前仍受限於資料分類、標籤、治理與細粒度存取控制能力不足。

CISA ZTMM 的身分 (Identity) 構面

- 身分是用來唯一識別並描述使用者或非人個體 (Entity) 的屬性或屬性集合
- 要能確保在對的時間、基於正確的目的，在不給予過多權限的情況下，僅能存取適當的資源

身分鑑別

身分儲存

風險評估

存取管理

可視性與分析能力

自動化與協作能力

治理能力

對於身分的成熟度要求

功能	傳統	起始	進階	最佳化
身分鑑別	收集使用者與個體的活動紀錄，並且進行例行的人工檢視	使用多因鑑別，而使用密碼以及一個其他的動態屬性 (像是位置或活動)	使用能夠抵抗網路釣魚的多因認證與屬性，並開始採用無密碼身分鑑別	會持續透過防止網路釣魚的 MFA 驗證使用者身分
身分儲存	只使用個系統自我管理或落地的身分儲存	有限度的整合各系統與雲端的身分儲存	整合各系統與雲端的身分儲存，並開始強化安全	適當與安全的整合所有身分儲存
風險評估	有限度的決定身分識別的風險 (如列在被破解資料庫)	使用人工方法與靜態規則來決定某身分識別的風險	使用自動化分析與動態規則來通知存取與回應活動	基於持續的分析的即時與動態規則，來提供持續的保護
存取管理	進行授權後週期性的對特權與非特權帳號的權限進行檢視	會透過自動審查來使得授權失效	依活動與資源，進行基於需求與交談的存取控制	依各別活動與資源的需求，即時進行授權並只提供所需的權限

對於身分的成熟度要求 (續)

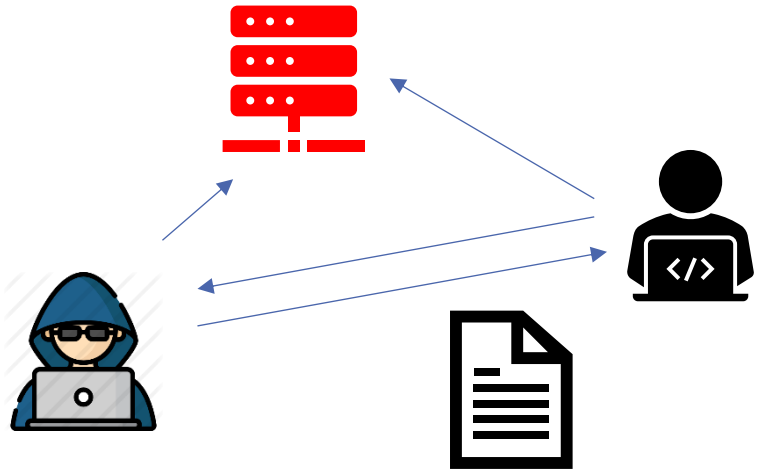
功能	傳統	起始	進階	最佳化
可視性與分析能力	尤其針對特權帳號，收集使用者與個體的活動紀錄，並部分執行例行性的人工分析	除了進行例行性的人工分析外，開始進行部分自動化分析，並會尋找關聯性	能夠跨使用者與個體在不同種類紀錄進行自動分析，並且會想辦法進行補強以解決可視性的差異	對使用者的各種紀錄進行分析，而提供完整的可視性與情境感知
自動化與協作能力	採用人工方式管理各系統的帳號	除了特權帳戶和外部帳號外，一般使用者帳號開始用自動化的方式進行管理	除了特權帳號外，其他帳號可以透過整合的方式進行自動化管理	所有的帳號都用整合的方式進行自動化管理
治理能力	實作身分管理政策，並且透過靜態規則與人工審查的方式去落實	開始訂定企業範圍的身分管理政策，但自動化程度較低，需要以人工的方式更新	訂定企業範圍的身分管理政策，並且使用自動化工具去落實政策，並且定期更新政策	採用全自動化的身分管理政策，並且持續性的落實這些政策。並讓這些政策的內容可以動態更新

多因認證

- 憑所知道的資訊
  - 帳號/密碼
  - PIN 碼
- 憑所有的資訊
  - 晶片卡
  - 識別證
- 憑本身的生物特徵
  - 指紋
  - 虹膜
  - 人臉辨識

如何防止撞庫攻擊？

如何防止被網路釣魚以後登入系統？



NIST SP 800-63-3 的身分鑑別等級

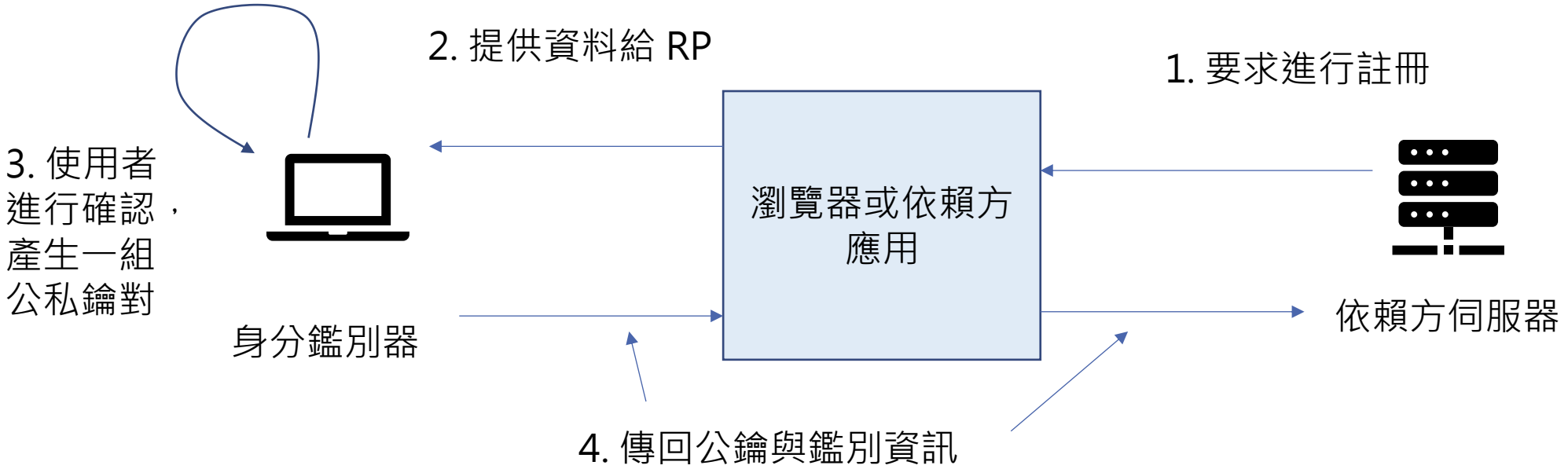
- 身分確認等級
  - IAL1: 屬性可以被自我宣告或是被視為是自我宣告
  - IAL2: 透過遠端或人面對面驗證身分
  - IAL3: 透過人面對面的驗證身分
- 鑑別保證等級
  - AAL1: 提供最基本的單因子鑑別
  - AAL2: 透過雙因認證與安全鑑別協定，去確認鑑別器
  - AAL3: 除了滿足 AAL2，還要確認是使用硬體
- 聯合保證等級
  - FAL1: RP 允許身分提供者所發出的不記名聲明，而該聲明是由 IdP 所簽署
  - FAL2: 聲明有被加密，而 RP 可將之解密
  - FAL3: 註冊者能夠用自身的簽章去做證明
- 技術服務中心文件中提到：
  - *政府機關導入零信任網路應至少達到 IAL2/AAL3/FAL2 等級*

可以思考 IAL 和產品關係

Fido 2 的概念

不過 Fido 只是針對身分辨識機制的強化，沒法做到持續身分鑑別

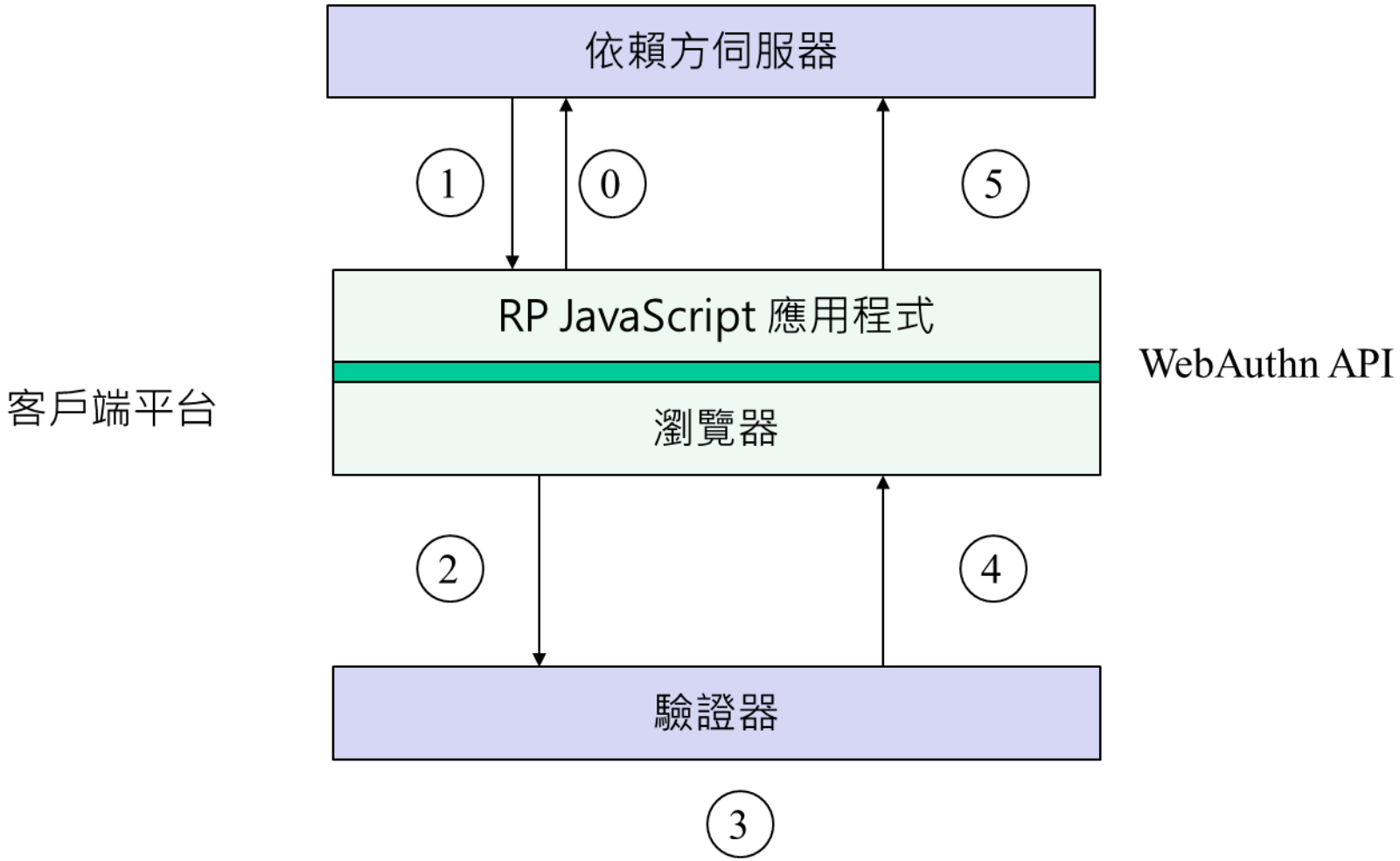
其實 WebAuthn 還有可以保護生物特徵的效果



如果細分，Fido 2 可以分成 WebAuthn 與 CTAP 兩個協定，前者著重於瀏覽器或應用，後者針對與鑑別器間的通訊

在 Fido 1.0 的時候，分成 UAF (Universal Authentication Framework) 與 U2F，UAF 和上述程序類似，U2F 主要針對雙因子鑑別

Fido 機制的運作方式



- Select
  - a0:00:00:06:47:2F:00:01

frame contains 00A4040008

No.	Time	Source	Destination	Protocol	Length	Info
575	8.232498	host	2.4.1	USB	56	URB_BULK out
731	13.948565	host	2.4.1	USB	56	URB_BULK out

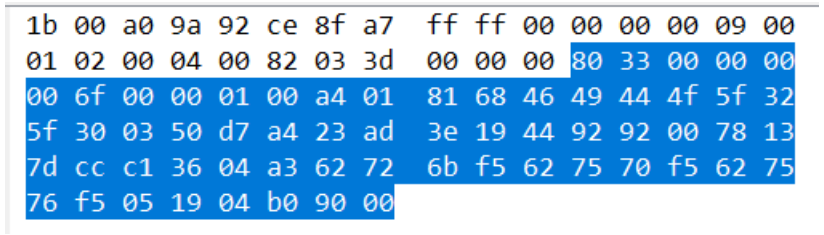
- Response
  - 800a000000006f000001<u>4649444f5f325f30900</u>

```
00  1b 00 a0 9a 92 ce 8f a7  ff ff 00 00 00 00 09 00   ···· ····
10  01 02 00 04 00 82 03 14  00 00 00 80 0a 00 00 00   ···· ···· ····
20  00 6f 00 00 01 46 49 44  4f 5f 32 5f 30 90 00      ·o···FID O_2_0··
```

- authenticatorGetInfo
  - fffe0100078010000010400

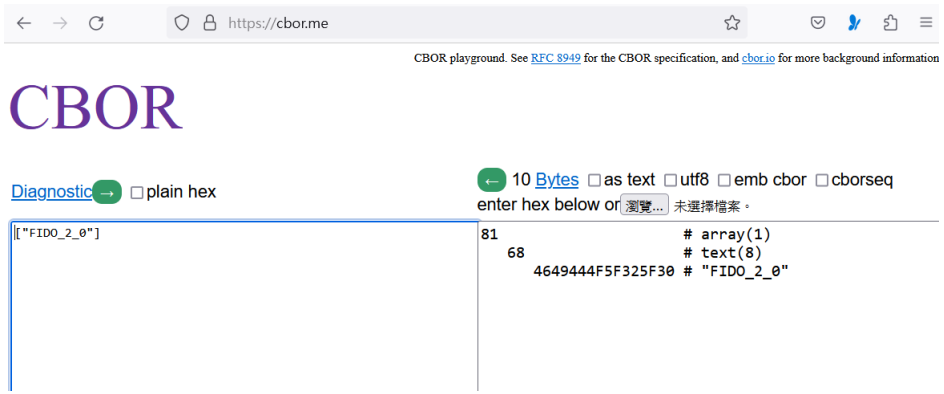
```
1b 00 a0 9a 92 ce 8f a7  ff ff 00 00 00 00 09 00   ........ ........
00 02 00 04 00 01 03 16  00 00 00 6f 0c 00 00 00   ........ ...o....
00 6f 00 00 01 ff fe 01  00 07 80 10 00 00 01 04   .o...... ........
00                                                 .
```

CLA	INS	P1	P2	Data In	Le
0x80	0x10	0x00	0x00	CTAP Command Byte || CBOR Encoded Data	Variable



```
1b 00 a0 9a 92 ce 8f a7  ff ff 00 00 00 00 09 00
01 02 00 04 00 82 03 3d  00 00 00 80 33 00 00 00
00 6f 00 00 01 00 a4 01  81 68 46 49 44 4f 5f 32
5f 30 03 50 d7 a4 23 ad  3e 19 44 92 92 00 78 13
7d cc c1 36 04 a3 62 72  6b f5 62 75 70 f5 62 75
76 f5 05 19 04 b0 90 00
```

1b00a09a92ce8fa7ffff0000000009000102000400820330d0000008033000000006f00000100a4018168464944f5f325f300350d7a423ad3e19449292007813 7dccc13604a362726bf5627570f5627576f5051904b09000



https://cbor.me

CBOR playground. See RFC 8949 for the CBOR specification, and cbor.io for more background information

CBOR

Diagnostic → ☐plain hex

← 10 Bytes ☐as text ☐utf8 ☐emb cbor ☐cborseq

enter hex below or 瀏覽... 未選擇檔案。

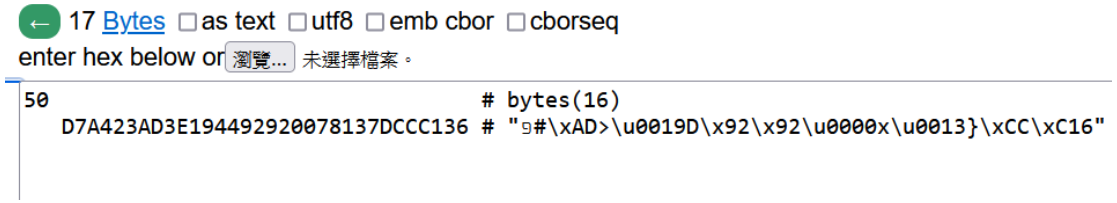
```
["FIDO_2_0"]
```

```
81                  # array(1)
   68               # text(8)
      4649444F5F325F30 # "FIDO_2_0"
```

0181684649444f5f325f30 = Version = FIDO_2_0

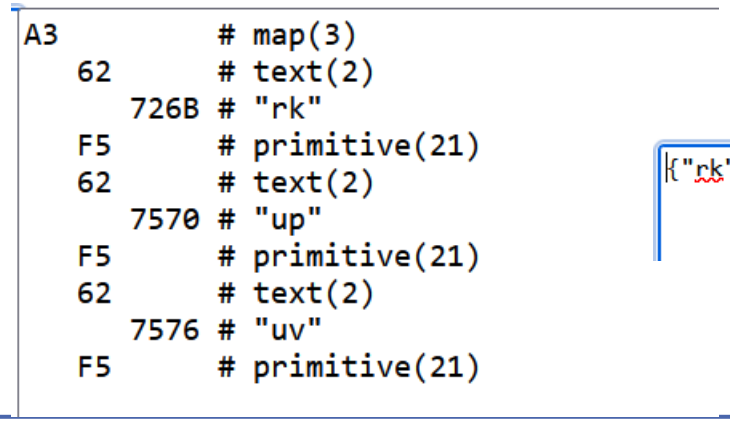
versions (0x01)	Array of strings	Required	List of supported versions. Supported versions are: "FIDO_2_1" for CTAP2.1 / FIDO2 / Web Authentication authenticators, "FIDO_2_0" for CTAP2.0 / FIDO2 / Web Authentication authenticators, "FIDO_2_1_PRE" for CTAP2.1 Preview features and "U2F_V2" for CTAP1/U2F authenticators.

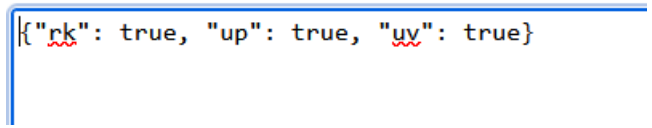
[03]50d7a423ad3e19449292007813 7dccc136 ->
aaguid d7a423ad3e19449292007813 7dccc136



aaguid (0x03)	Byte String	Required	The claimed AAGUID. 16 bytes in length and encoded the same as MakeCredential AuthenticatorData, as specified in [WebAuthn].

[04]a362726bf5627570f5627576f5





051904b0

maxMsgSize (0x05)	Unsigned Integer	Optional	Maximum message size supported by the authenticator.

```
19 04B0 # unsigned(1200)
```

- authenticatorGetAssertion

```
20  00 6f 00 00 01 ff fe 01  00 76 80 10 00 00 70 02   ·o····· ·v····p·
30  a4 01 6b 77 65 62 61 75  74 68 6e 2e 69 6f 02 58   ··kwebau thn.io·X
40  20 f6 00 5d 20 58 d8 65  c7 a6 2a a0 d6 91 0b 60    ··] X·e ··*····`
50  43 0b 7b 74 ff 43 73 54  39 88 cb 10 f6 1d 6f f6   C·{t·CsT 9·····o·
60  f0 03 81 a2 62 69 64 58  20 d9 06 00 a3 4b 3a 36   ····bidX  ····K:6
70  bb ce 75 38 8d 6c 35 42  d8 65 ce 82 fa 8f dc a6   ··u8·l5B ·e·····
80  3a e7 43 92 6e 20 69 85  cc 64 74 79 70 65 6a 70   :·C·n i· ·dtypejp
90  75 62 6c 69 63 2d 6b 65  79 05 a1 62 75 70 f4 00   ublic-ke y··bup··
```

70 02 (Command 為authenticatorGetAssertion)
a4 01 6b 77 65 62 61 75 74 68 6e 2e 69 6f 02 58 20 f6 00 5d 20 58 d8 65 c7 a6 2a a0 d6 91 0b 60 43 0b 7b 74 ff 43 73 54 39 88 cb 10 f6 1d 6f f6 f0 03 81 a2 62 69 64 58 20 d9 06 00 a3 4b 3a 36 bb ce 75 38 8d 6c 35 42 d8 65 ce 82 fa 8f dc a6 3a e7 43 92 6e 20 69 85 cc 64 74 79 70 65 6a 70 75 62 6c 69 63 2d 6b 65 79 05 a1 62 75 70 f4 00

```
# CBOR sequence with 2 elements
A4                                      # map(4)
   01                                   # unsigned(1)
   6B                                   # text(11)
      776562617574686E2E696F            # "webauthn.io"
   02                                   # unsigned(2)
   58 20                                # bytes(32)
      F6005D2058D865C7A62AA0D6910B60430B7B74FF4373543988CB10F61D6FF6F0 # "\xF6\u0000]
X\xD8eĞ*\xA0\v`C\v{t\xFFCsT9\x88\xCB\u0010\xF6\u001Do\xF6\xF0"
   03                                   # unsigned(3)
   81                                   # array(1)
      A2                                # map(2)
         62                             # text(2)
            6964                        # "id"
         58 20                          # bytes(32)
            D90600A34B3A36BBCE75388D6C3542D865CE82FA8FDCA63AE743926E206985CC #
"\xD9\u0006\u0000\xA3K:6\xBB\xCEu8\x8Dl5B\xD8e\u0382\xFA\x8F:\xE7C\x92n i\x85\xCC"
         64                             # text(4)
            74797065                    # "type"
         6A                             # text(10)
            7075626C69632D6B6579        # "public-key"
   05                                   # unsigned(5)
   A1                                   # map(1)
      62                                # text(2)
         7570                           # "up"
      F4                                # primitive(20)
00 # unsigned(0)
```

回應：01 2e 90 00

0x2D	CTAP2_ERR_KEEPALIVE_CANCEL	Pending keep alive was cancelled.
0x2E	CTAP2_ERR_NO_CREDENTIALS	No valid credentials provided.
0x2F	CTAP2_ERR_USER_ACTION_TIMEOUT	A user action timeout occurred.

- authenticatorMakeCredential (0x01)

```
1b 00 a0 9a 92 ce 8f a7  ff ff 00 00 00 00 09 00   ···· ····  ····
00 02 00 04 00 01 03 b9  00 00 00 6f af 00 00 00   ···· ····  ···o····
00 6f 00 00 01 ff fe 01  00 aa 80 10 00 00 a4 01   ·o·· ····  ····
a5 01 58 20 f6 00 5d 20  58 d8 65 c7 a6 2a a0 d6   ··X  ··]  X·e··*··
91 0b 60 43 0b 7b 74 ff  43 73 54 39 88 cb 10 f6   ··`C ·{t·  CsT9····
1d 6f f6 f0 02 a2 62 69  64 6b 77 65 62 61 75 74   ·o····bi  dkwebaut
68 6e 2e 69 6f 64 6e 61  6d 65 6b 77 65 62 61 75   hn.iodna  mekwebau
74 68 6e 2e 69 6f 03 a3  62 69 64 46 59 57 78 6c   thn.io··  bidFYWxl
65 41 64 6e 61 6d 65 64  61 6c 65 78 6b 64 69 73   eAdnamed  alexkdis
70 6c 61 79 4e 61 6d 65  64 61 6c 65 78 04 82 a2   playName  dalex···
63 61 6c 67 26 64 74 79  70 65 6a 70 75 62 6c 69   calg&dty  pejpubli
63 2d 6b 65 79 a2 63 61  6c 67 39 01 00 64 74 79   c-key·ca  lg9··dty
70 65 6a 70 75 62 6c 69  63 2d 6b 65 79 07 a1 62   pejpubli  c-key··b
75 76 f5 00                                        uv··
```

```
# CBOR sequence with 2 elements
02 # unsigned(2)
A2                          # map(2)
   62                       # text(2)
      6964                  # "id"
   6B                       # text(11)
      776562617574686E2E696F # "webauthn.io"
   64                       # text(4)
      6E616D65              # "name"
   6B                       # text(11)
      776562617574686E2E696F # "webauthn.io"
```

a5 01 58 20 f6 00 5d 20 58 d8 65 c7 a6 2a a0 d6 91 0b 60 43 0b 7b 74 ff 43 73 54 39 88 cb 10 f6 1d 6f f6 f0

Client Hash

```
58 20                                           # bytes(32)
   F6005D2058D865C7A62AA0D6910B60430B7B74FF4373543988CB10F61D6FF6F0 # "\xF6\u0000]
X\xD8eǦ*\xA0\v`C\v{t\xFFCsT9\x88\xCB\u0010\xF6\u001Do\xF6\xF0"
```

02 是 RP 的PublicKeyCredentialRpEntity

0x03 是 user data，應該就是 user 自己填的東西

03 a3 62 69 64 46 59 57 78 6c 65 41 64 6e 61
6d 65 64 61 6c 65 78 6b 64 69 73 70 6c 61 79
4e 61 6d 65 64 61 6c 65 78

```
# CBOR sequence with 7 elements
03 # unsigned(3)
A3                              # map(3)
   62                           # text(2)
      6964                      # "id"
   46                           # bytes(6)
      5957786C6541              # "YWxleA"
   64                           # text(4)
      6E616D65                  # "name"
   64                           # text(4)
      616C6578                  # "alex"
   6B                           # text(11)
      646973706C61794E616D65    # "displayName"
   64                           # text(4)
      616C6578                  # "alex"
```

pubKeyCredParams (0x04)

04 82 a2 63 61 6c 67 26 64 74 79 70 65 6a 70
75 62 6c 69 63 2d 6b 65 79 a2 63 61 6c 67 39
01 00 64 74 79 70 65 6a 70 75 62 6c 69 63 2d
6b 65 79

```
# CBOR sequence with 5 elements
04 # unsigned(4)
82                              # array(2)
   A2                           # map(2)
      63                        # text(3)
         616C67                 # "alg"
      26                        # negative(6)
      64                        # text(4)
         74797065               # "type"
      6A                        # text(10)
         7075626C69632D6B6579   # "public-key"
   A2                           # map(2)
      63                        # text(3)
         616C67                 # "alg"
      39 0100                   # negative(256)
      64                        # text(4)
         74797065               # "type"
      6A                        # text(10)
         7075626C69632D6B6579   # "public-key"
```

```
4, [{"alg": -7, "type": "public-key"}, {"alg": -257, "type": "public-key"}]
```

07 a1 62 75 76 f5 00

```
07 # unsigned(7)
A1          # map(1)
   62       # text(2)
      7576 # "uv"
   F5       # primitive(21)
00 # unsigned(0)
```

option

```
, 7, {"uv": true}, 0
```

excludeList (0x05)	Array of PublicKeyCredentialDescriptor	Optional	An array of PublicKeyCredentialDescriptor structures, as specified in [WebAuthn]. The authenticator returns an error if the authenticator already contains one of the credentials enumerated in this array. This allows RPs to limit the creation of multiple credentials for the same account on a single authenticator.
extensions (0x06)	CBOR map of extension identifier → authenticator extension input values	Optional	Parameters to influence authenticator operation, as specified in [WebAuthn]. These parameters might be authenticator specific.
pinUvAuthParam (0x08)	Byte String	Optional	Result of calling authenticate(pinUvAuthToken, clientDataHash)
pinUvAuthProtocol (0x09)	Unsigned Integer	Optional	PIN/UV protocol version chosen by the platform
enterpriseAttestation (0x0A)	Unsigned Integer	optional	An authenticator supporting this enterprise attestation feature is ***enterprise attestation capable*** and signals its support via the epOption ID in the authenticatorGetInfo command response. If the `enterpriseAttestation` parameter is absent, attestation's privacy characteristics are unaffected, regardless of whether the enterprise attestation feature is

80fc000000006f00bb0100[a3[01667061636b656
4][02589474a6ea9213c99c2f74b22492b320cf402
62a94c1a950a0397f29250b60841ef04500000000
d7a423ad3e194492920078137dccc13600104706
f55356e83e1c7d0948779c0feec8a501020326200
121582062d582ca2d2d29c49f18f20678355e23ce
9e82e56b58e1e56c0816dfb3cf6dcc225820731a6
50ac0c0216fab1c082d0fa83f657c9c2fd42ad7322
38a046b7247500f6b][03a363616c672663736967
5846304402202c2223c6fbcd981cfff491bd3149d
647b96190a9fe5b14fb6972d41016aab0c202203
d4cc5966f9347c2b61fb20faeedf4e87fccdc42821
c79dfdc710026e588426c637835638159014 0]

```
# CBOR sequence with 2 elements
01 # unsigned(1)
66                # text(6)
   7061636B6564 # "packed"
```

```
# CBOR sequence with 2 elements
02 # unsigned(2)
58 94                                 # bytes(148)

74A6EA9213C99C2F74B22492B320CF40262A94C1A950A0397F29250B60841EF04500000000D7A423AD3E194492920078137
DCCC13600104706F55356E83E1C7D0948779C0FEEC8A501020326200121582062D582CA2D2D29C49F18F20678355E23CE9E
82E56B58E1E56C0816DFB3CF6DCC225820731A650AC0C0216FAB1C082D0FA83F657C9C2FD42AD732238A046B7247500F6B
# "t\xA6\xEA\x92\u0013ɜ/t\xB2$\x92\xB3
\xCF@&*\x94\xC1\xA9P\xA09\u007F)%\v`\x84\u001E\xF0E\u0000\u0000\u0000\u0000ɔ#\xAD>\u0019D\x92\x92\u0
000x\u0013}\xCC\xC16\u0000\u0010G\u0006\xF5SV\xE8>\u001C}\tHw\x9C\u000F\xEEʒ\u0001\u0002\u0003&
\u0001!X bʔ\xCA--)ğ\u0018\xF2\u0006x5^#Ξ\x82\xE5kX\xE1\xE5l\b\u0016\xCFm\xCC\"X
s\u001Ae\n\xC0\xC0!o\xAB\u001C\b-\u000F\xA8?e|\x9C/\xD4*\xD72#\x8A\u0004krGP\u000Fk"
```

Attest 資料

- 前面 [74a6ea9213c99c2f74b22492b320cf40262a94c1a950a0397f29250b60841ef0] 是 webauthn.io 的 SHA256 Hash
- 接下來是 Flag UP, UV, Extended data included

HEX	45
DEC	69
OCT	105
BIN	0100 0101

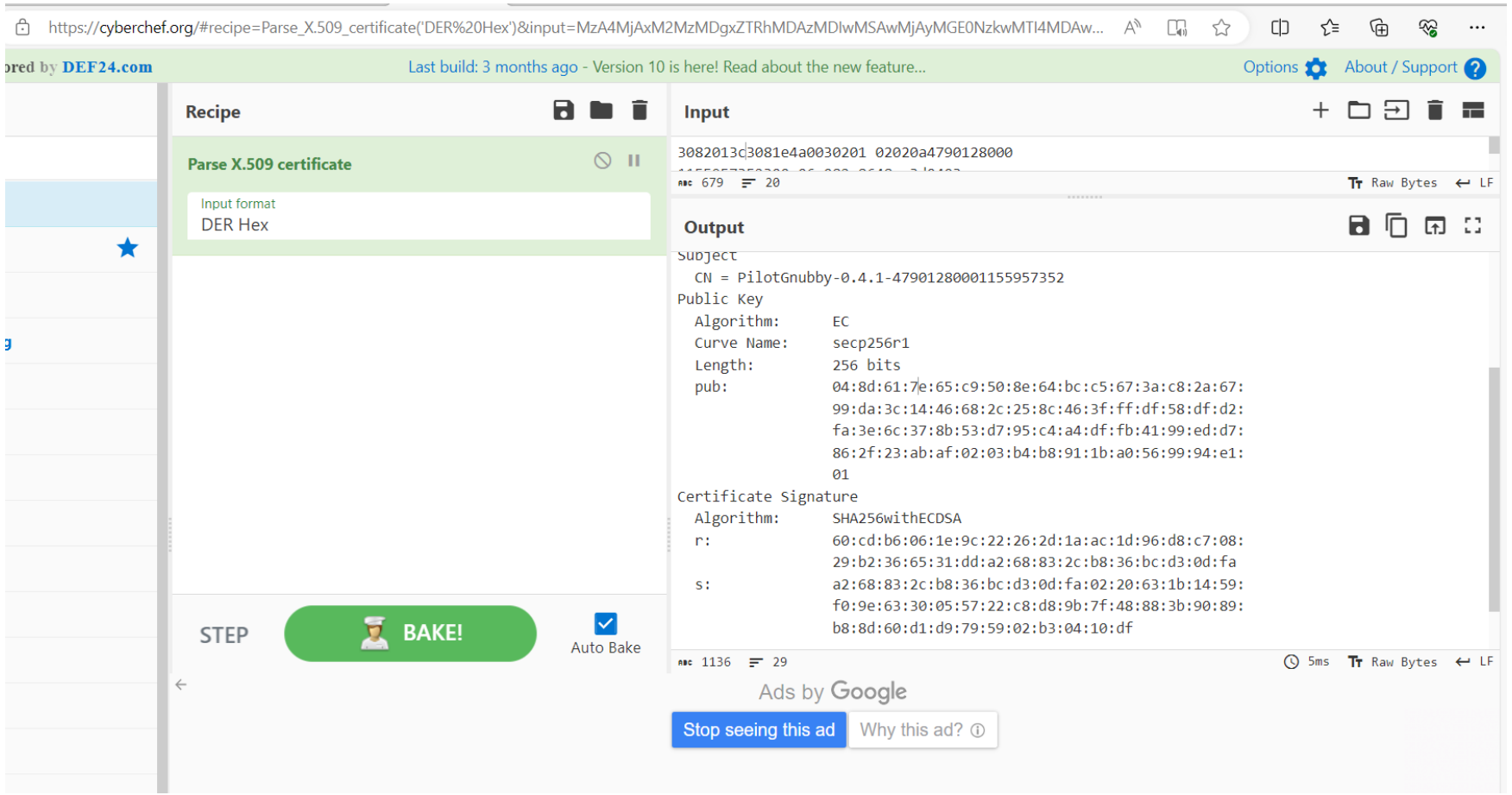
flags	1	Flags (bit 0 is the least significant bit): • Bit 0: User Present (UP) result. ◦ 1 means the user is present. ◦ 0 means the user is not present. • Bit 1: Reserved for future use (RFU1). • Bit 2: User Verified (UV) result. ◦ 1 means the user is verified. ◦ 0 means the user is not verified. • Bits 3-5: Reserved for future use (RFU2). • Bit 6: Attested credential data included (AT). ◦ Indicates whether the authenticator added attested credential data. • Bit 7: Extension data included (ED). ◦ Indicates if the authenticator data has extensions.

- Signature Count: 0
- 然後是 Attest Credential Data
- [a423ad3e19449292007813 7dccc136] 是前面出現過的 aaguid
- CredentialIDLength:[0010]
- crentialD[4706f55356e83e1c7d0948779c0feec8]
- 後面是 Credential Public Key
- [a501020326200121582062d582ca2d2d29c49f18f20678355e23ce9e82e56b58e1e56c0816dfb3cf6dcc225820731a650ac0c0216fab1c082d0fa83f657c9c2fd42ad732238a046b7247500f6b]
- 為 P256 的橢圓曲線

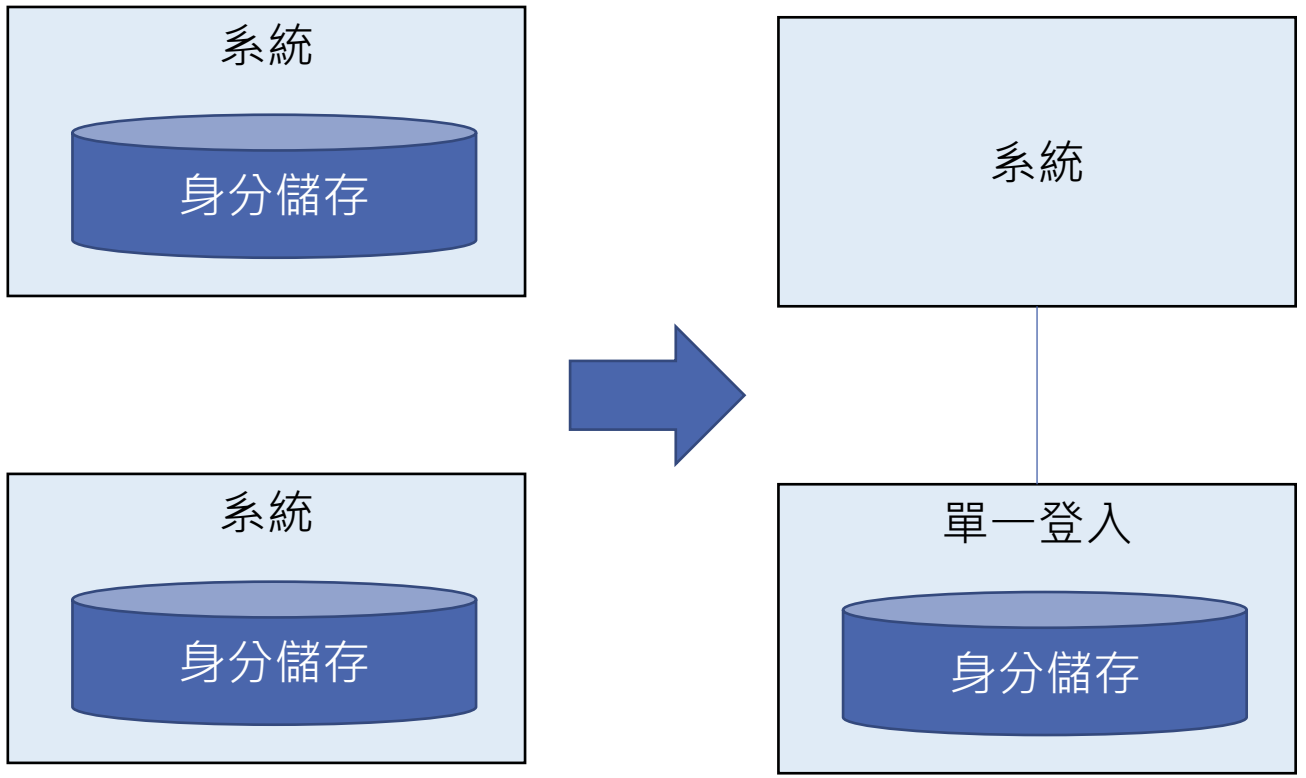
```
{1: 2, 3: -7, -1: 1, -2: h'62D582CA2D2D29C49F18F20678355E23CE9E82E56B58E1E56C0816DFB3CF6DCC', -3:
h'731A650AC0C0216FAB1C082D0FA83F657C9C2FD42AD732238A046B7247500F6B'}
```

```
EXAMPLE 6
{
  1:   2,  ; kty: EC2 key type
  3:  -7,  ; alg: ES256 signature algorithm
 -1:   1,  ; crv: P-256 curve
 -2:   x,  ; x-coordinate as byte string 32 bytes in length
           ; e.g., in hex: 65eda5a12577c2bae829437fe338701a10aaa375e1bb5b5de108de439c08551d
 -3:   y   ; y-coordinate as byte string 32 bytes in length
           ; e.g., in hex: 1e52ed75701163f7f9e40ddf9f341b3dc9ba860af7e0ca7ca7e9eecd0084d19c
}
```

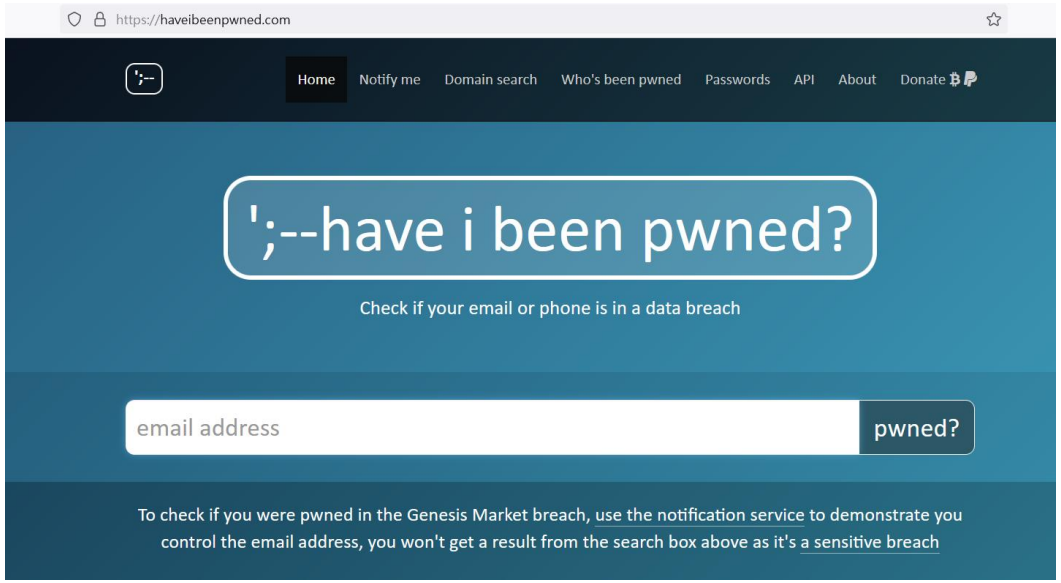
[03a363[616c672663][7369675846[304402202c2223c6
fbcd981cfff491bd3149d647b96190a9fe5b14fb6972d4
1016aab0c202203d4cc5966f9347c2b61fb20faeedf4e8
7fccdc42821c79dfdc710026e588426c63]][7835638159
0140]
616c67 = alg (26 = -7) ES256 P256
736967 = sig
783563 = x5c (Cert)

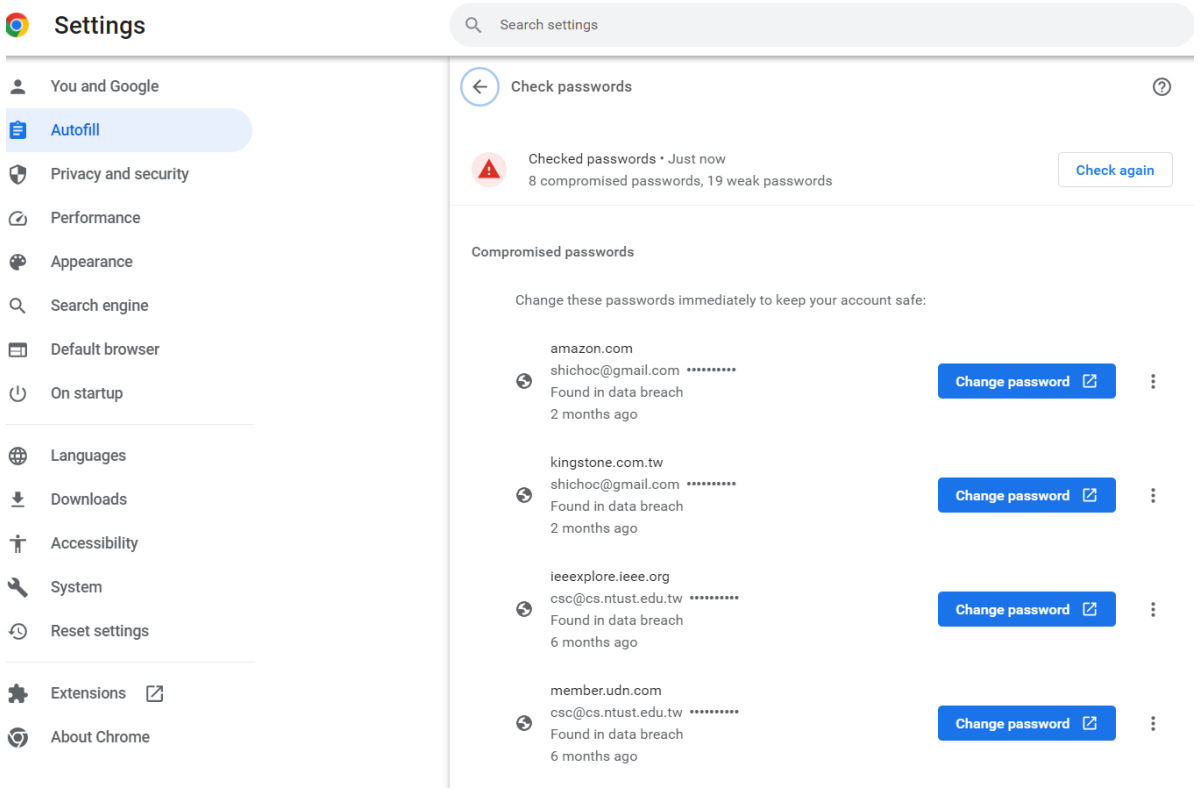

https://cyberchef.org/#recipe=Parse_X.509_certificate('DER%20Hex')&input=MzA4MjAxM2MzMDgxZTRhMDAzMDIwMSAwMjAyMGE0NzkwMTI4MDAw...
ored by DEF24.com
Last build: 3 months ago - Version 10 is here! Read about the new feature...
Options
About / Support
Recipe
Parse X.509 certificate
Input format
DER Hex
STEP
BAKE!
Auto Bake
Input
3082013c3081e4a0030201 02020a4790128000
679 20
Raw Bytes
LF
Output
Subject
CN = PilotGnubby-0.4.1-47901280001155957352
Public Key
Algorithm: EC
Curve Name: secp256r1
Length: 256 bits
pub: 04:8d:61:7e:65:c9:50:8e:64:bc:c5:67:3a:c8:2a:67:
99:da:3c:14:46:68:2c:25:8c:46:3f:ff:df:58:df:d2:
fa:3e:6c:37:8b:53:d7:95:c4:a4:df:fb:41:99:ed:d7:
86:2f:23:ab:af:02:03:b4:b8:91:1b:a0:56:99:94:e1:
01
Certificate Signature
Algorithm: SHA256withECDSA
r: 60:cd:b6:06:1e:9c:22:26:2d:1a:ac:1d:96:d8:c7:08:
29:b2:36:65:31:dd:a2:68:83:2c:b8:36:bc:d3:0d:fa
s: a2:68:83:2c:b8:36:bc:d3:0d:fa:02:20:63:1b:14:59:
f0:9e:63:30:05:57:22:c8:d8:9b:7f:48:88:3b:90:89:
b8:8d:60:d1:d9:79:59:02:b3:04:10:df
1136 29
5ms
Raw Bytes
LF
Ads by Google
Stop seeing this ad
Why this ad?

身分儲存的整合



目前有些工具可協助檢查資料外洩





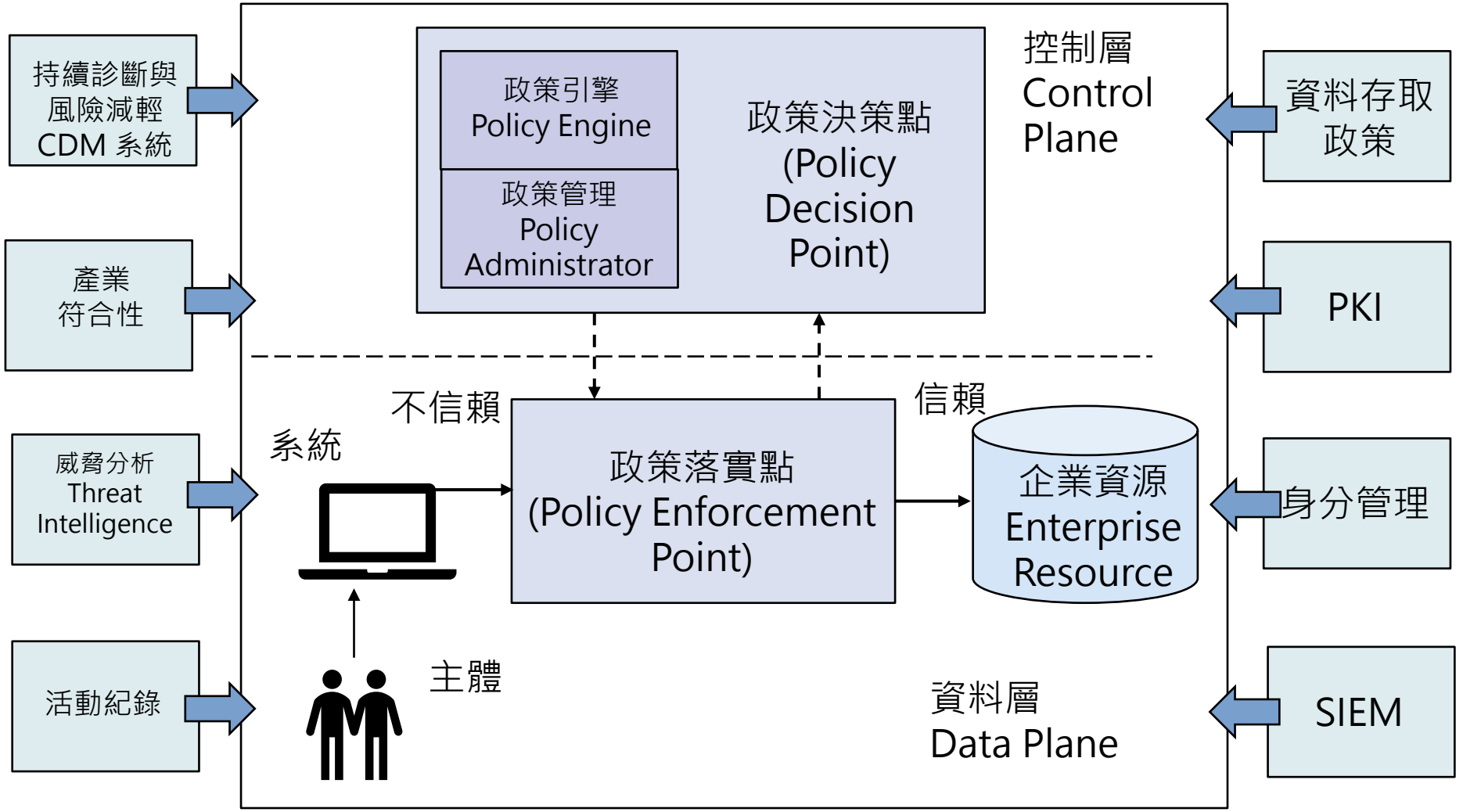
靜態與動態風險資訊

經由一段時間的行為紀錄評估風險，並且產生對存取權限的修正建議

針對存取當下的狀況，去評估風險

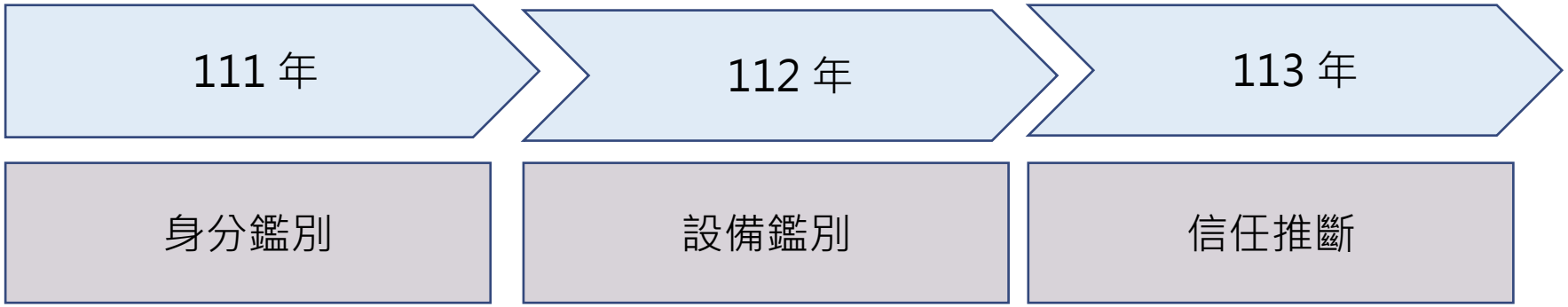
持續性的身分鑑別

NIST SP 800-207 當中的存取控制相關資訊

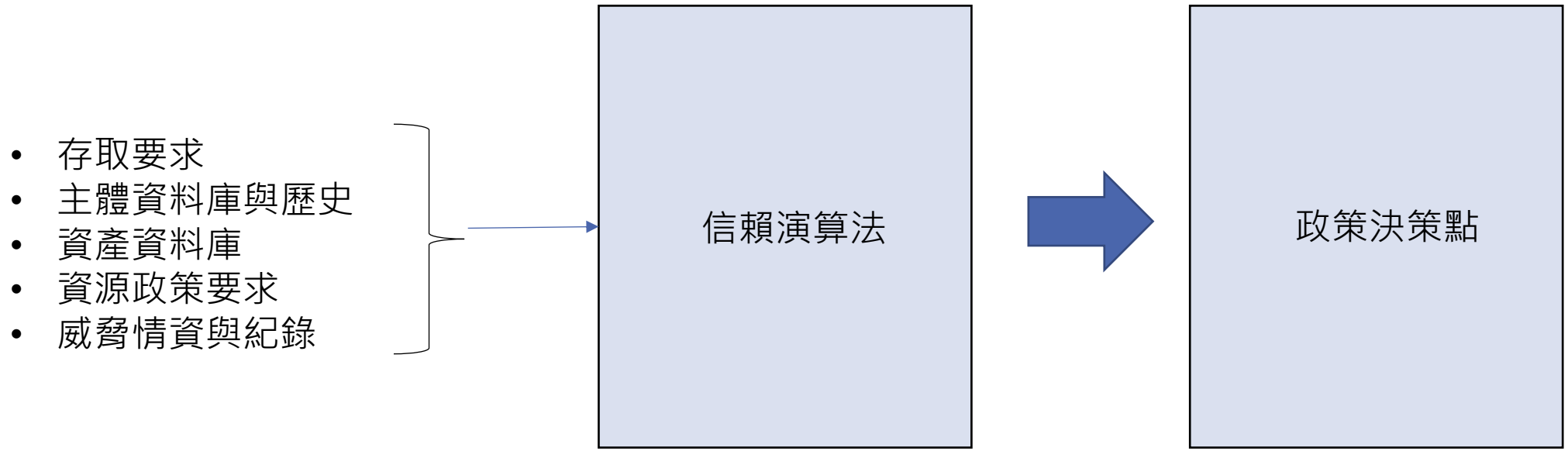


資安研究院的規劃當中，最麻煩的是信任推斷這塊

- 行政院國家資通安全會報技術服務中心於 7 月 14 發布資料
  - *依據第六期「國家資通安全發展方案(110年至113年)」之「善用智慧前瞻科技、主動抵禦潛在威脅」推動策略，將發展零信任網路資安防護環境，推動政府機關導入零信任網路，完善政府網際服務網防禦深廣度*
  - *將由數位發展部資通安全署規劃投入經費，優先推動A級公務機關導入零信任網路*
  - *著眼於以下三項：*
    - *身分鑑別：FIDO2身分鑑別與鑑別聲明*
    - *設備鑑別：TPM設備鑑別與設備健康管理*
    - *信任推斷：基於分數與情境之信任推斷機制*



NIST SP 800-207 並沒有明確的信任判斷演算法定義



- 條件 (Criteria-based) 或分數 (Score-based)為基礎的信賴評估
- 單一 (Singular) 或情境為基礎 (Context-based) 的信賴評估

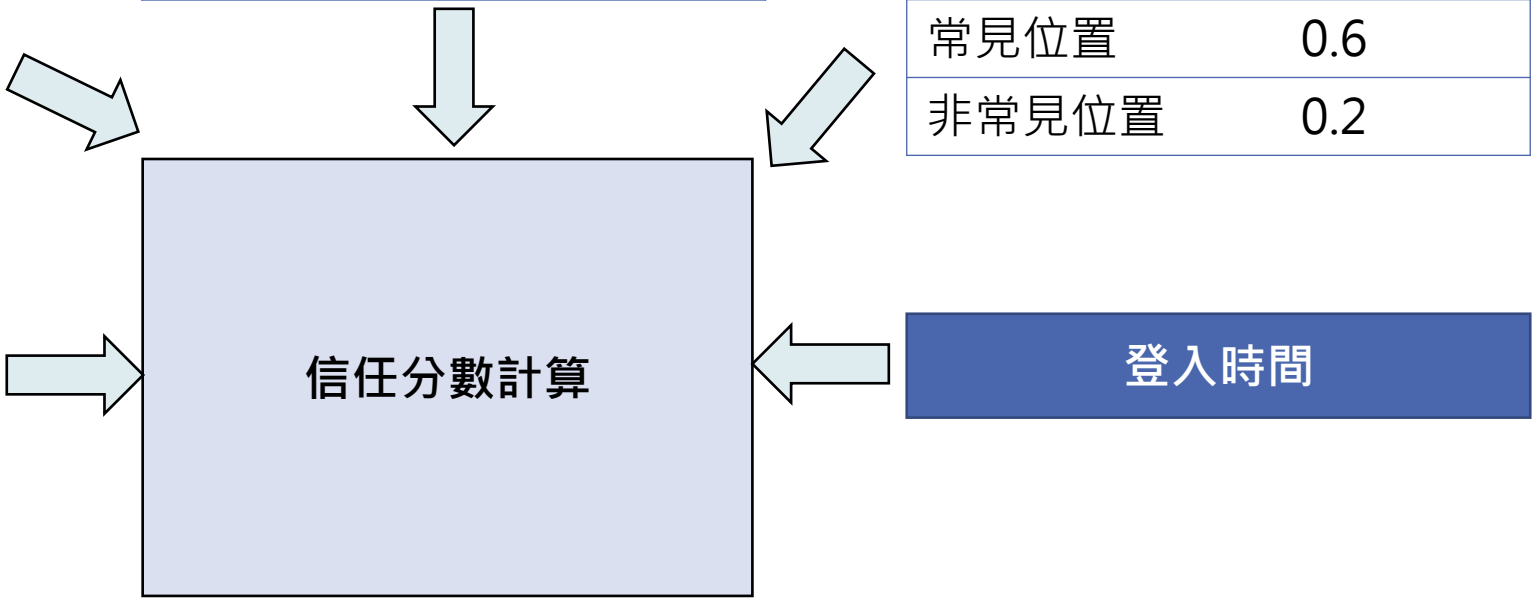
技術服務中心的信任推斷建議

身分鑑別方式	信任等級
AAL3	1.0
AAL2	0.8
AAL1	0.5

設備鑑別方式	信任等級
有 TPM	1.0
其他登錄設備	0.5

IP 位置	信任等級
內部位置	1.0
GSN 位置	0.8
常見位置	0.6
非常見位置	0.2

設備健康狀態	權重
作業系統更新	0.4
防毒更新	0.3
應用軟體更新	0.2
組態合規	0.1



CISA ZTMM 的裝置構面

- 裝置是指可以連到網路的所有資產

政策落實與
符合性監控

資產與供應鏈
風險管理

資源存取

裝置威脅防護

可視性與分析
能力

自動化與協作
能力

治理能力

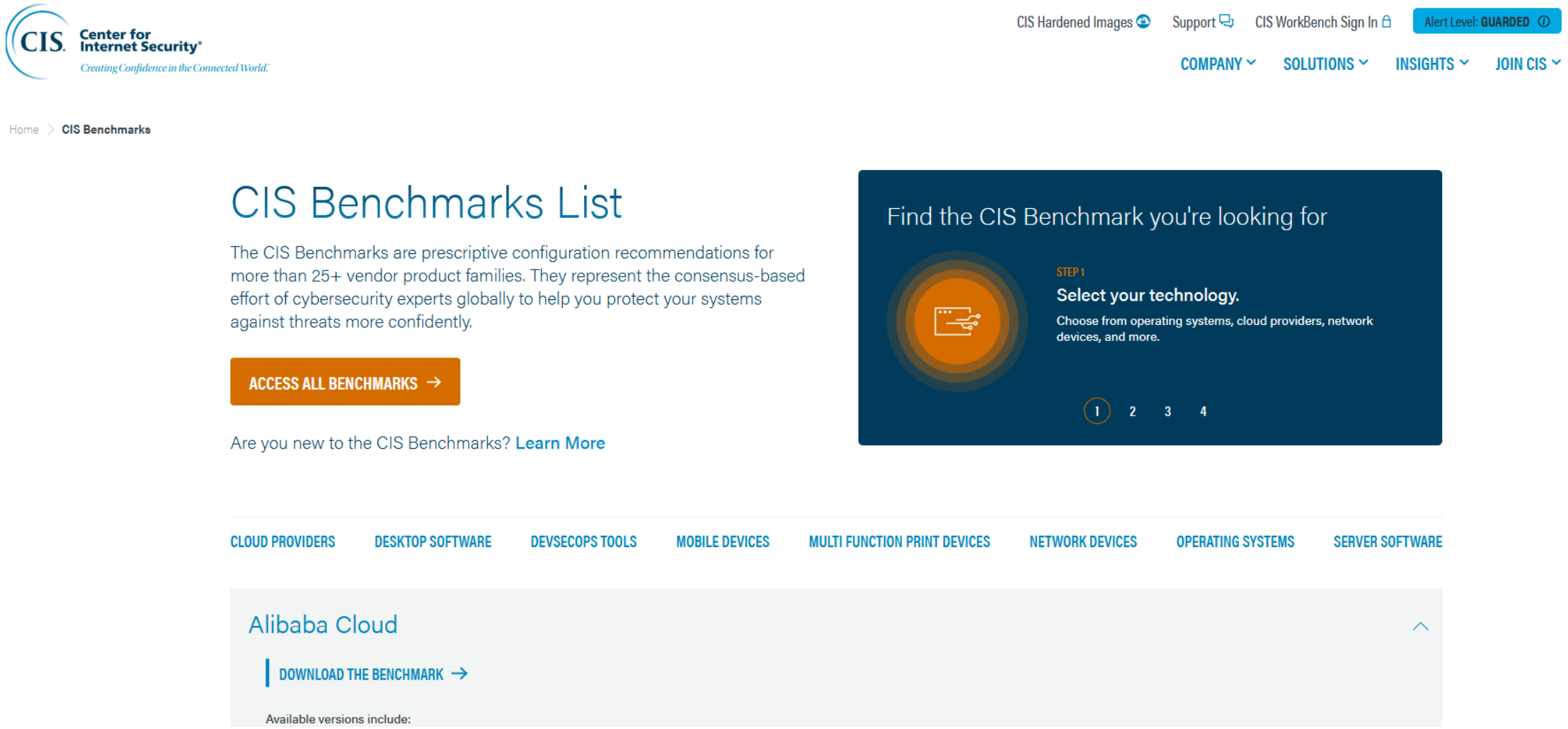
對於裝置的成熟度要求

功能	傳統	起始	進階	最佳化
政策落實與符合性監控	有限或近乎沒有的合規可視能力，而無法監控裝置的狀態	接受自我提供的裝置特徵，但只有有限度的落實。對於允許使用的軟體有基本的程序，並會推送更新到設備	可以初步驗證裝置狀態並確保合規。能夠採用自動化的方式去對實體或虛擬裝置管理軟體與設定更新。	可以持續驗證裝置狀態以確保生命週期中的合規。並且整合組織整體的軟體和設備更新與設定管理，以及弱點感理機制
資產與供應鏈風險管理	企業沒有追蹤自身與跨供應商的資產。並且沒有掌握取得設備的風險	追蹤所有實體與虛擬資產，並依照美國聯邦政府的框架建立供應鏈風險管理政策與基線。	透過自動化方式去呈現整體實體與虛擬資產狀況，並且能夠追蹤供應商的生命週期風險	對跨供應鏈的所有資產有近乎即時的了解，以掌握風險。
資源存取	沒有對可存取資源的資產進行可視性要求	在資源存取前要提供裝置或虛擬資產特徵以進行審查	在開始對資源存取時會考慮到裝置或是虛擬資產是有被驗證過的	對於資源的存取會考慮到裝置或是虛擬資產的即時風險
裝置威脅防護	手動部署威脅防護能力到各設備	有部署部分的自動化威脅防護能力，並且有限的去落實符合性與監控	建立集中管理的威脅防護能力，並能夠對裝置要求落實符合性與監控	採用一致的方法去要求裝置能夠落實符合性與監控

對於裝置的成熟度要求 (續)

功能	傳統	起始	進階	最佳化
可視性與分析能力	有對於設備進行實體標記，並且有限度的對設備進行軟體監控與人工審查	使用數位識別結合人工管理的裝置清單，並結合端點監控。部分裝置可以進行自動化的異常偵測。	可以自動化的進行裝置盤點，並且可以透過異常分析自動發現未經授權的裝置	自動收集連網的設備和虛擬資產的狀態，而與裝置識別做連結。並且有進行端點監控，以及對資源存取的異常進行分析。也會對虛擬資產的配置與解除配置進行追蹤以發現異常
自動化與協作能力	採用人工設定、註冊與管理企業內的設備	開始使用工具與腳本來對設備與虛擬資產的提供、設定、註冊，與解除配置的程序進行自動化	會對裝置進行監控，以便落實對於未合規裝置的斷線與隔離	對於裝置或虛擬資產的配置、註冊、監控、隔離、風險控管，與解除配置有完整的自動化程序
治理能力	對於傳統的電腦設備與周邊裝置建立部分生命週期管理政策，並且使用手動方式進行維護	對於新採購的設備，以及非傳統電腦的虛擬資產之生命週期訂定週期性監控與掃描的政策	制定包括盤點與指派責任等，整個企業對於裝置與虛擬資產的生命週期管理政策。並且部份能自動落實	對於所有連網裝置與虛擬資產的生命週期管理程序自動化

CIS Benchmark



https://www.cisecurity.org/cybersecurity-tools/cis-cat-pro

CIS Benchmark 範例

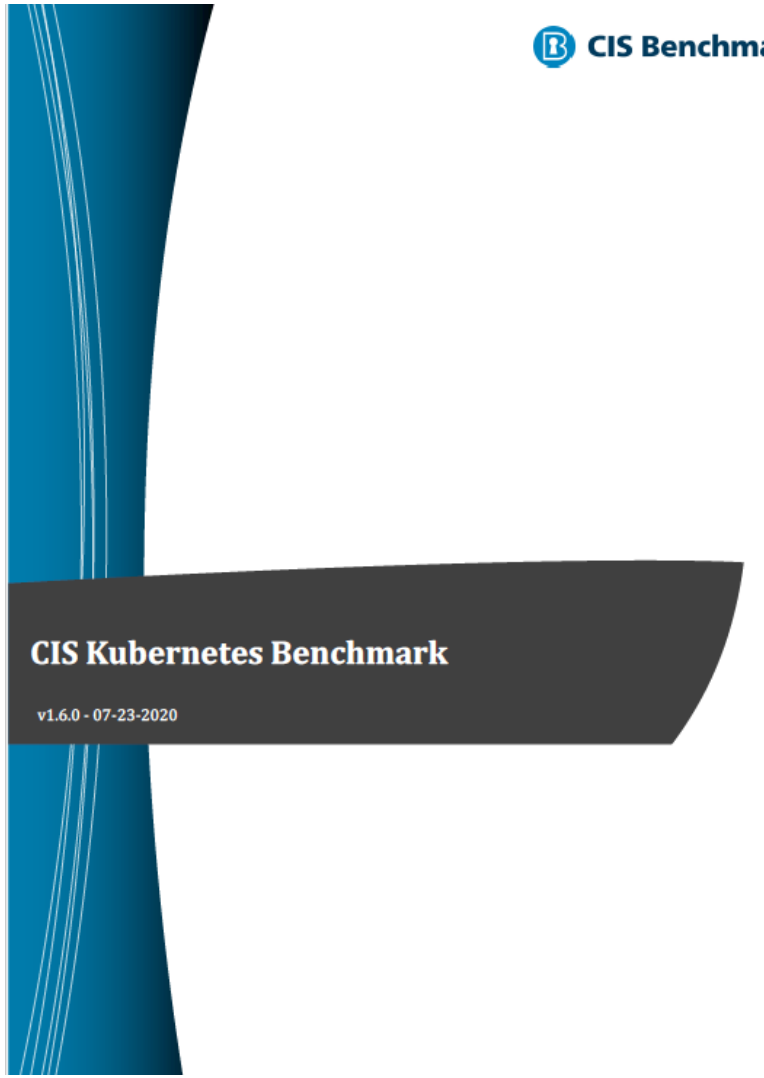


Table of Contents

Terms of Use 1
Overview 10
Intended Audience 10
Consensus Guidance 10
Typographical Conventions 12
Assessment Status 12
Profile Definitions 13
Acknowledgements 14
Recommendations 15
1 Control Plane Components 15
1.1 Master Node Configuration Files 16
1.1.1 Ensure that the API server pod specification file permissions are set to 644 or more restrictive (Automated) 16
1.1.2 Ensure that the API server pod specification file ownership is set to root:root (Automated) 18
1.1.3 Ensure that the controller manager pod specification file permissions are set to 644 or more restrictive (Automated) 20
1.1.4 Ensure that the controller manager pod specification file ownership is set to root:root (Automated) 22
1.1.5 Ensure that the scheduler pod specification file permissions are set to 644 or more restrictive (Automated) 24
1.1.6 Ensure that the scheduler pod specification file ownership is set to root:root (Automated) 26
1.1.7 Ensure that the etcd pod specification file permissions are set to 644 or more restrictive (Automated) 28
1.1.8 Ensure that the etcd pod specification file ownership is set to root:root (Automated) 30
1.1.9 Ensure that the Container Network Interface file permissions are set to 644 or more restrictive (Manual) 32
1.1.10 Ensure that the Container Network Interface file ownership is set to root:root (Manual) 34



CIS-CAT® Pro

A powerful tool for automating CIS Benchmark assessment and reporting

The CIS Benchmarks are a powerful set of best practices to help your organization ensure its IT systems, software, networks, and cloud infrastructure are securely configured. Testing those configurations can be a labor-intensive process – and that can be a challenge for many organizations.

As a CIS SecureSuite Member, you gain access to tools that help make assessing and reporting significantly easier and more effective.

Our configuration assessment tool, CIS-CAT Pro, turns the best practices of the CIS Benchmarks and CIS Controls into actionable insights by scanning systems and reporting on their levels of compliance.

GET ACCESS →

CIS-CAT Pro Overview Features

CIS-CAT®Pro

Already a SecureSuite Member?

Sign in to your account.

LOGIN PORTAL →

Ready to Try CIS-CAT?

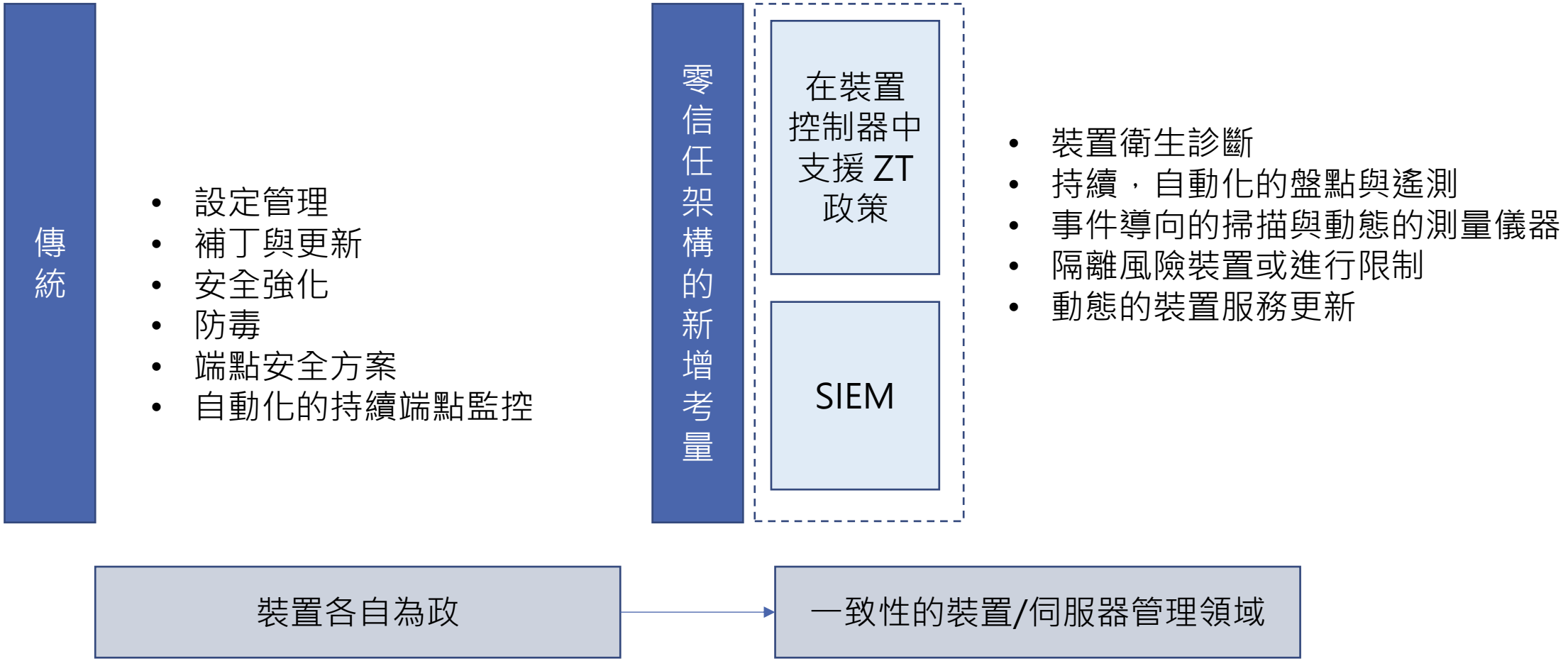
SIGN UP TODAY →

Questions?

Still have questions or need more information? You can contact us directly.

GET IN TOUCH →

在零信任架構的裝置健康發展方向



主要裝置健康監控方法

針對網路封包與紀錄

安裝代理人程式

在虛擬環境當中監控

CISA ZTMM 的網路 (Network) 構面

- 網路是指通訊媒介，包括傳統的有線與無線網路，以及行動網路或是應用程式層級用來傳輸訊息的通訊

網路分割

網路流量管理

流量加密

網路韌性

可視性與分析能力

自動化與協作能力

治理能力

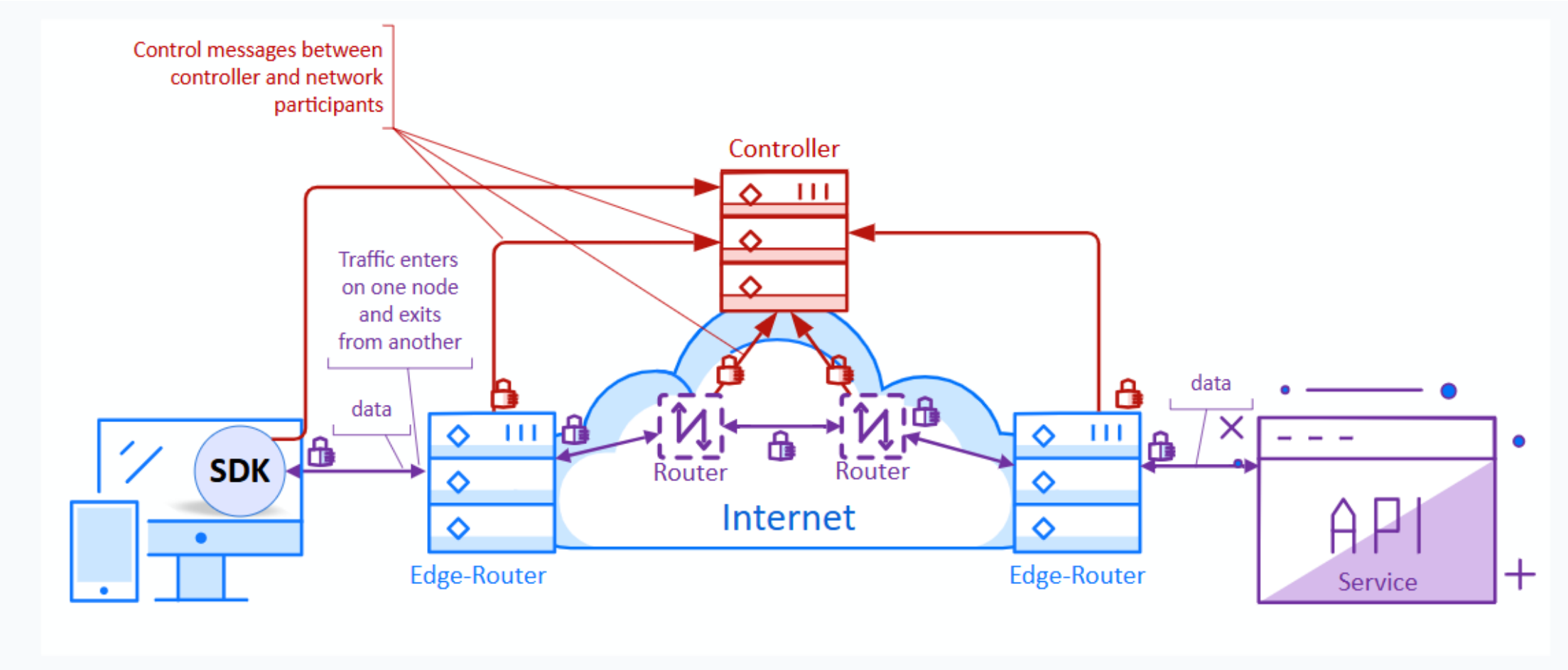
對於網路的成熟度要求

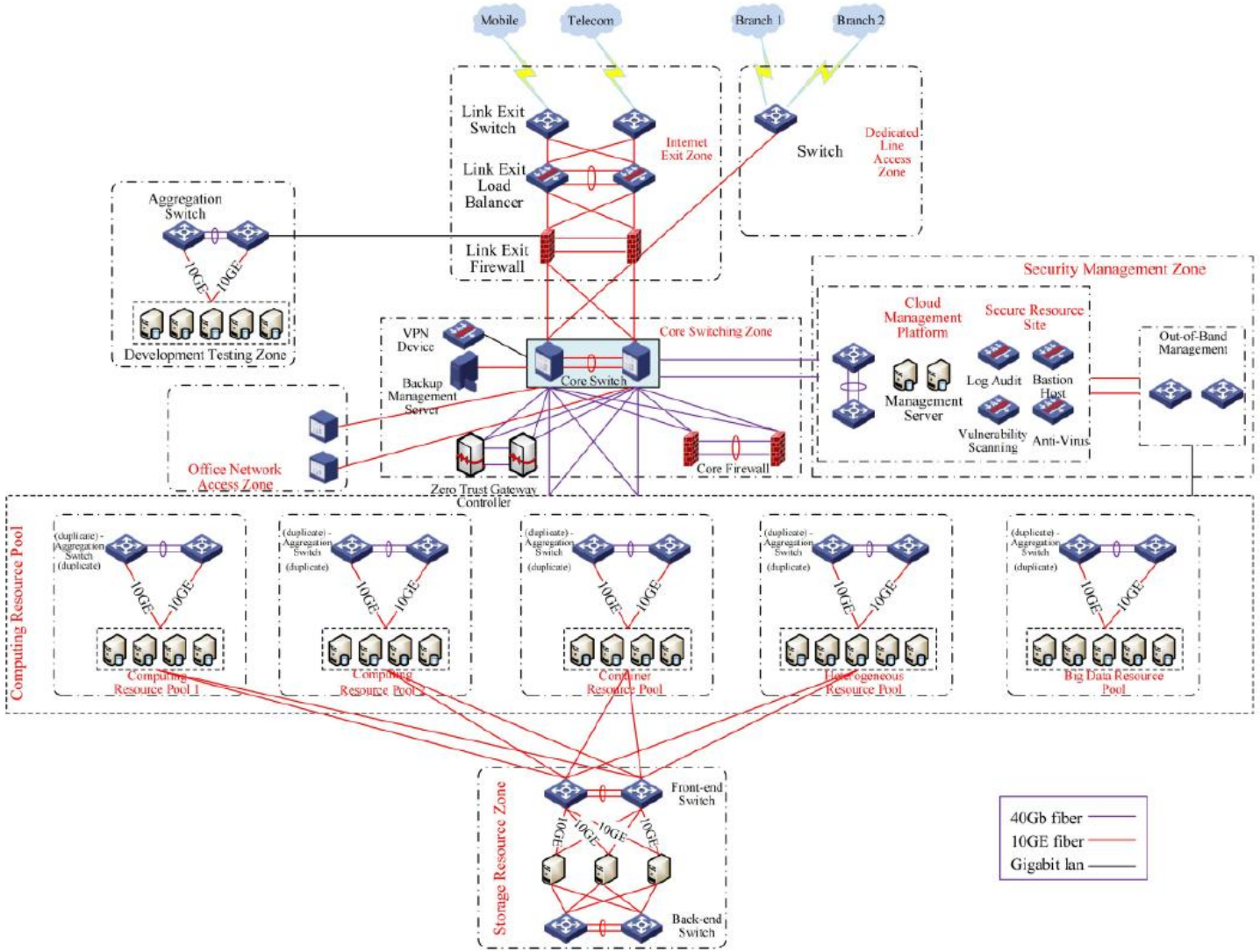
功能	傳統	起始	進階	最佳化
網路分割	使用大型邊界或巨分割來定義網路架構，並且較少對分割內的通訊做限制。允許多種服務在同一連線中傳輸。	調整網路架構，能夠對關鍵負載進行隔離，要求最小需求原則的網路連線，並朝按各別服務分隔過渡	將部署在端點與應用程式的隔離機制，擴充為針對輸入輸出交通的微分割機制，並且能夠對服務建立特有連線。	網路架構包括完全分散的微分割架構，而為分割能夠針對應用程式屬性動態且恰到好處的調整連線
網路流量管理	在提供新服務時，會透過人工的方式去設定靜態規則。對於關鍵任務的設定變更採用人工的方式進行稽核與審查	開始對不同流量管理需求的應用建立分類檔案，並且建立靜態規則以套用到這些檔案，並且定期進行稽核與評估	實作動態的網路規則與設定，以便資源能夠定期依照應用程式檔案監控與評估的風險進行最佳化	實作動態網路規則與設定，而能因應應用程式需求而演進，並能依照任務關鍵性、風險等重新調整應用程式優先性
流量加密	鮮少對流量進行加密，並使用人工或隨意的方式管理與保護金鑰	開始對內部應用的流量加密，尤其是對外部應用的連線。並建立正式的金鑰管理政策，來保護金鑰	確保對所有內外部適用的流量加密，並且管理金鑰與憑證的發行與輪調，並且採取密碼學演進因應的最佳實務	持續加密網路流量，並且整個企業採用最小需求原則管理金鑰，並且能夠迅速因應密碼學演進的變化
網路韌性	依照各別應用的可用性需求去進行設定，並且對於非關鍵任務的工作僅提供有限的韌性確保機制	具有管理額外應用程式需求，以及擴展非關鍵任務的復原機制的網路設定能力	擁有能夠依照可用性需求以及主要應用程式回復性機制動態管理的網路設定能力	在組織內全方面針對所有工作負載的可用性需求變更，提供合乎比例的韌性之認知

對於網路的成熟度要求 (續)

功能	傳統	起始	進階	最佳化
可視性與分析能力	整合網路邊界的監控能力，在只有少量分析的情況下進行集中化的情境感知	發展基於已知的入侵指標，以針對每個環境進行情境感知的網路監控能力，並且開始對不同類型的遙測數據進行關聯與分析，並進行威脅追蹤	部署跨環境的網路異常的偵測能力，並且將來自多個來源的遙測數據進行分析，並且整合自動化程序以強化威脅追蹤活動	維護對網路環境當中所有連線的可視性，並落實全企業的情境感知，與能夠自動將所有偵測資料來源的遙測數據進行關聯分析的進階監控能力。
自動化與協作能力	透過手動的程序，去管理網路環境中資源與設定的生命週期。並由人工定期整合各元件之政策需求與情境感知的結果	開始使用自動化方法來管理網路環境中資源與設定的生命週期。並且確保每個資源有基於政策與遙測數據所定義的生命週期	採用自動化變更管理方法來管理網路環境中資源與設定的生命週期。並且能夠依據感知的風險套用政策與保護機制來進行回應	網路與環境使用基礎設施即代碼 (Infrastructure as Code, IaC) 的方式進行定義，並且套用自動化的變更管理方法。
治理能力	針對週邊防護，實作靜態網路政策	能夠在依循公司整體的規範下，對各分割與資源訂定符合個別需求的政策	能夠從針對週邊的保護，轉型到符合各元件或分割需求的政策，並且能夠自動化落實政策	實作企業整體的網路政策，並在此政策下，依應用程式與工作需求，去訂定相應的控制措施、動態更新，以及安全連線機制。

Open Ziti


Control messages between controller and network participants
Controller
Traffic enters on one node and exits from another
data
SDK
Router
Router
Internet
Edge-Router
Edge-Router
data
API
Service



L. Guowei, P. Hua, Y. Fuming and C. Qifeng, "Design Scheme of Network Security Access System Based on Zero Trust," 2024 IEEE 2nd International Conference on Control, Electronics and Computer Technology (ICCECT), Jilin, China, 2024, pp. 625-629, doi: 10.1109/ICCECT60629.2024.10546038.

CISA ZTMM 的應用程式與負載 (Application and Workload)構面

- 包括在地端、行動裝置，或雲端執行的系統、電腦程式，或服務

應用程式存取	應用程式威脅防護	應用程式可存取性	應用程式開發與負載部署安全
應用程式安全測試	可視性與分析能力	自動化與協作能力	治理能力

對於應用程式與負載的成熟度要求

功能	傳統	起始	進階	最佳化
應用程式存取	基於本地授權與靜態屬性來進行存取控制	開始實作能夠依照每次要求的情境資訊進行存取授權的能力，且授權有期限	依照延伸的情境資訊，自動進行存取決策，並且能夠依照最小權限原則，落實授權期限	結合即時風險分析與例如行為與使用模式等因子，持續對應用程式進行存取授權
應用程式威脅防護	應用程式的威脅防護與應用程式的工作流程整合度低，只針對已知威脅提供通用的防禦措施	將威脅防護整合到關鍵應用的工作流程中，除了一般的已知威脅外，也開始針對應用程式的特殊威脅	將威脅防護整合到所有應用程式的工作流程，以防護特別針對應用程式的特定威脅	將進階威脅防護整合到所有應用程式的工作流程，並對針對應用程式的複雜攻擊，提供可視且依據內容的防護。
應用程式可存取性	讓少數關鍵應用只能透過私網或是被保護的公共網路 (如透過 VPN) 在監控下存取	允許部分關鍵應用能夠讓授權的使用者經由公共網路而使用代理連接存取	大部分關鍵的應用程式可讓授權的使用者在有需要的情況下經過公共網路存取	讓授權的使用者與裝置，在有需要的情況下，可以透過公共網路存取所有應用程式
應用程式開發與負載部署安全	使用非正式的開發、測試，與生產環境，並且採用不夠堅耐的程式碼部署機制	提供開發、測試，與生產自動化環境的骨幹，能夠透過 CI/CD管道實施正式的程式部署，並提供支援最小權限原則的存取控制	建立不同且合作的團隊，分別進行開發、安全，與作業工作，並且移除開發者對於生產環境程式部署的權限	如果可行的話，利用不可改的工作負載，只允許在重新部署時才能變更，並取消管理者對部署環境的存取權限，以支持自動化的程式部署程序

對於應用程式與負載的成熟度要求 (續)

其實人工與靜態檢測在一般情況下等級可能比較高

功能	傳統	起始	進階	最佳化
應用程式安全測試	主要透過人工測試的方法，在部署程式前進行應用程式安全測試	在程式部署前，除了專家分析外，開始使用動態與靜態分析	將應用程式開發與部署和應用程式安全測試整合，並且定期使用動態測試方法	企業將安全測試整合到整個軟體開發測試生命週期，並且會對部署的程式進行例行性自動測試
可視性與分析能力	對部分關鍵應用程式，執行效能和安全監控，但是整合和分析能力有限	開始以自動的方式建立應用程式檔案與安全監控，以便改進紀錄的收集、整合，與分析。	對大部分的應用程式使用自動化的建檔與安全監控，並且透過經驗法則去分別識別各應用程式與整個企業的趨勢，而隨著時間去調整可視性的落差	在所有應用程式中，執行持續且動態的監控，以維持對企業所有應用程式的可視性
自動化與協作能力	在設定應用程式時，手動設定靜態的應用程式托管位置和訪問權限，維護和審查相對有限	定期修改應用程式設定，以滿足相對的安全與效能目標	進行自動化應用程式設定，以因應作業與環境的變化	透過自動化設定，來持續進行安全與效能的最佳化
治理能力	主要依賴人工的方式來落實應用程式存取、開發、部署、軟體資產管理、新技術的安全測試與評估、更新，與軟體依賴性追蹤的程序	開始對於使用自動化程序，進行應用程式的開發、部署、軟體資產管理，引用新技術的安全測試與評估、更新、依照任務需求的軟體依賴關係 (利用 SBOM)	在整個企業對所有應用程式開發與部署的生命週期，針對應用程式實施量身訂做與分層的政策，如果可能的話，用自動化的方法來協助落實	完全採用自動化的政策對於應用程式的開發與部署進行治理，這包括依照 CI/CD 管道對於應用程式的動態更新

CISA ZTMM 的資料 (Data)構面

- 包括在系統、裝置、網路、應用程式、骨幹，與備份當中所有的結構與非結構化檔案與片段，以及相關的元資料 (Meta Data)

資料清單管理	資料分類	資料可用性	資料存取
應用程式安全測試	可視性與分析能力	自動化與協作能力	治理能力

對於資料的成熟度要求

功能	傳統	起始	進階	最佳化
資料清單管理	人工識別與盤點部分資料	開始對在地與雲端環境進行自動化資料盤點程序，而且可以包括多數資料，並開始保護資料不會遺失	開始自動化進行整個企業所有資料的資料盤點與追蹤，並且導入依照靜態屬性或標籤的資料遺失防止策略	持續盤點適用的資料，並且採用堅耐的資料遺失防止策略，以動態攔阻可能的資料外洩
資料分類	有限與非正式的資料分類能力	開始依照定義的標籤與人工落實機制，實施資料分類策略	以一致性、具有層次，針對部分資料，以簡單與結構化的格式，進行自動化的分類與標記程序，並且定期進行審查	以堅耐的技術，對整個企業進行自動化的資料分類和標記，並且採用細緻化的格式，以因應所有類型的資料
資料可用性	主要從本地資料儲存提供資料，並有部分資料有做離線備份	有部分的資料經由重複，高可用性的資料儲存提供，而所有的本地資料有進行離線備份	主要從重複，高可用性的資料園提供資料，並且可以存取歷史資料	依照使用者與實體的需求，使用動態的方法來對包括歷史資料在內的資料，進行資料可用性進行最佳化。
資料存取	透過靜態的存取控制，管理使用者與實體的存取	開始在企業內部署自動化資料存取控制機制，並且整合最小需求原則	將資料存取控制自動化，並且考量身分、裝置風險、應用程式，資料類別等不同屬性。並且每次只授予有限的存取時間	在整個企業範圍內，採用資料存取控制的自動化，必且做到即時及僅可存取所需資料，並且持續的審查權限

對於資料的成熟度要求 (續)

功能	傳統	起始	進階	最佳化
資料加密	只對少數儲存與傳輸的資料加密，並且依照手動或臨時的程序去管理與保護加密金鑰	對所有傳輸中的資料加密，且對部分儲存的資料加密。並且開始使用正規的金鑰管理政策以保護加密金鑰	在最大的程度上，對企業所有傳輸與儲存的資料加密，並且整合靈活的密碼機制，以保護加密金鑰	在適用的情境對資料加密，並且落實整個企業在金鑰管理上，落實最小權限原則，並且套用符合現況的密碼標準，並僅可能做到靈活性
可視性與分析能力	對資料僅有位置、存取，與使用等有限度的可視性，並且主要採用手動的分析程序	透過資料庫存管理、分類、加密，及嘗試存取來獲得可視性，並且部分採用自動化的方式，進行分析與建立關聯	以更全面的方式維護資料可視性，並且從整個企業的角度，去進行自動化的分析與建立關聯，並且開始進行預測性分析	使用預測性分析等堅耐的分析功能，以擁有所有資料生命週期的可視性。並支援對資料的全面了解和持續的安全狀態評估
自動化與協作能力	透過人工與臨時的程序，建立資料的生命週期與安全政策	使用部分自動化的程序，來落實資料生命週期與安全防護的政策	以一致、分層、有針對性的方式，對企業內大部分的資料，透過自動化的方法，實施資料生命週期和安全政策	在最大程度上自動化企業內所有資料的資料生命週期和安全政策
治理能力	以人工的實施方式，建立臨時的資料治理政策	主要基於人工與分段的實作方式，定義高階的資料治理政策	開始在企業內，整合資料生命週期政策的落實方式，以定義更統一的資料治理政策	以最大可能的程度，統一資料生命週期政策，並且在整個企業動態執行

跨支柱的能力彙整

功能	傳統	起始	進階	最佳化
可視性與分析能力	僅手動收集有限的紀錄，資料精確度低，且少有分析	對於關鍵功能，開始自動收集紀錄與事件，並且進行分析。同時定情評估程序以發現可視性的缺口。	擴大自動化收集整個企業的紀錄和事件，以進行集中化的分析，並能對多個資料來源建立關聯	透過集中化的動態監控，以及對記錄和事件的進階分析，以維護企業全面的可視性
自動化與協作能力	依照靜態與手動程序來進行協作程序與回應活動，且自動化程度有限	開始自動化支援關鍵任務功能的協作和回應活動。	對整個企業的協作與回應活動進行自動化，並且利用多個來源的情境資訊來做為決策依據	企業的協作與回應活動，能夠依照整個企業的變更需求與環境的變化來進行動態回應
治理能力	在整個企業中，透過手動過程或靜態的技術機制，以臨時方式實施政策	開始建立整個企業的執行政策，但是自動化程度有限，多半為手動更新	在企業範圍內實行分層且量身訂做的政策，並且在可能的情況下支持自動化的方式執行。存取政策的決策會考量到多個地方的情境資訊。	實施全面自動化的企業政策，並且允許因地制宜的控制，進行持續落實與動態更新

美國國防部的零信任策略

- 提出一套具適應性的推動方法，說明美國國防部應如何主導並加速轉型至零信任架構
- 國防部及其所屬各單位必須積極擁抱持續演進的新興技術，同時具備因應已知與未知惡意攻擊者的能力，以快速調整並回應各類資安威脅。
- 目標能夠達到：將能有效降低敵方企圖拒止 (deny)、降低效能 (degrade)、干擾(disrupt)、欺騙(deceive)或摧毀(destroy)資訊系統的攻擊行動。
- 2027 年要達到目標等級零信任：
  - 保護國防部資料 (Data)、應用程式 (Applications)、資產(Assets)與服務 (Services) (DAAS)，並有效管理目前已知威脅風險所必須具備的最低零信任能力成果與活動。

策略架構

1. 建立零信任文化	2. 確保並防衛 DoD 資訊系統	3.加速技術發展	4. 零信任推動機制 (Zero Trust Enablement)
1.1 承諾 (Commitment)	2.1 使用者 (User)	3.1 能力 (Capabilities)	4.1 政策 (Policy)
1.2 推廣 (Outreach)	2.2 裝置 (Device)	3.2 架構 (Architecture)	4.2 計畫規劃 (Programming)
1.3 認知 (Awareness)	2.3 應用程式與工作負載 (Application & Workload)	3.3 互通性 (Interoperability)	4.3 規劃 (Planning)
1.4 人才發展 (Workforce)	2.4 資料 (Data)	3.4 構想發展與創新 (Ideation/ Innovation)	4.4 經費 (Funding)
1.5 教育訓練 (Training)	2.5 網路與環境 (Network & Environment)		4.5 採購 (Acquisition)
	2.6 自動化與協同調度 (Automation& Orchestration)		4.6 績效管理 (Performance)
	2.7 可視性與分析 (Visibility & Analytics)		4.7 零信任投資組合管理辦公室 (ZT PfMO)

目標水準的要求

	目標	持續成熟能力	進階
使用者	1.1 使用者盤點 1.7 最小權限存取	1.2 條件式使用者存取 1.3 多因素驗證 1.4 特權存取管理 1.5身分聯邦與使用者憑證管理 1.6 行為分析、情境式身分識別與生物特徵驗證 1.8持續性身分驗證 1.9整合式 ICAM 平臺	
裝置	2.5 資產、弱點與修補管理 (部分 / 全面自動化) 2.6 統一端點管理 (UEM)與行動裝置管理 (MDM)	2.1 裝置盤點 (Device Inventory) 2.2 裝置偵測與合規性檢查 (Device Detection and Compliance) 2.3 即時檢測式裝置授權(Device Authorization with Real-Time Inspection) 2.4 遠端存取 (Remote Access) 2.7 端點與延伸式偵測及回應 (EDR/XDR)	
應用程式與工作負載	3.1 應用程式盤點 3.3 軟體風險管理	3.2 安全軟體開發與整合 3.4 資源存取授權與整合	3.5 持續監控與持續授權

目標水準的要求 (續)

	目標	持續成熟能力	進階
資料	4.1 資料目錄與風險校準 4.2 DoD 企業資料治理	4.3 資料標示與標籤管理 4.4 資料監控與偵測 4.5 資料加密與權限管理 4.6 資料外洩防護(DLP) 4.7 資料存取控制	
網路與環境	5.1 資料流向盤點 5.3 巨分段 (Macro Segmentation)	5.2 軟體定義網路 5.4 微分段 (Micro Segmentation)	
自動化與協同調度	6.3 機器學習 6.6 API 標準化	6.1 政策決策點與政策協同調度 6.2 關鍵流程自動化 6.5 安全協同調度、自動化與回應 (SOAR) 6.7 安全維運中心 (SOC) 與事件應變 (IR)	6.4 人工智慧
可視性與分析	7.1 全面記錄所有流量 7.3 共通安全與風險分析 7.5 威脅情資整合	7.2 安全資訊與事件管理 (SIEM) 7.4 使用者與實體行為分析 (UEBA)	7.6 自動化動態政策 (Automated Dynamic Policies)

預期成果

- 使用者可在任何地點，透過任何經授權且完成身分驗證的使用者與裝置，安全地存取所需資料。
- 建構安全且受保護的資訊系統，支援國防部轉型為更敏捷、更具行動力、並以雲端為基礎的新型工作模式。
- 透過國防部資訊企業 (DoD Information Enterprise)的微分段 (Micro-segmentation)，降低整體攻擊面(Attack Surface)及相關風險。
- 透過風險導向(Risk-based) 的資安政策與防護措施，降低雲端、人工智慧及指揮、管制、通信、電腦與情報 (Command, Control, Communications, Computers, and Intelligence, C4I) 等重要領域的資安威脅。
- 當裝置、網路、使用者或身分憑證遭到入侵時，能迅速完成損害控制、風險緩解及補救
- 建立一致、相互協調且獲得充分資源支持的零信任能力，以支援進階網路安全作業
- 打造具高度韌性的國防部資訊企業，使其在遭受攻擊後能快速恢復運作，並將損害降至最低。

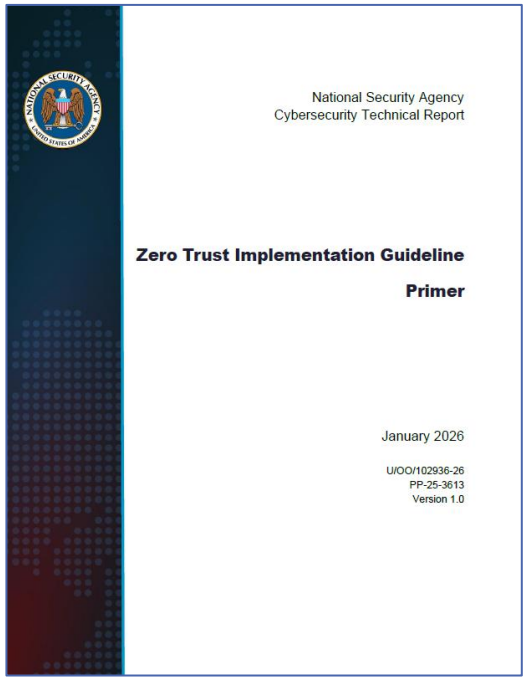
NSA 針對 7 個支柱發表的成熟度文件

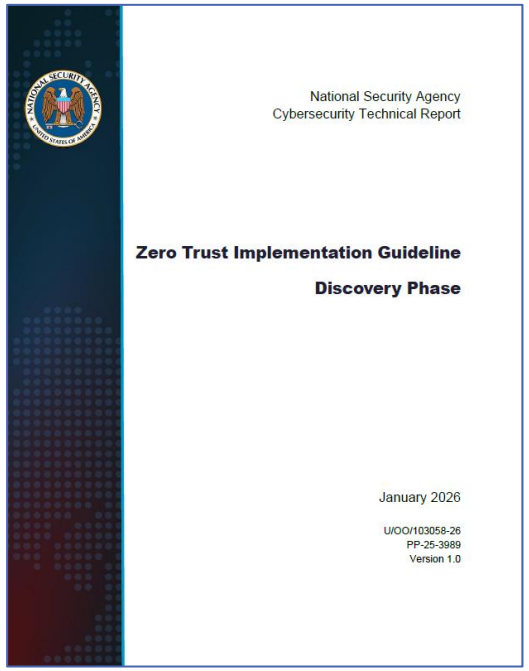
發布日期	文件名稱
2023 年 4 月	Advancing Zero Trust Maturity Throughout the User Pillar
2023 年 10 月	Advancing Zero Trust Maturity Throughout the Device Pillar
2024 年 3 月	Advancing Zero Trust Maturity Throughout the Network and Environment Pillar
2024 年 4 月	Advancing Zero Trust Maturity Throughout the Data Pillar
2024 年 5 月	Advancing Zero Trust Maturity Throughout the Visibility and Analytics Pillar
2024 年 5 月	Advancing Zero Trust Maturity Throughout the Application and Workload Pillar
2024 年 7 月	Advancing Zero Trust Maturity Throughout the Automation and Orchestration Pillar

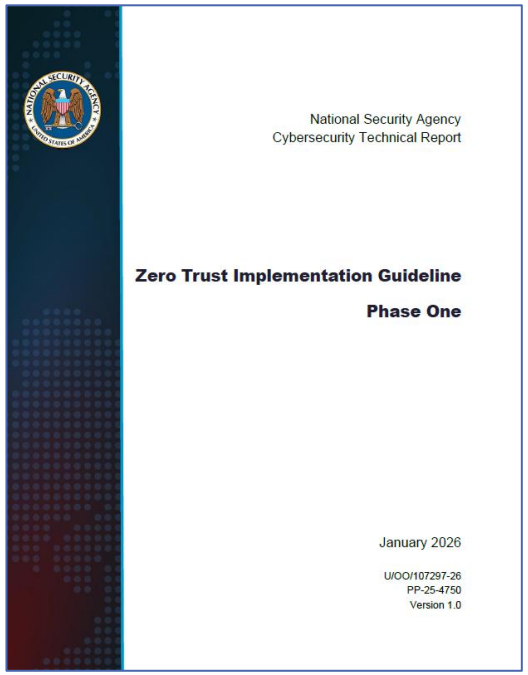
NSA Zero Trust Implementation Guideline (ZIG)

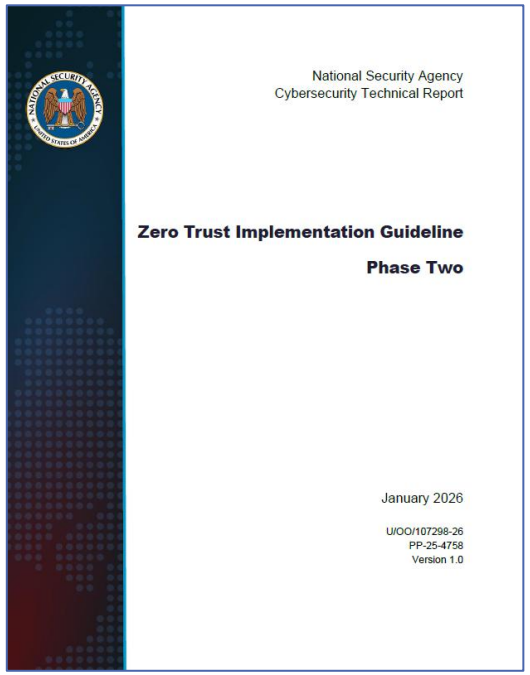
- 目的在於協助美國國防部、國防工業基礎 (Defense Industrial Base, DIB)、國家安全系統，以及其他相關合作組織，將零信任原則整合至其作業流程中，使其能夠達成 DoD「零信任策略」所定義的目標等級零信任能力。

針對目標等級










活動 (152 個活動)
目標等級 (91 個活動)
進階等級 (61 個活動)
探索
(14 個活動)
階段 1
(36 個活動)
階段 2
(41 個活動)
階段 3
(37 個活動)
階段 4
(24 個活動)
能力 (45 個能力)
目標
(15 能力)
持續成熟
(27 能力)
進階
(3 能力)

ZIGs 屬於實作指引

層級	代表文件	作用
政策(Policy)	EO 14028、NSM-8	為何要推動零信任(Why)
策略(Strategy)	DoD Zero Trust Strategy	要達成哪些目標(What)
架構(Architecture)	NIST SP 800-207、DoD ZT RA	如何設計零信任(Architecture)
實作(Implementation)	ZIGs、NSA 七大 Pillar 指引	如何落地執行(How)

NSA ZIG 的基礎理念

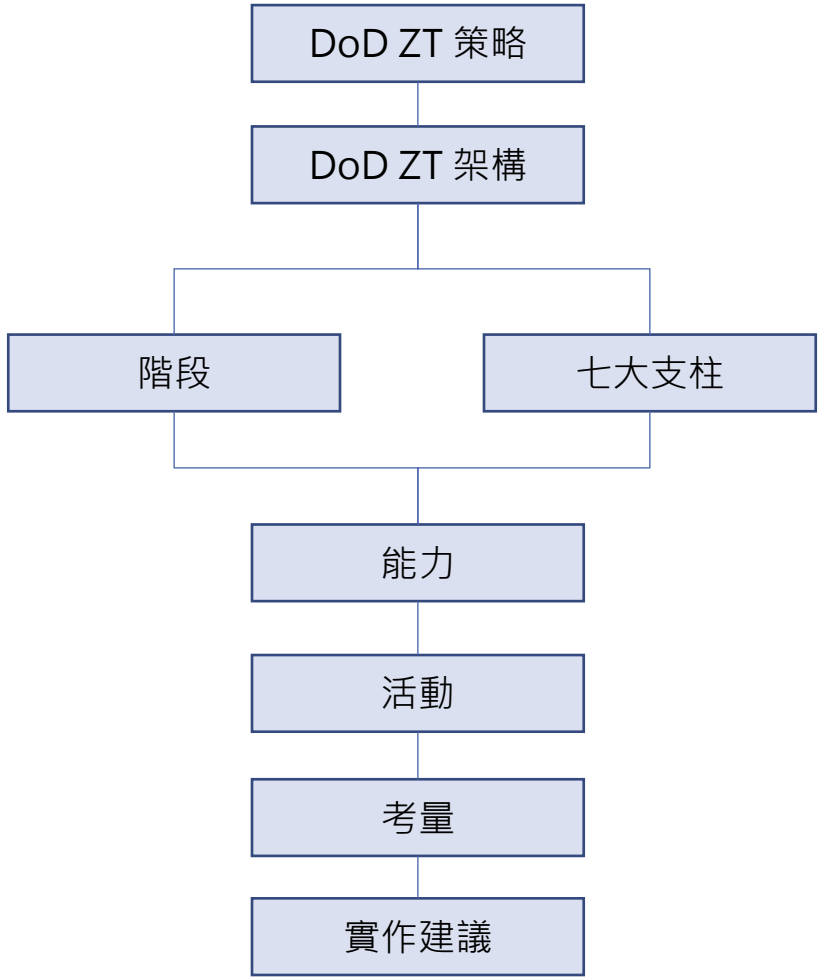
- 基於零信任思維假設
  - 所有環境中的網路流量、使用者、裝置及基礎設施皆可能已遭受入侵或遭到攻擊者控制。
  - 無論實體位於組織內部或外部，都不應預設任何使用者、裝置或系統值得信任。
- 基於 NIST SP 800-207 的三個原則
  - 永不預設信任，持續驗證 (Never Trust, Always Verify)。組織應：
    - 持續進行動態身分驗證
    - 對所有操作進行明確授權
    - 遵循最小權限原則
  - 假設已遭入侵 (Assume Breach)
    - 採取預設拒絕策略
    - 對所有使用者、裝置、資料流及存取請求進行高度審查
    - 持續記錄、檢查及監控
  - 明確驗證 (Verify Explicitly)：所有資源的存取都應透過安全且一致的驗證程序完成。
- 零信任是一種整體性的資安方法：零信任並非單純的一項資訊科技 (IT) 解決方案，而是一套整體性的網路安全方法 (Holistic Cybersecurity Approach)。
- ZIGs是一套「最佳實務與實施指引」，而不是強制性的法規或標準。
  - 並非強制性規範、並非適用所有組織的標準答案、並非針對特定廠商、不會取代既有法規、政策或主管機關權限

設計零信任架構的關鍵概念

- 以任務成果 (Mission Outcomes) 為設計起點：
  - 零信任架構應從組織的任務需求 (Mission Requirements) 出發，而非由技術開始規劃。
- 採用由內而外(Inside-Out)的架構設計：
  - 零信任架構的建置應遵循以下順序：優先保護關鍵 DAAS；再保護所有可存取 DAAS 的路徑。
- 明確界定誰(Who)與什麼(What)需要存取 DAAS，以建立存取控制政策：
  - 組織應識別所有需要存取關鍵 DAAS 的來源，如使用者(Users)、人員實體(Person Entities, PE)、非人員實體(Non-Person Entities, NPE)、裝置應用程式工作負載(Workloads)等，並據此制定一致性的存取控制政策(Access Control Policies)。
- 先檢查、記錄，再採取行動：
  - 組織應建立完整且全面的可視性 (Visibility)，持續監控所有層級的活動
  - 各類系統元件所有流量與操作都應先經過檢查 (Inspect)及記錄(Log)，再決定是否允許執行。

導論

- 目的
  - 說明零信任架構發展的歷史背景，以及相關政策與法規要求。
  - 提供使用各份 ZIGs 的方向與指引，協助組織理解如何運用這些文件推動零信任導入。
  - 說明 ZIGs 所採用的方法論，以及如何定義各項零信任活動與其實施流程 。
- 目前只針對 IT ，未來會更進一步考慮營運技術 (OT)、國防關鍵基礎設施 (Defense Critical Infrastructure, DCI)，以及戰術系統/武器系統 (Tactical/ Weapons Systems)
- 介紹 ZIG 之設計方法
  - 以 DoD Zero Trust Framework 為基礎
  - 以 Activity 為最小設計單位
  - 採模組化設計
  - 不採固定流程
  - 著重可執行性
  - 與 DoD ZT 策略一致



探索階段

- 主要有五個目的
  - 建立現況基線
  - 進行完整資產盤點
  - 找出能力缺口
  - 作為後續 Phase 的基礎
  - 降低導入風險
- 核心原則
  - 先盤點後治理 (Inventory First)
  - 先了解後導入 (Understand Before Implement)
  - 以盤點資料作為決策依據 (Data-driven)
  - 不預設任何已知狀態 (No Assumption)
  - 建立後續實作基礎 (Foundation Building)
  - 循序漸進推動 (Incremental Adoption)

使用者	• 能力 1.1 使用者盤點
裝置	• 能力 2.1 裝置盤點 • 能力 2.3 即時檢測式裝置授權
應用程式與工作負載	• 能力 3.1 應用程式盤點
資料	• 能力 4.1 資料目錄與風險校準 • 能力 4.4 資料監控與偵測
網路與環境	• 能力 5.1 資料流向盤點 • 能力 5.2 軟體定義網路
自動化與協同調度	• 能力 6.1 政策決策點與協同調度 • 能力 6.2 關鍵流程自動化 • 能力 6.5 SOAR • 能力 6.6 API 標準化
可視性與分析	• 能力 7.1 全面記錄所有流量

探索階段能力與活動

使用者	• 能力 1.1 使用者盤點	• 活動 1.1.1 盤點使用者
裝置	• 能力 2.1 裝置盤點 • 能力 2.3 即時檢測式裝置授權	• 活動 2.1.1 裝置健康度工具差異分析 • 活動 2.3.4：整合新世代防毒工具與符合才能連線 (Comply-to-Connect, C2C) 機制
應用程式與工作負載	• 能力 3.1 應用程式盤點	• 活動 3.1.1 應用程式與程式碼識別
資料	• 能力 4.1 資料目錄與風險校準 • 能力 4.4 資料監控與偵測	• 活動 4.4.1：資料外洩防護 (DLP) 執行點之日誌記錄與分析 • 活動 4.4.2：資料權利管理 (DRM) 執行點之日誌記錄與分析
網路與環境	• 能力 5.1 資料流向盤點 • 能力 5.2 軟體定義網路	• 活動 5.1.1：建立細粒度存取控制規則與政策 (第一部分) • 活動 5.2.1：定義軟體定義網路 (SDN) 之應用程式介面(API)
自動化與協同調度	• 能力 6.1 政策決策點與協同調度 • 能力 6.2 關鍵流程自動化 • 能力 6.5 SOAR • 能力 6.6 API 標準化	• 活動 6.1.1：政策盤點與制定 • 活動 6.2.1：工作自動化(適合性)分析 • 活動 6.5.1：事件回應自動化化(適合性)分析 • 活動 6.6.1：工具相容性與符合性分析
可視性與分析	• 7.1 全面記錄所有流量	• 活動 7.1.1：規模考量

建立

階段 1

- 以探索階段成果為基礎，建立支援零信任的安全基礎與核心能力。
- 主要工作
  - 建立零信任基礎能力 (MFA、ICAM、EDR、DLP、SIEM 等)
  - 建立政策、治理與管理制度
  - 推動標準化 (API、標籤、資料模型、日誌)
  - 建立各支柱目標等級能力
  - 為階段 2 的整合與自動化奠定基礎
- 核心原則
  - 先建立基礎 (Foundation First)
  - 先標準化，再整合 (Standardize Before Integrate)
  - 以政策驅動 (Policy-driven)
  - 從設計就考慮到安全 (Security by Design)
  - 全組織一致性 (Enterprise Consistency)
  - 循序漸進部署 (Incremental Deployment)
  - 為後續整合做準備 (Prepare for Integration)

使用者	• 能力 1.3 多因子鑑別 (MFA) • 能力 1.4 特權存取管理 • 能力 1.5身分聯邦與使用者憑證管理 • 能力 1.7 最小權限存取 • 能力1.8持續性身分驗證
裝置	• 能力 2.1 裝置盤點 • 能力 2.4 遠端存取 • 能力 2.5 資產、弱點與修補管理 (部分 / 全面自動化) • 能力 2.6 統一端點管理 (UEM)與行動裝置管理 (MDM) • 能力 2.7 端點與延伸式偵測及回應
應用程式與工作負載	• 能力 3.2 安全軟體開發與整合 • 能力 3.3 軟體風險管理 • 能力3.4 資源存取授權與整合
資料	• 能力 4.2 DoD 企業資料治理 • 能力 4.3 資料標示與標籤管理 • 能力 4.4 資料監控與偵測 • 能力 4.5 資料加密與權限管理 • 能力 4.6 資料外洩防護(DLP)

階段 1

- 以探索階段成果為基礎，建立支援零信任的安全基礎與核心能力。
- 主要工作
  - 建立零信任基礎能力 (MFA、ICAM、EDR、DLP、SIEM 等)
  - 建立政策、治理與管理制度
  - 推動標準化 (API、標籤、資料模型、日誌)
  - 建立各支柱目標等級能力
  - 為階段 2 的整合與自動化奠定基礎
- 核心原則
  - 先建立基礎 (Foundation First)
  - 先標準化，再整合 (Standardize Before Integrate)
  - 以政策驅動 (Policy-driven)
  - 從設計就考慮到安全 (Security by Design)
  - 全組織一致性 (Enterprise Consistency)
  - 循序漸進部署 (Incremental Deployment)
  - 為後續整合做準備 (Prepare for Integration)

網路與環境	• 能力 5.1 資料流向盤點 • 能力 5.2 軟體定義網路 • 能力 5.3 巨分段 • 能力 5.4 巨分段
自動化與協同調度	• 能力 6.1 政策決策點與協同調度 • 能力 6.5 SOAR • 能力 6.6 API 標準化 • 能力 6.7 安全維運中心與事件應變
可視性與分析	• 能力 7.1 全面記錄所有流量 • 能力 7.2 安全資訊與事件管理 • 能力 7.3 共通安全與風險分析 • 能力 7.5 威脅情資整合

階段 1 能力與活動 (1/2)

使用者	• 能力 1.3 多因子鑑別 (MFA) • 能力 1.4 特權存取管理 • 能力 1.5身分聯邦與使用者憑證管理 • 能力 1.7 最小權限存取 • 能力 1.8持續性身分驗證	• 活動 1.3.1：建置組織多因素驗證與身分提供者 • 活動 1.4.1：建置系統並遷移特權使用者 (第一部分) • 活動 1.5.1：建立組織身分生命週期管理 • 活動 1.7.1：預設拒絕使用者存取政策 • 活動 1.8.1：單次身分驗證
裝置	• 能力 2.1 裝置盤點 • 能力 2.4 遠端存取 • 能力 2.5 資產、弱點與修補管理 (部分 / 全面自動化) • 能力 2.6 統一端點管理 (UEM)與行動裝置管理 (MDM) • 2.7 端點與延伸式偵測及回應	• 活動 2.1.2：將非人員實體及公開金鑰基礎設施裝置納入管理 • 活動 2.4.1：預設拒絕裝置存取政策 • 活動 2.5.1：部署資產、弱點與修補管理工具 • 活動 2.6.1：部署統一端點與裝置管理或同等功能工具 • 活動 2.6.2：企業裝置管理 (第一部分) • 活動 2.7.1：部署端點偵測與回應工具，並整合至符合才能連線 (Comply-to-Connect, C2C) 機制
應用程式與工作負載	• 能力 3.2 安全軟體開發與整合 • 能力 3.3 軟體風險管理 • 能力 3.4 資源存取授權與整合	• 活動 3.2.1：建置 DevSecOps 軟體工廠(第一部分) • 活動 3.2.2：建置 DevSecOps 軟體工廠(第二部分) • 活動 3.3.1：核准之二進位檔與程式碼管理 • 活動 3.3.2：弱點管理計畫(第一部分) • 活動 3.4.1：資源授權(第一部分) • 活動 3.4.3：軟體定義運算資源授權(第一部分)

高風險特權帳號要透過 PAM才能登入

整合認證機制

讓所有裝置可被管

裝置可做

建立平台

都在上面做

建立制度

能夠建立針對 VM 的授權機制

階段 1 能力與活動 (2/2)

資料	• 能力 4.2 DoD 企業資料治理 • 能力 4.3 資料標示與標籤管理 • 能力 4.4 資料監控與偵測 • 能力 4.5 資料加密與權限管理 • 能力 4.6 資料外洩防護(DLP)	• 活動 4.2.1：制定資料標籤標準 • 活動 4.2.2：制定互通性標準 • 活動 4.3.1：部署資料標籤與分類工具 • 活動 4.4.3：檔案活動監控 (第一部分) • 活動 4.5.1：部署資料權利管理與資料保護工具 (第一部分) • 活動 4.6.1：部署政策執行點
網路與環境	• 能力 5.1 資料流向盤點 • 能力 5.2 軟體定義網路 • 能力 5.3 巨分段 • 能力 5.4 巨分段	• 活動 5.1.2：定義細粒度存取控制規則與政策 (第二部分) • 活動 5.2.2：部署軟體定義網路可程式化基礎架構 • 活動 5.3.1：資料中心巨集分段 • 活動 5.4.1：部署微分段
自動化與協同調度	• 能力 6.1 政策決策點與協同調度 • 能力 6.5 SOAR • 能力 6.6 API 標準化 • 能力 6.7 安全維運中心與事件應變	• 活動 6.1.2：建立組織存取設定檔 • 活動 6.5.2：部署安全協同調度、自動化與回應工具 • 活動 6.6.2：標準化應用程式介面呼叫與綱要 (第一部分) • 活動 6.7.1：工作流程強化 (第一部分)
可視性與分析	• 能力 7.1 全面記錄所有流量 • 能力 7.2 安全資訊與事件管理 • 能力 7.3 共通安全與風險分析 • 能力 7.5 威脅情資整合	• 活動 7.1.2：日誌解析 • 活動 7.2.1：威脅告警 (第一部分) • 活動 7.2.4：資產識別與告警關聯分析 • 活動 7.3.1：部署分析工具 • 活動 7.5.1：建立網路威脅情資計畫 (第一部分)

看的到

有 DRM

可執行

有收資料

階段 2

- 階段2以探索階段與階段 1建立的基礎能力為基礎，開始將各項零信任核心解決方案整合至組織資訊環境中，建立跨支柱協同運作的零信任架構，並逐步實現動態、風險導向的存取控制與自動化安全管理。
- 主要工作
  - 整合七大 支柱
  - 建立動態授權與風險導向存取控制
  - 建立跨系統 API 與自動化流程
  - 建立持續驗證與持續監控
  - 推動企業層級整合與資訊共享
- 核心原則
  - 先整合，再最佳化 (Integration First)
  - 預設採用自動化 (Automation by Default)
  - 動態授權決策 (Dynamic Decision Making)
  - 持續驗證 (Continuous Validation)
  - 全組織協同 (Enterprise-wide Coordination)
  - 以政策驅動整合 (Policy-driven Integration)

階段 2 能力與活動 (1/3)

使用者	• 能力 1.2：條件式使用者存取 • 能力 1.4：特權存取管理 • 能力 1.5：身分聯邦與使用者憑證管理 • 能力 1.6：行為分析、情境式身分識別與生物特徵驗證 • 能力 1.8：持續性身分驗證 • 能力 1.9：整合式身分、憑證與存取管理平台	• 活動 1.2.1：依企業規範實作應用程式權限 • 活動 1.2.2：規則式動態存取(第一部分) • 活動 1.4.2：建置系統並遷移特權使用者(第二部分) • 活動 1.5.2：企業身分生命週期管理(第一部分) • 活動 1.6.1：部署使用者與實體行為分析(UEBA)及使用者活動監控(UAM)工具 • 活動 1.8.2：週期性身分驗證 • 活動 1.9.1：企業公開金鑰基礎設施(PKI)與身分提供者(IdP)(第一部分)
裝置	• 能力 2.1：裝置盤點 • 能力 2.2：裝置偵測與合規性檢查 • 能力 2.3：具即時檢測的裝置授權 • 能力 2.4：遠端存取 • 能力 2.6：統一端點管理與行動裝置管理 • 能力 2.7：端點與延伸式偵測及回應	• 活動 2.1.3：企業身分提供者 (第一部分) • 活動 2.2.1：部署符合才能連線機制 (第一部分) • 活動 2.3.3：部署應用程式控制與檔案完整性監控工具 • 活動 2.4.2：支援受管理且受限制的自攜裝置與物聯網 • 活動 2.6.3：企業裝置管理 (第二部分) • 活動 2.7.2：部署延伸式偵測與回應 (XDR) 工具，並整合符合才能連線機制 (第一部分)
應用程式與工作負載	• 能力 3.2：安全軟體開發與整合 • 能力 3.3：軟體風險管理 • 能力 3.4：資源授權與整合	• 活動 3.2.3：自動化應用程式安全與程式碼修復 (第一部分) • 活動 3.3.3：弱點管理計畫 (第二部分) • 活動 3.3.4：持續驗證 • 活動 3.4.2：資源授權 (第二部分) • 活動 3.4.4：軟體定義運算資源授權 (第二部分)

全面納管特權帳號

裝置也納入 IdP

落實連網決定

資訊整合

整合到開發流程

能動態授權

階段 2 能力與活動 (2/3)

資料	• 能力 4.2：DoD 整體資料治理 • 能力 4.3：資料標示與標籤管理 • 能力 4.4：資料監控與感知 • 能力 4.5：資料加密與資料權利管理 • 能力 4.6：資料外洩防護 • 能力 4.7：資料存取控制	• 活動 4.2.3：制定軟體定義儲存政策 • 活動 4.3.2：人工資料標示 (第一部分) • 活動 4.4.4：檔案活動監控 (第二部分) • 活動 4.5.2：部署資料權利管理與資料保護工具 (第二部分) • 活動 4.5.3：透過資料標籤與分析實施資料權利管理 (第一部分) • 活動 4.6.2：透過資料標籤與分析實施資料外洩防護 (第一部分) • 活動 4.7.1：整合資料、應用程式、資產與服務存取控制與軟體定義儲存政策 (第一部分) • 活動 4.7.4：整合解決方案與政策至企業身分提供者(第一部分)
網路與環境	• 能力 5.2：軟體定義網路 • 能力 5.3：巨分段 • 能力 5.4：微分段	• 活動 5.2.3：將網路流量劃分為控制平面、管理平面與資料平面 • 活動 5.3.2：基地/營區/駐地巨集分段 • 活動 5.4.2：應用程式與裝置微分段 • 活動 5.4.4：保護傳輸中的資料
自動化與協同調度	• 能力 6.1：政策決策點與政策作 • 能力 6.2：關鍵流程自動化 • 能力 6.3：機器學習 • 能力 6.6：應用程式介面標準化 • 能力 6.7：安全維運中心與事件回應	• 活動 6.1.3：企業安全設定檔(第一部分) • 活動 6.2.2：企業整合與工作流程佈建(第一部分) • 活動 6.3.1：部署資料標示與分類機器學習工具 • 活動 6.6.3：標準化應用程式介面(API)呼叫與綱要(第二部分) • 活動 6.7.2：工作流程強化(第二部分)

能執行

階段 2 能力與活動 (3/3)

可視性與分析	• 能力 7.1：全面記錄所有流量 • 能力 7.2：安全資訊與事件管理 • 能力 7.3：共通安全與風險分析 • 能力 7.4：使用者與實體行為分析 • 能力 7.5：威脅情資整合	• 活動 7.1.3：日誌分析 • 活動 7.2.2：威脅告警(第二部分) • 活動 7.2.5：建立使用者與裝置基準 • 活動 7.3.2：建立使用者行為基準 • 活動 7.4.1：建立基準與行為剖析(第一部分) • 活動 7.5.2：網路威脅情資(CTI)計畫(第二部分)

能整合到零信任

跨階段比較–使用者

探索	• 能力 1.1 使用者盤點	• 活動 1.1.1 盤點使用者
階段 1	• 能力 1.3 多因子鑑別 (MFA) • 能力 1.4 特權存取管理 • 能力 1.5身分聯邦與使用者憑證管理 • 能力 1.7 最小權限存取 • 能力 1.8持續性身分驗證	• 活動 1.3.1：建置組織多因素驗證與身分提供者 • 活動 1.4.1：建置系統並遷移特權使用者 (第一部分) • 活動 1.5.1：建立組織身分生命週期管理 • 活動 1.7.1：預設拒絕使用者存取政策 • 活動 1.8.1：單次身分驗證
階段 2	• 能力 1.2：條件式使用者存取 • 能力 1.4：特權存取管理 • 能力 1.5：身分聯邦與使用者憑證管理 • 能力 1.6：行為分析、情境式身分識別與生物特徵驗證 • 能力 1.8：持續性身分驗證 • 能力 1.9：整合式身分、憑證與存取管理平台	• 活動 1.2.1：依企業規範實作應用程式權限 • 活動 1.2.2：規則式動態存取(第一部分) • 活動 1.4.2：建置系統並遷移特權使用者(第二部分) • 活動 1.5.2：企業身分生命週期管理(第一部分) • 活動 1.6.1：部署使用者與實體行為分析(UEBA)及使用者活動監控(UAM)工具 • 活動 1.8.2：週期性身分驗證 • 活動 1.9.1：企業公開金鑰基礎設施(PKI)與身分提供者(IdP)(第一部分)

跨階段比較—裝置

探索	• 能力 2.1 裝置盤點 • 能力 2.3 即時檢測式裝置授權	• 活動 2.1.1 裝置健康度工具差異分析 • 活動 2.3.4：整合新世代防毒工具與符合才能連線 (Comply-to-Connect, C2C) 機制
階段 1	• 能力 2.1 裝置盤點 • 能力 2.4 遠端存取 • 能力 2.5 資產、弱點與修補管理 (部分 / 全面自動化) • 能力 2.6 統一端點管理 (UEM)與行動裝置管理 (MDM) • 2.7 端點與延伸式偵測及回應	• 活動 2.1.2：將非人員實體及公開金鑰基礎設施裝置納入管理 • 活動 2.4.1：預設拒絕裝置存取政策 • 活動 2.5.1：部署資產、弱點與修補管理工具 • 活動 2.6.1：部署統一端點與裝置管理或同等功能工具 • 活動 2.6.2：企業裝置管理 (第一部分) • 活動 2.7.1：部署端點偵測與回應工具，並整合至符合才能連線 (Comply-to-Connect, C2C) 機制
階段 2	• 能力 2.1：裝置盤點 • 能力 2.2：裝置偵測與合規性檢查 • 能力 2.3：具即時檢測的裝置授權 • 能力 2.4：遠端存取 • 能力 2.6：統一端點管理與行動裝置管理 • 能力 2.7：端點與延伸式偵測及回應	• 活動 2.1.3：企業身分提供者 (第一部分) • 活動 2.2.1：部署符合才能連線機制 (第一部分) • 活動 2.3.3：部署應用程式控制與檔案完整性監控工具 • 活動 2.4.2：支援受管理且受限制的自攜裝置與物聯網 • 活動 2.6.3：企業裝置管理 (第二部分) • 活動 2.7.2：部署延伸式偵測與回應 (XDR) 工具，並整合符合才能連線機制 (第一部分)

跨階段比較–應用程式與工作負載

探索	• 能力 3.1 應用程式盤點	• 活動 3.1.1 應用程式與程式碼識別
階段 1	• 能力 3.2 安全軟體開發與整合 • 能力 3.3 軟體風險管理 • 能力 3.4 資源存取授權與整合	• 活動 3.2.1：建置 DevSecOps 軟體工廠(第一部分) • 活動 3.2.2：建置 DevSecOps 軟體工廠(第二部分) • 活動 3.3.1：核准之二進位檔與程式碼管理 • 活動 3.3.2：弱點管理計畫(第一部分) • 活動 3.4.1：資源授權(第一部分) • 活動 3.4.3：軟體定義運算資源授權(第一部分)
階段 2	• 能力 3.2：安全軟體開發與整合 • 能力 3.3：軟體風險管理 • 能力 3.4：資源授權與整合	• 活動 3.2.3：自動化應用程式安全與程式碼修復 (第一部分) • 活動 3.3.3：弱點管理計畫 (第二部分) • 活動 3.3.4：持續驗證 • 活動 3.4.2：資源授權 (第二部分) • 活動 3.4.4：軟體定義運算資源授權 (第二部分)

跨階段比較—資料

探索	• 能力 4.1 資料目錄與風險校準 • 能力 4.4 資料監控與偵測	• 活動 4.4.1：資料外洩防護 (DLP) 執行點之日誌記錄與分析 • 活動 4.4.2：資料權利管理 (DRM) 執行點之日誌記錄與分析
階段 1	• 能力 4.2 DoD 企業資料治理 • 能力 4.3 資料標示與標籤管理 • 能力 4.4 資料監控與偵測 • 能力 4.5 資料加密與權限管理 • 能力 4.6 資料外洩防護(DLP)	• 活動 4.2.1：制定資料標籤標準 • 活動 4.2.2：制定互通性標準 • 活動 4.3.1：部署資料標籤與分類工具 • 活動 4.4.3：檔案活動監控 (第一部分) • 活動 4.5.1：部署資料權利管理與資料保護工具 (第一部分) • 活動 4.6.1：部署政策執行點
階段 2	• 能力 4.2：DoD 整體資料治理 • 能力 4.3：資料標示與標籤管理 • 能力 4.4：資料監控與感知 • 能力 4.5：資料加密與資料權利管理 • 能力 4.6：資料外洩防護 • 能力 4.7：資料存取控制	• 活動 4.2.3：制定軟體定義儲存政策 • 活動 4.3.2：人工資料標示 (第一部分) • 活動 4.4.4：檔案活動監控 (第二部分) • 活動 4.5.2：部署資料權利管理與資料保護工具 (第二部分) • 活動 4.5.3：透過資料標籤與分析實施資料權利管理 (第一部分) • 活動 4.6.2：透過資料標籤與分析實施資料外洩防護 (第一部分) • 活動 4.7.1：整合資料、應用程式、資產與服務存取控制與軟體定義儲存政策 (第一部分) • 活動 4.7.4：整合解決方案與政策至企業身分提供者(第一部分)

跨階段比較—網路與環境

探索	• 能力 5.1 資料流向盤點 • 能力 5.2 軟體定義網路	• 活動 5.1.1：建立細粒度存取控制規則與政策 (第一部分) • 活動 5.2.1：定義軟體定義網路 (SDN) 之應用程式介面(API)
階段 1	• 能力 5.1 資料流向盤點 • 能力 5.2 軟體定義網路 • 能力 5.3 巨分段 • 能力 5.4 巨分段	• 活動 5.1.2：定義細粒度存取控制規則與政策 (第二部分) • 活動 5.2.2：部署軟體定義網路可程式化基礎架構 • 活動 5.3.1：資料中心巨集分段 • 活動 5.4.1：部署微分段
階段 2	• 能力 5.2：軟體定義網路 • 能力 5.3：巨分段 • 能力 5.4：微分段	• 活動 5.2.3：將網路流量劃分為控制平面、管理平面與資料平面 • 活動 5.3.2：基地/營區/駐地巨集分段 • 活動 5.4.2：應用程式與裝置微分段 • 活動 5.4.4：保護傳輸中的資料

跨階段比較—自動化與協同調度

探索	• 能力 6.1 政策決策點與協同調度 • 能力 6.2 關鍵流程自動化 • 能力 6.5 SOAR • 能力 6.6 API 標準化	• 活動 6.1.1：政策盤點與制定 • 活動 6.2.1：工作自動化(適合性)分析 • 活動 6.5.1：事件回應自動化化(適合性)分析 • 活動 6.6.1：工具相容性與符合性分析
階段 1	• 能力 6.1 政策決策點與協同調度 • 能力 6.5 SOAR • 能力 6.6 API 標準化 • 能力 6.7 安全維運中心與事件應變	• 活動 6.1.2：建立組織存取設定檔 • 活動 6.5.2：部署安全協同調度、自動化與回應工具 • 活動 6.6.2：標準化應用程式介面呼叫與綱要 (第一部分) • 活動 6.7.1：工作流程強化 (第一部分)
階段 2	• 能力 6.1：政策決策點與政策作 • 能力 6.2：關鍵流程自動化 • 能力 6.3：機器學習 • 能力 6.6：應用程式介面標準化 • 能力 6.7：安全維運中心與事件回應	• 活動 6.1.3：企業安全設定檔(第一部分) • 活動 6.2.2：企業整合與工作流程佈建(第一部分) • 活動 6.3.1：部署資料標示與分類機器學習工具 • 活動 6.6.3：標準化應用程式介面(API)呼叫與綱要(第二部分) • 活動 6.7.2：工作流程強化(第二部分)

跨階段比較–可視性與分析

探索	• 7.1 全面記錄所有流量	• 活動 7.1.1：規模考量
階段 1	• 能力 7.1 全面記錄所有流量 • 能力 7.2 安全資訊與事件管理 • 能力 7.3 共通安全與風險分析 • 能力 7.5 威脅情資整合	• 活動 7.1.2：日誌解析 • 活動 7.2.1：威脅告警 (第一部分) • 活動 7.2.4：資產識別與告警關聯分析 • 活動 7.3.1：部署分析工具 • 活動 7.5.1：建立網路威脅情資計畫 (第一部分)
階段 2	• 能力 7.1：全面記錄所有流量 • 能力 7.2：安全資訊與事件管理 • 能力 7.3：共通安全與風險分析 • 能力 7.4：使用者與實體行為分析 • 能力 7.5：威脅情資整合	• 活動 7.1.3：日誌分析 • 活動 7.2.2：威脅告警(第二部分) • 活動 7.2.5：建立使用者與裝置基準 • 活動 7.3.2：建立使用者行為基準 • 活動 7.4.1：建立基準與行為剖析(第一部分) • 活動 7.5.2：網路威脅情資(CTI)計畫(第二部分)

零信任架構的本質與核心概念

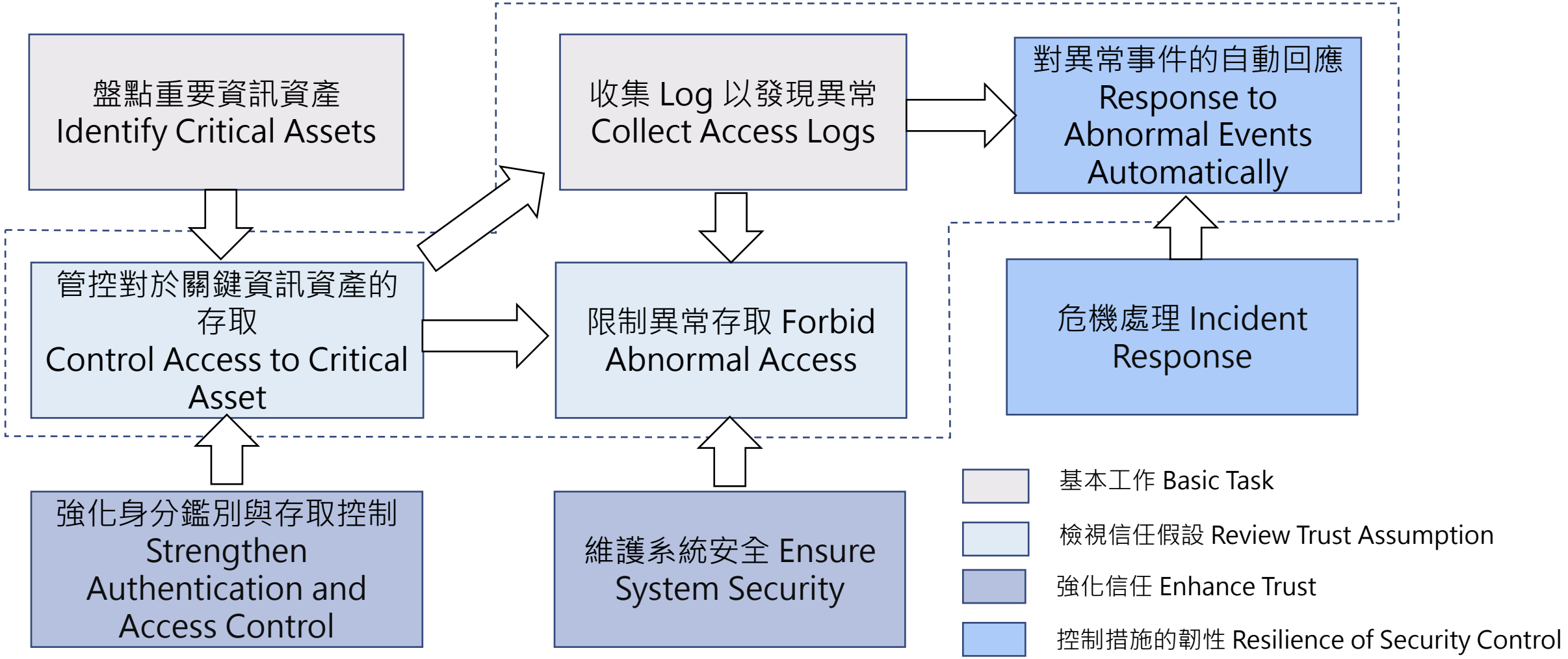
從美國的要求來看各項資安控制的意義

零信任架構的實作架構

AI 代理人與零信任架構

結論

從零信任架構的導入，應該要執行的基本工作 Fundamental Tasks for Implementing ZTA

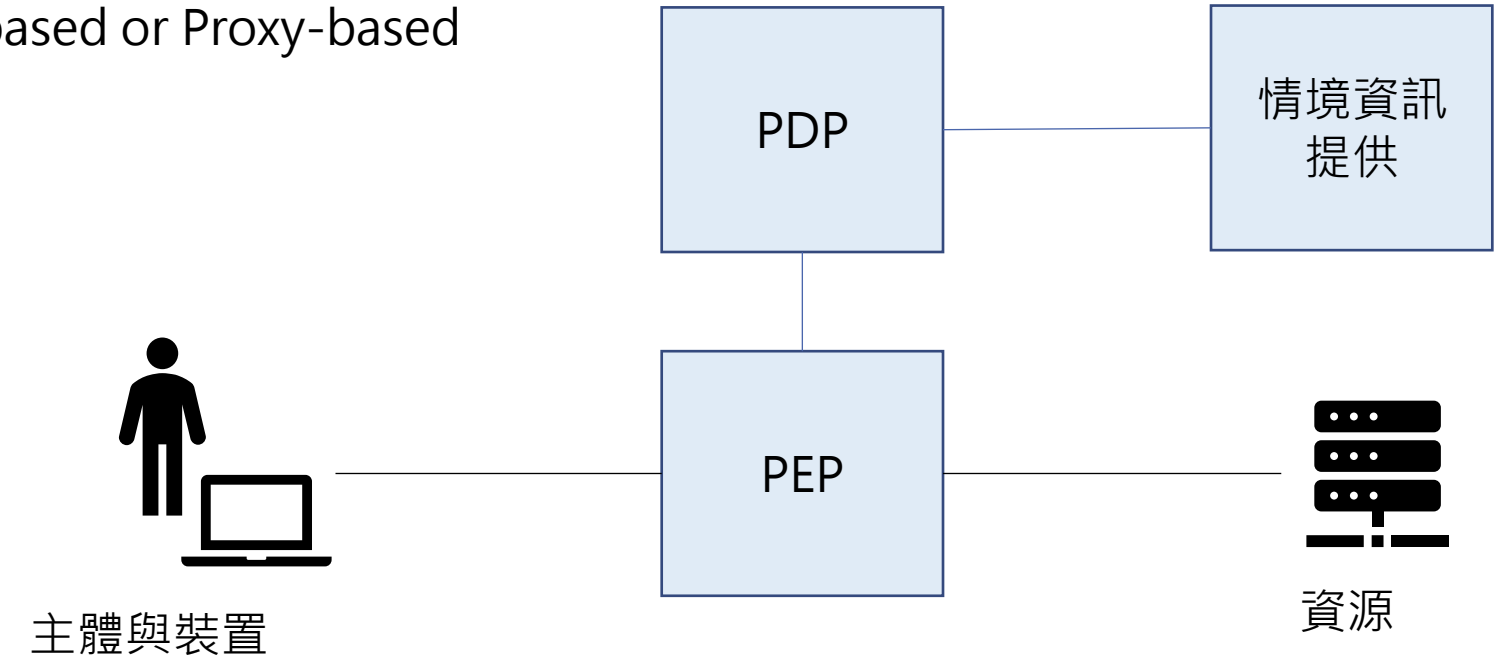


技術

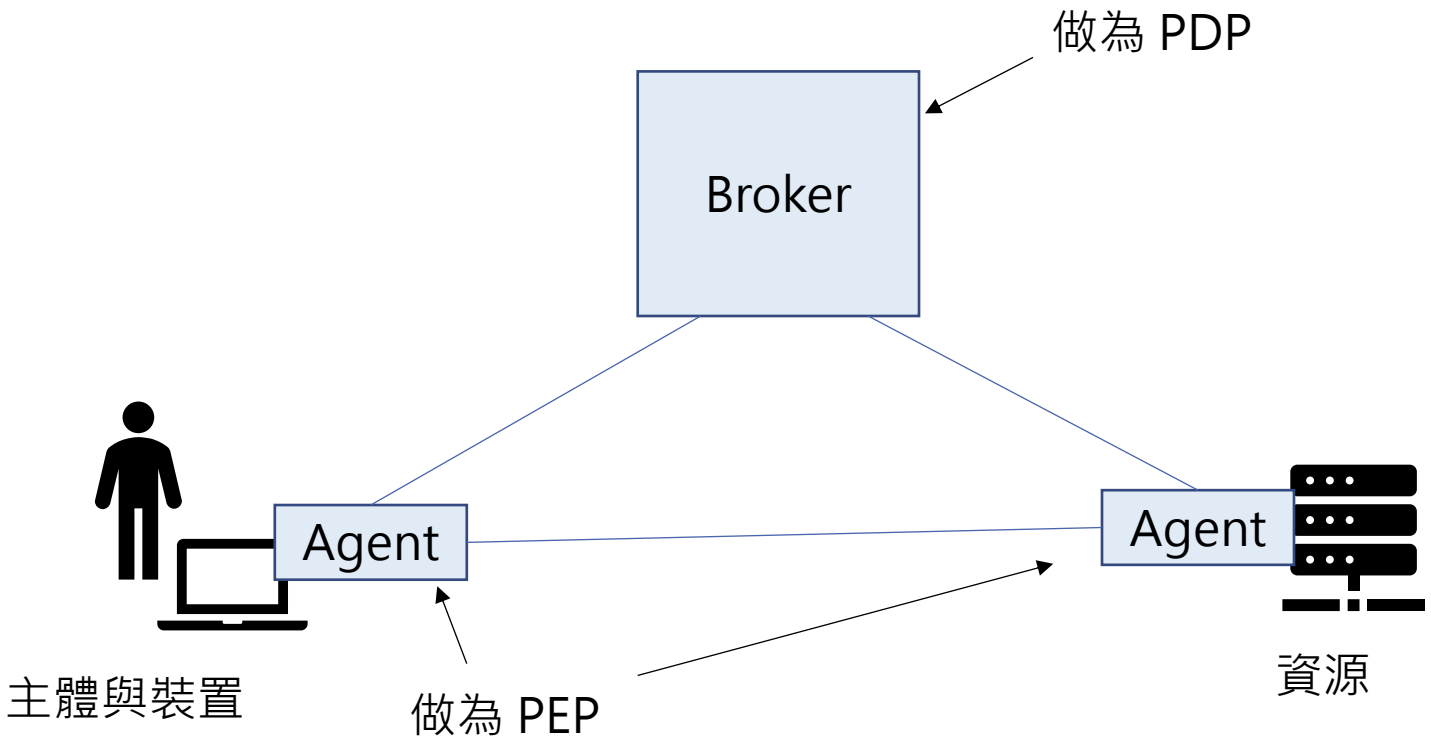
管理

常見實作架構－EIG (Enhanced Identity Governance)

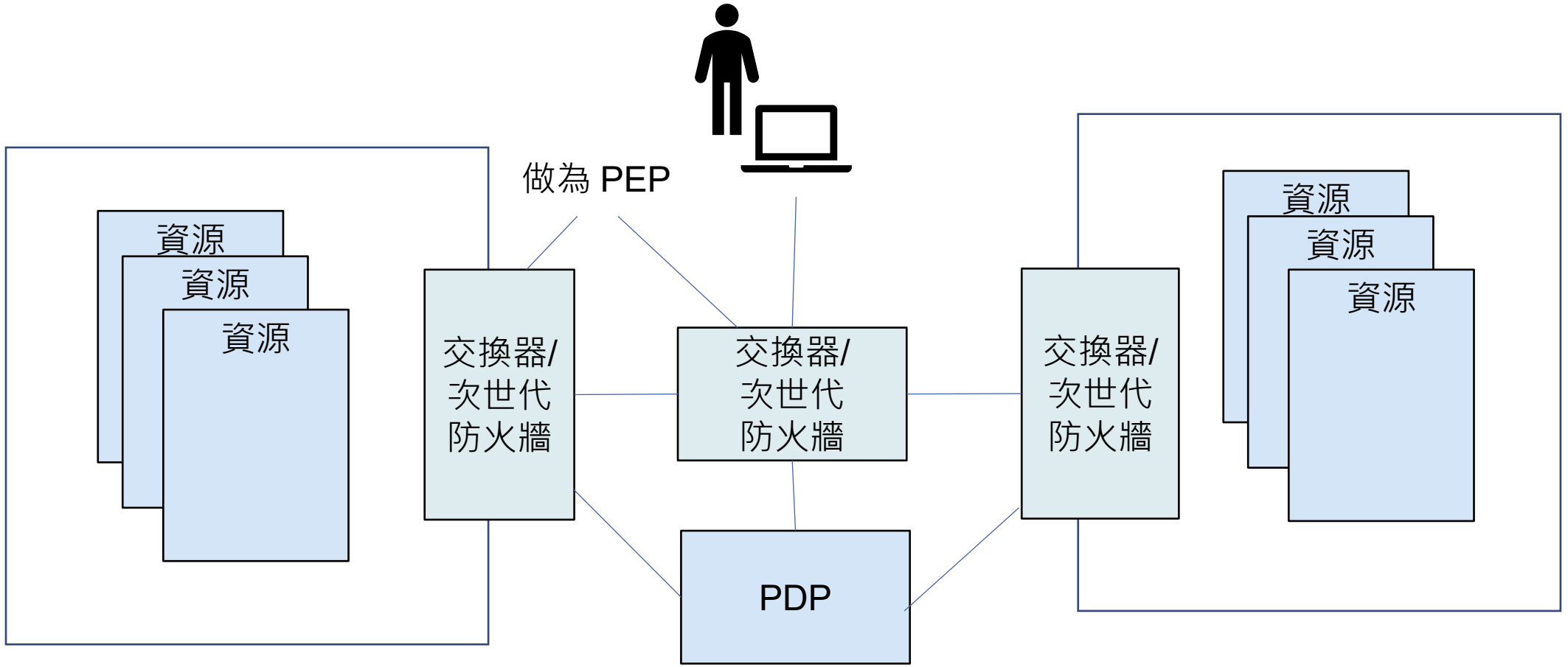
- EIG (Enhanced Identity Governance)
- SDP (Software-Defined Perimeter)
- Micro-Segmentation
- Broker-based or Proxy-based



常見實作架構－SDP (Software-Defined Perimeter)

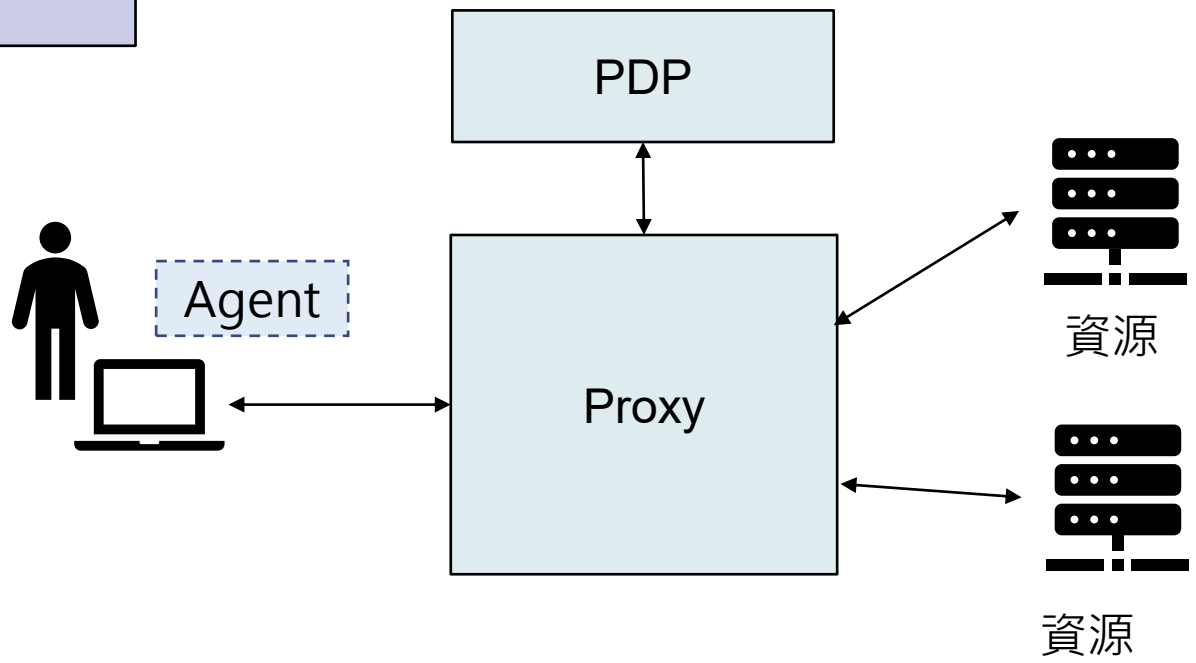


常見實作架構 – 微分割 (Micro-Segmentation)



常見實作架構－Proxy-based Gateway

可以說是 EIG 的一種特別情境



ISO 27002:2022 的作業能力分類



治理與人力資源安全作業能力相關程序中的零信任架構考量

A.5.1	資訊安全政策	A.5.1.1建立資訊安全政策 A.5.1.2對於相關政策的審查
A.5.2	資訊安全角色與責任	A.6.1.1 資訊安全角色與責任
A.5.3	分工	A.6.1.2 分工
A.5.4	管理者責任	A.7.2.1管理階層責任
A.5.5	與權責單位聯繫	A.6.1.3與權責單位的聯繫
A.5.6	與特殊利害關係團體聯繫	A.6.1.4與特殊利害關係團體的聯繫
A.5.8	在專案管理中內入資訊安全	A.14.1.1資訊安全需求分析與規格定義 A.6.1.5 專案管理中的資訊安全考量
A.5.24	規劃與準備意外事件管理	A.16.1.1責任與程序

資安政策當中可以納入對於符合零信任架構的目標與指標

A.6.1	背景過濾	A.7.1.1背景篩選
A.6.2	聘僱條款	A.7.1.2聘僱條款
A.6.3	資訊安全教育訓練與宣導	A.7.2.2資訊安全認知、教育、訓練
A.6.4	處分程序	A.7.2.3懲處過程
A.6.5	聘僱終止與變更後的責任	A.7.3.1聘用責任之終止與變更
A.6.6	保密合約	A.13.2.4 保密或資訊不可揭露協議

專案的系統規格要考量到與零信任架構元件的整合

需要納入相關教育訓練

資產管理作業能力相關程序中的零信任架構考量

A.5.10	資訊與其他資產可接受的使用方式	A.8.1.3資產之可被接受使用 A.8.2.3資產之處置
A.5.11	資產歸還	A.8.1.4 資產之歸還
A.5.14	資訊傳遞 資訊傳遞 資訊傳遞	A.13.2.1 資訊傳輸政策與程序 A.13.2.2 資訊傳輸協議 A.13.2.3 電子訊息
A.5.33	保護紀錄	A.18.1.3紀錄之保護
A.5.37	作業程序的文件化	A.12.1.1文件化的作業程序
A.5.9	資訊與其他資產的盤點	A.8.1.1資產清冊 A.8.1.2 識別所有權
A.6.5	聘僱終止與變更後的責任	A.7.3.1聘用責任之終止與變更
A.6.7	遠端工作	A.6.2.2遠端工作
A.7.3	保護辦公室與設施	A.11.1.3 辦公室、房間、設施之保全
A.7.8	設備選地與保護	A.11.2.1設備安置與保護
A.7.9	資產在邊界外的 安全	A.11.2.6場所外之設備與資產之安全
A.7.10	儲存媒介	A.11.2.5資產攜出 A.8.3.1可移動儲存媒體之管理 A.8.3.2儲存媒體之汰除 A.8.3.3實體媒體之傳送
A.7.13	設備維護	A.11.2.4設備維護
A.7.14	設備報廢與重用的安全	A.11.2.7設備報廢與重新使用之安全
A.8.1	使用者終端裝置	A11.2.8無人看管設備之保護 A6.2.1行動裝置安全
A.8.14	資訊處理設施的備援	A.17.2.1資訊處理設施之可用性

確認要盤點出所有重要的資訊資產並加以保護

遠端工作的安全

資產生命週期當中的安全考量

組織外資產的保護

BYOD 與可攜式裝置的管理

資訊保護作業能力相關程序中的零信任架構考量

A.5.10	資訊與其他資產可接受的使用方式	A.8.1.3資產之可被接受使用 A.8.2.3資產之處置
A.5.12	資訊分類	A.8.2.1 資訊分類
A.5.13	資訊標記	A.8.2.2 資訊標記
A.5.14	資訊傳遞	A.13.2.1 資訊傳輸政策與程序 A.13.2.2 資訊傳輸協議 A.13.2.3 電子訊息
A.5.33	保護紀錄	A.18.1.3紀錄之保護
A.5.34	個人可識別資訊的隱私與保護	A.18.1.4個人可識別資訊之隱私與保護
A.6.6	保密合約	A.13.2.4 保密或資訊不可揭露協議
A.6.7	遠端工作	A.6.2.2遠端工作
A.8.1	使用者終端裝置	A11.2.8無人看管設備之保護 A6.2.1行動裝置安全
A.8.7	惡意程式防護	A.12.2.1限制惡意軟體
A.8.10	資訊刪除	新增
A.8.11	資料遮罩	新增
A.8.12	資料外洩防護	新增
A.8.33	測試資訊	A.14.3.1保護測試資料
A.8.34	在稽核測試時保護資訊系統	A.12.7.1資訊系統稽核控制措施

資訊可視為特殊的資產

資訊可以做分類和標記

對於個人資料可以透過刪除或遮罩等方式保護

要考慮到稽核測試的存取控制

識別與存取管理作業能力相關程序中的零信任架構考量

A.5.3	分工	A.6.1.2 分工
A.5.15	存取控制	A.9.1.1 存取控制政策 A.9.1.2 對網路與網路服務之存取
A.5.16	身分管理	A.9.2.1使用者註冊與註銷
A.5.17	鑑別資訊	A.9.2.4使用者秘密鑑別資訊的管理 A.9.3.1秘密鑑別資訊之使用 A.9.4.3密碼管理系統
A.5.18	存取權限	A.9.2.2使用者存取權限配置 A.9.2.5使用者存取審查 A.9.2.6存取權限之移除或調整
A.5.37	作業程序的文件化	A.12.1.1文件化的作業程序
A.7.2	實體門禁	A.11.1.2實體進入控制 A.11.1.6交付與裝卸區
A.8.2	特權存取權限	A.9.2.3特權管理
A.8.3	資訊存取限制	A.9.4.1資訊存取限制
A.8.4	對於原始碼的存取	A.9.4.5對於程式原始碼的存取限制
A.8.5	安全鑑別	A.9.4.2 安全登入程序

零信任架構本身是存取控制模型，因此許多項目會反映在此

存取控制政策當中加入存取控制原則的考量

身分鑑別機制的要求

安全設定與威脅及弱點管理作業能力相關程序中的零信任架構考量

A.5.37	作業程序的文件化	A.12.1.1文件化的作業程序
A.8.18	特權工具程式的使用	A.9.4.4限制特權工具程式的使用
A.8.19	在作業系統安裝軟體	A.12.5.1安裝軟體之限制
		A.12.6.2限制軟體安裝
A.8.4	對於原始碼的存取	A.9.4.5對於程式原始碼的存取限制
A.8.9	設定管理	新增
A.8.24	加解密機制的使用	A.10.1.1加解密機制使用政策
		A.10.1.2金鑰管理

設定資訊的存取限制

安全傳輸時的加解密演算法要求

A.5.7	威脅情資	新增
A.5.37	作業程序的文件化	A.12.1.1文件化的作業程序
A.8.8	技術弱點管理	A.12.6.1管理技術弱點
		A.18.2.3技術符合性審查

要運用外部威脅情資以管控弱點並作為存取控制時的考量

掌握系統元件與弱點

實體安全作業能力相關程序中的零信任架構考量

A.5.37	作業程序的文件化	A.12.1.1文件化的作業程序
A.6.7	遠端工作	A.6.2.2遠端工作
A.7.1	實體安全邊界	A.11.1.1實體安全邊界
A.7.2	實體門禁	A.11.1.2實體進入控制 A.11.1.6交付與裝卸區
A.7.3	保護辦公室與設施	A.11.1.3 辦公室、房間、設施之保全
A.7.4	實體安全監控	新增
A.7.5	避免實體與環境安全威脅	A.11.1.4防範外部與環境威脅
A.7.6	在安全區域中的 工作	A.11.1.5在安全區域內工作之規定
A.7.7	桌面與螢幕淨空	A.11.2.9桌面及螢幕淨空
A.7.8	設備選地與保護	A.11.2.1設備安置與保護
A.7.9	資產在邊界外的安全	A.11.2.6場所外之設備與資產之安全
A.7.10	儲存媒介	A.11.2.5資產攜出 A.8.3.1可移動儲存媒體之管理 A.8.3.2儲存媒體之汰除 A.8.3.3實體媒體之傳送
A.7.11	支援設施	A.11.2.2支援設施與資源
A.7.12	纜線安全	A.11.2.3纜線安全
A.7.13	設備維護	A.11.2.4設備維護
A.7.14	設備報廢與重用的安全	A.11.2.7設備報廢與重新使用之安全

在外工作時的防護

實體存取也應該有零信任的考量

要考慮到對組織外資產的存取保護

應用系統安全作業能力相關程序中的零信任架構考量

A.5.37	作業程序的文件化	A.12.1.1文件化的作業程序
A.8.4	對於原始碼的存取	A.9.4.5對於程式原始碼的存取限制
A.8.18	特權工具程式的使用	A.9.4.4限制特權工具程式的使用
A.8.19	在作業系統安裝軟體	A.12.5.1安裝軟體之限制 A.12.6.2限制軟體安裝
A.8.25	安全的開發生命週期	A.14.2.1安全開發政策
A.8.26	應用程式安全需求	A.14.1.2公共網路上提供應用服務之安全 A.14.1.3作業平台變更後的應用程式技術審查
A.8.27	安全系統架構與工程原則	A.14.2.5遵守系統工程安全原則
A.8.28	程式開發時考量安全	新增
A.8.29	開發時的安全測試與驗收	A.14.2.8系統安全測試 A.14.2.9系統驗收測試
A.8.30	委外開發	A.14.2.7委外開發管理
A.8.31	區分開發、測試，與線上環境	A.12.1.4分隔開發、測試，與線上環境 A.14.2.6保護開發環境安全
A.8.32	變更管理	A.12.1.2變更管理 A.14.2.2系統變更控制程序 A.14.2.3作業平台變更後的應用程式技術審查 A.14.2.4限制對於套裝軟體的變更

應用程式開發相關重要元件的存取控制

對於身分鑑別與存取控制機制的要求

需要確保應用程式安全

系統和網路安全作業能力相關程序中的零信任架構考量

A.5.37	作業程序的文件化	A.12.1.1文件化的作業程序
A.6.7	遠端工作	A.6.2.2遠端工作
A.8.7	惡意程式防護	A.12.2.1限制惡意軟體
A.8.18	特權工具程式的使用	A.9.4.4限制特權工具程式的使用
A.8.20	網路安全	A.13.1.1網路控制
A.8.21	網路服務安全	A.13.1.2安全的網路服務
A.8.22	網路分隔	A.13.1.3網路分割
A.8.23	網頁過濾	新增
A.8.25	安全的開發生命週期	A.14.2.1安全開發政策
A.8.26	應用程式安全需求	A.14.1.2公共網路上提供應用服務之安全 A.14.1.3作業平台變更後的應用程式技術審查
A.8.27	安全系統架構與工程原則	A.14.2.5遵守系統工程安全原則
A.8.28	程式開發時考量安全	新增
A.8.29	開發時的安全測試與驗收	A.14.2.8系統安全測試 A.14.2.9系統驗收測試
A.8.30	委外開發	A.14.2.7委外開發管理
A.8.31	區分開發、測試，與線上環境	A.12.1.4分隔開發、測試，與線上環境 A.14.2.6保護開發環境安全
A.8.32	變更管理	A.12.1.2變更管理 A.14.2.2系統變更控制程序 A.14.2.3作業平台變更後的應用程式技術審查 A.14.2.4限制對於套裝軟體的變更
A.8.34	在稽核測試的稽核測試	A.12.7.1資訊系統稽核控制措施

有一部分和應用系統安全重複

網路分割與傳輸安全是零信任架構的重要手段

利用網頁過濾技術來做為補償技術

供應商關係安全與資訊安全保障作業能力相關程序中的零信任架構考量

A.5.19	供應關係中的資訊安全	A.15.1.1對供應商的資訊安全政策
A.5.20	在供應協定中考量資訊安全	A.15.1.2與供應商協定的安全要求
A.5.21	在ICT的供應中管理資訊安全	A.15.1.3供應鏈的資訊與溝通技術安全
A.5.22	供應商服務的監控、審查，與變更管理	A.15.2.1對供應商服務的監控與審查 A.15.2.2對供應商服務的變更 管理
A.5.23	使用雲端服務的資訊安全	新增
A.6.6	保密合約	A.13.2.4 保密或資訊不可揭露協議
A.8.30	委外開發	A.14.2.7委外開發管理

要求委外開發單位符合零信任原則

雲端與組織外資源的安全

A.5.35	資訊安全的獨立審查	A.18.2.1資訊安全的獨立性審查
A.5.36	資訊安全政策、規則、標準的符合	A.18.2.2符合資訊安全政策與標準 A.18.2.3技術符合性審查
A.8.29	開發時的安全測試與驗收	A.14.2.8系統安全測試 A.14.2.9系統驗收測試

如果有零信任相關產品規格的要求時，需要列入考量

持續性與資訊安全事件管理作業能力相關程序中的零信任架構考量

A.5.29	在中斷時的資訊安全	A.17.1.1規劃資訊安全持續
		A.17.1.2實作資訊安全持續
		A.17.1.3查證、審查，並評估資訊安全持續
A.5.30	ICT在業務永續中準備就緒	新增
A.5.37	作業程序的文件化	A.12.1.1文件化的作業程序
A.8.6	容量管理	A.12.1.3容量管理
A.8.13	資訊備份	A.12.3.1資訊備份
A.8.14	資訊處理設施的備援	A.17.2.1資訊處理設施之可用性

確保備援資料的存取控制安全

A.5.24	規劃與準備意外事件管理	A.16.1.1責任與程序
A.5.25	資訊安全事件的評估與決定	A.16.1.4對資訊安全事件之評估與決策
A.5.26	資訊安全意外事件的回應	A.16.1.5安全意外事件之回應
A.5.27	從資訊安全意外事件中學習	A.16.1.6從資訊安全意外事件中學習
A.5.28	證據收集	A.16.1.7證據收集
A.5.37	作業程序的文件化	A.12.1.1文件化的作業程序
A.6.8	資訊安全事件報告	A.16.1.2通報資訊安全事件
A.8.15	紀錄	A.12.4.1事件紀錄
		A.12.4.2保護紀錄資訊
		A.12.4.3管理者與操作者日誌
A.8.16	監控活動	新增
A.8.17	時鐘同步	A.12.4.4時鐘同步

相關安全機制的持續性

對紀錄方式的要求

零信任架構會有自動處理的考量

法律和遵循性作業能力相關程序中的零信任架構考量

A.5.31	法律、命令、規則，與合約要求	A.18.1.1 識別適用之法規與契約要求事項 A.18.1.5符合使用加解密控制之規定
A.5.32	智慧財產權	A.18.1.2智慧財產權
A.5.33	保護紀錄	A.18.1.3紀錄之保護
A.5.34	個人可識別資訊的隱私與保護	A.18.1.4個人可識別資訊之隱私與保護
A.5.36	資訊安全政策、規則、標準的符合	A.18.2.2符合資訊安全政策與標準 A.18.2.3技術符合性審查
A.8.10	資訊刪除	新增

依照法規與契約識別重要資產

依照法規與契約設定存取控制政策

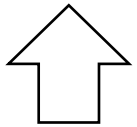
落實零信任架構的兩難 The Dilemmas in Implementing Zero Trust Architecture

再次檢查頻率設定的兩難
Dilemmas of Re-Inspections Frequency

強化對既有安控機制的信任
Strengthen trust in existing security safeguard

對既有存取控制信任假設的檢視
Reevaluating existing access control assumptions of trust

控制措施的韌性
Resilience of Security Controls



要多頻繁的檢查？ How often should security checks be conducted?

應該要基於連線，但最大連線時間是問題？By session? What should be the maximum allowable connection time?

預設信賴
Trust by Default

每次存取時
At every access attempt

效率
Performance

安全性
Security

落實零信任架構的兩難 The Dilemmas in Implementing Zero Trust Architecture

風險門檻設定的兩難
Dilemmas in Choosing Risk Threshold

強化對既有安控機制的信任
Strengthen trust in existing security safeguard

對既有存取控制信任假設的檢視
Reevaluating existing access control assumptions of trust

控制措施的韌性
Resilience of Security Controls

可以建立折衷的處理方法
A compromise approach would be to initially forbid access and then manually grant it later

要設定甚麼樣的可接受風險值？
What level of acceptable risk should be set?

至少要先禁止一定不允許的狀況
Situations that are definitely not allowed must be prohibited

高容忍度
High Tolerance

高敏感度
High Sensitive

高漏判率
High False Positive

高假警報率
High False Negative

落實零信任架構的兩難 The Dilemmas in Implementing Zero Trust Architecture

安全控制部署與效能的兩難
Dilemmas in Deploying Security Controls

強化對既有安控機制的信任
Strengthen trust in existing security safeguard

對既有存取控制信任假設的檢視
Reevaluating existing access control assumptions of trust

控制措施的韌性
Resilience of Security Controls

要疊加多少安全控制？ How many security controls should be used?

不應該有 SPOF，但是也不該影響到可用性。There should be no SPOF. Moreover, security controls should not seriously affect usability.

有資產未被保護
Unprotected Asset

層層防禦
Layered defense

效率
Performance

安全性
Security

落實零信任架構的兩難 The Dilemmas in Implementing Zero Trust Architecture

資訊收集完整度與資源使用的兩難
Dilemmas in Log Collection and Resource Usage

強化對既有安控機制的信任
Strengthen trust in existing security safeguard

對既有存取控制信任假設的檢視
Reevaluating existing access control assumptions of trust

控制措施的韌性
Resilience of Security Controls

依照當時的技術狀況，採用最佳實務方法 Adopt best practices according to the current technological conditions

要收集多少 Log 與情資？
How much log data and intelligence should be collected?

沒收集
Not Available

鉅細靡遺
In Meticulous Detail

束手無策
Unsure how to respond

尚未投入
Not yet implemented

有充分資訊進行回應
Respond with sufficient information

需要大量資源
Requires substantial resources

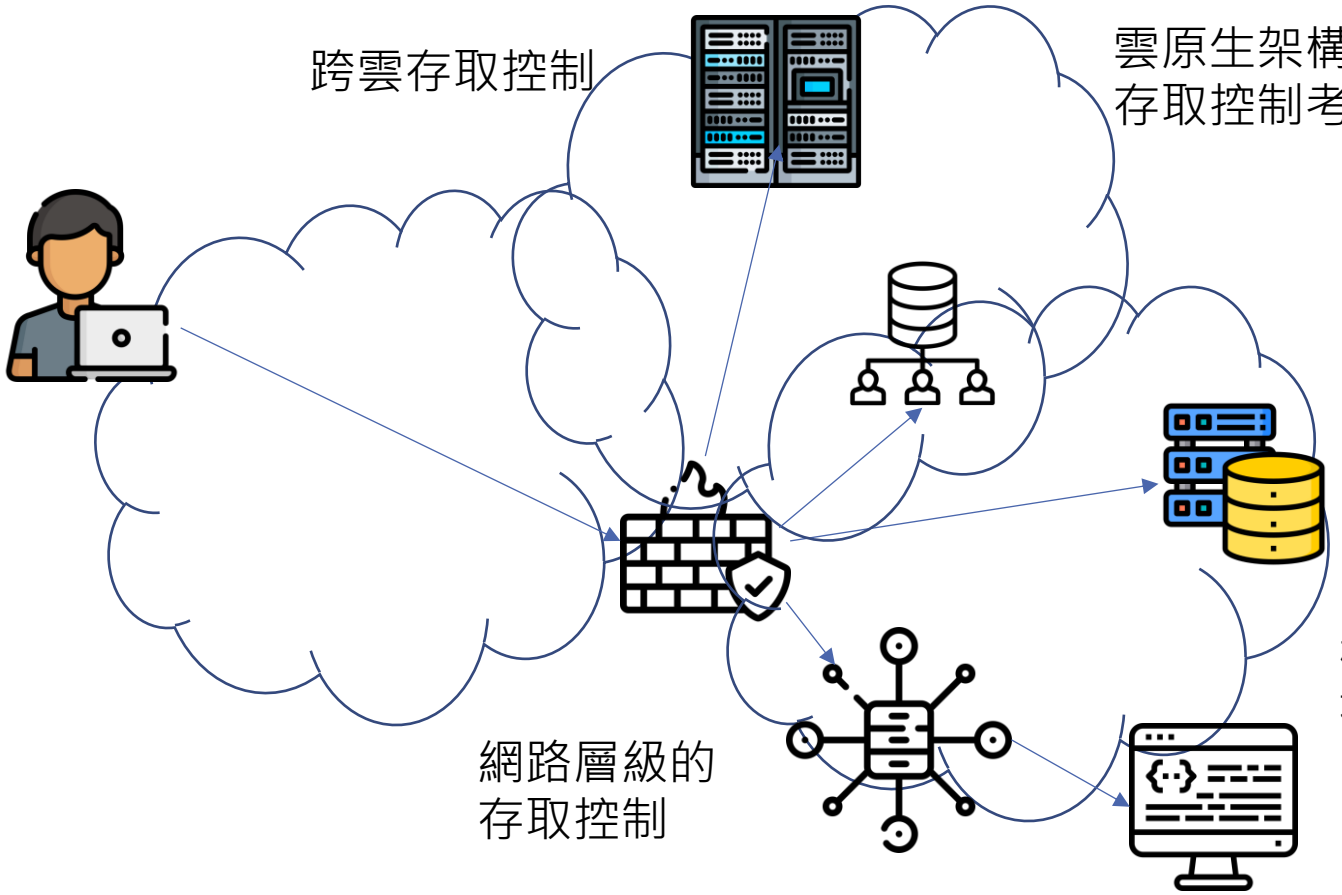
實作零信任架構的挑戰 Challenges of Implementing Zero Trust Architecture

存取控制的標的種類眾多
Different types of assets to be protected

欠缺驗證信任推斷效果的資料
Lack of data to verify the effectiveness of trust inference

老舊系統的整合問題
Integration issues with legacy systems.

存取控制的標的種類眾多 Different Types of Assets to be Protected



識別點對點的存取路徑

辨識存取政策落實點 (PEP)

建立跨情境的身分鑑別與存取控制整合標準

透過 API 等方式進行整合

欠缺驗證信任推斷效果的資料 Lack of data to verify the effectiveness of trust inference

至少要能發現異常與因應

先分開評估，處理有把握的結果

信賴評估之結果

輸出

考量

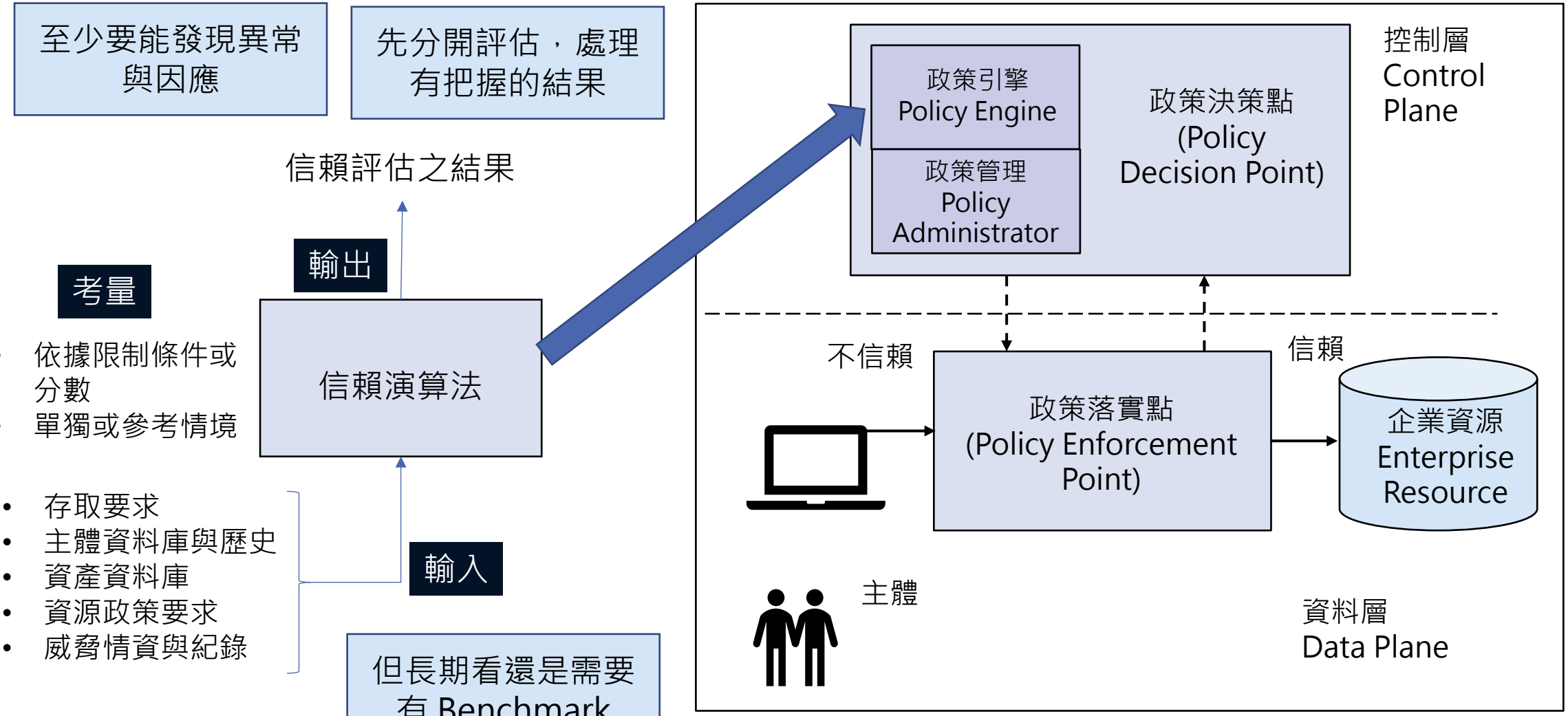
- 依據限制條件或分數
- 單獨或參考情境

信賴演算法

- 存取要求
- 主體資料庫與歷史
- 資產資料庫
- 資源政策要求
- 威脅情資與紀錄

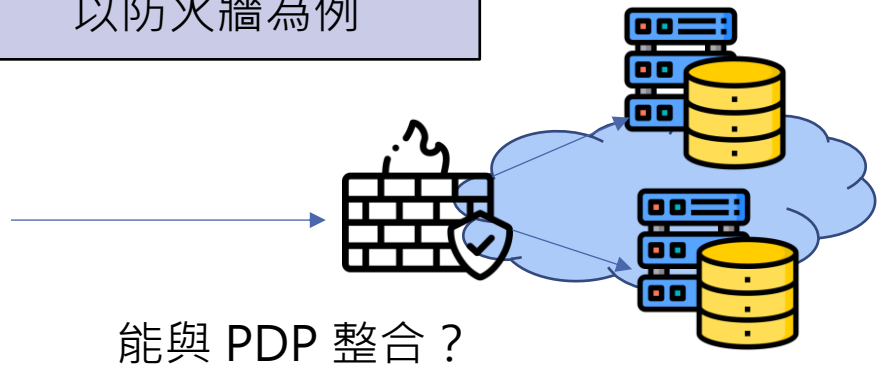
輸入

但長期看還是需要有 Benchmark



老舊系統的整合問題 Integration issues with legacy systems

以防火牆為例

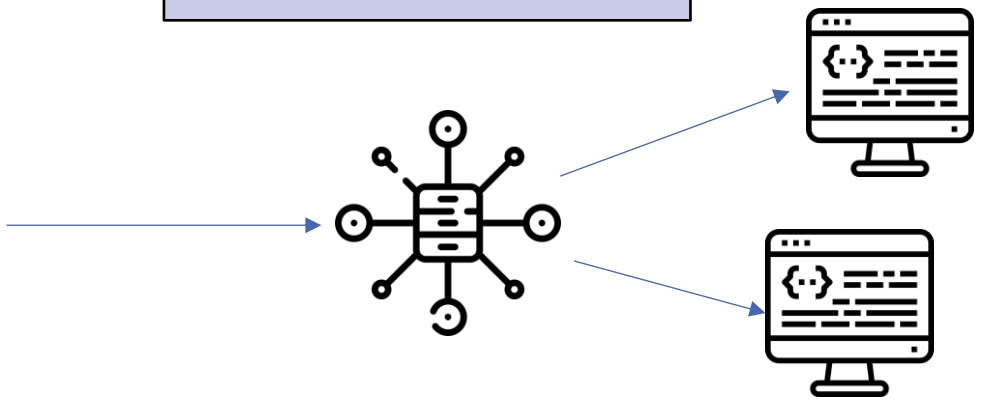


能與 PDP 整合？

能否收集需要的情境資訊？

能否動態調整政策？

以代理伺服器為例



能否支援既有的應用程式身分鑑別機制？

情境

- 要讓既有的安全控制機制支援零信任架構
- 要讓機制能夠與既有系統整合

對策

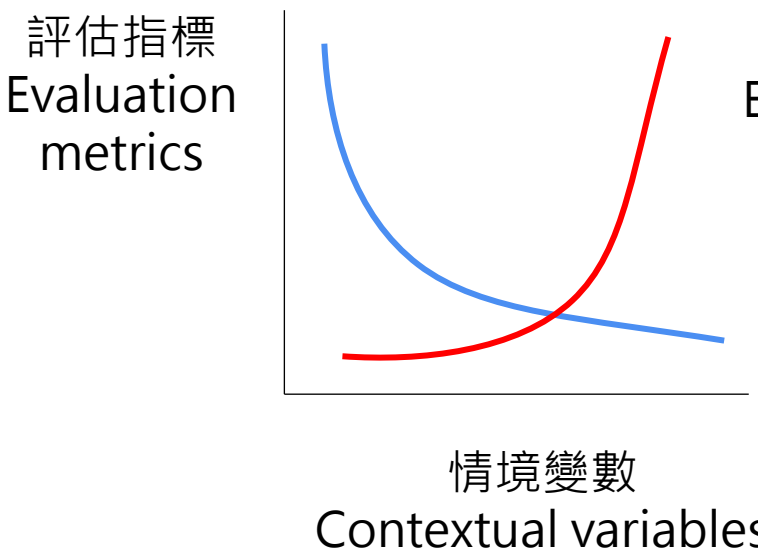
- 全部更新/改寫
- 想辦法補強/整合

原則

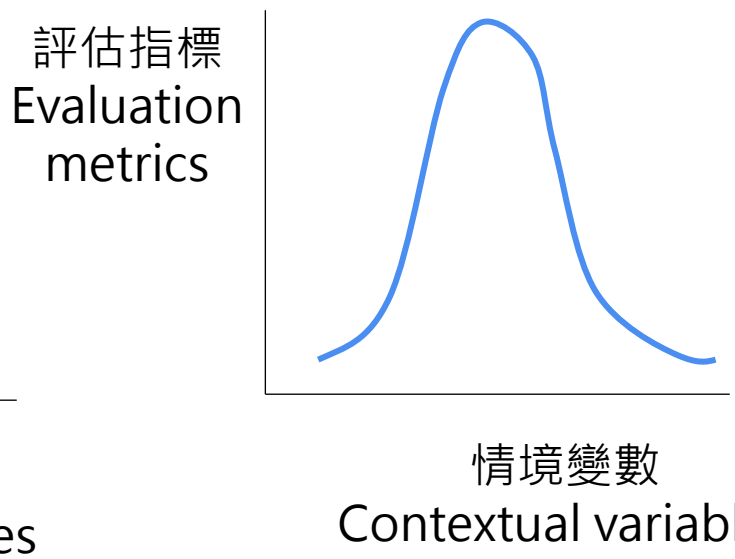
不要為了要整合某機制，而造成本身機制的漏洞

面對兩難的情況，會需要有決策的依據 In the face of dilemmas, it is necessary to have evaluation criteria to make decisions

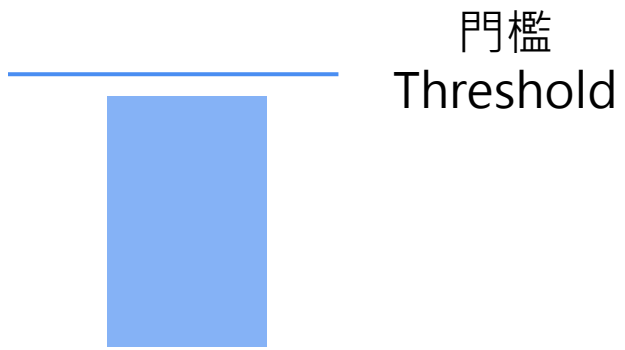
從不同的角度綜合考量
Consider from different perspectives



尋找最佳表現
Optimization



達到門檻的最低投入
Finding the minimum investment to achieve the threshold

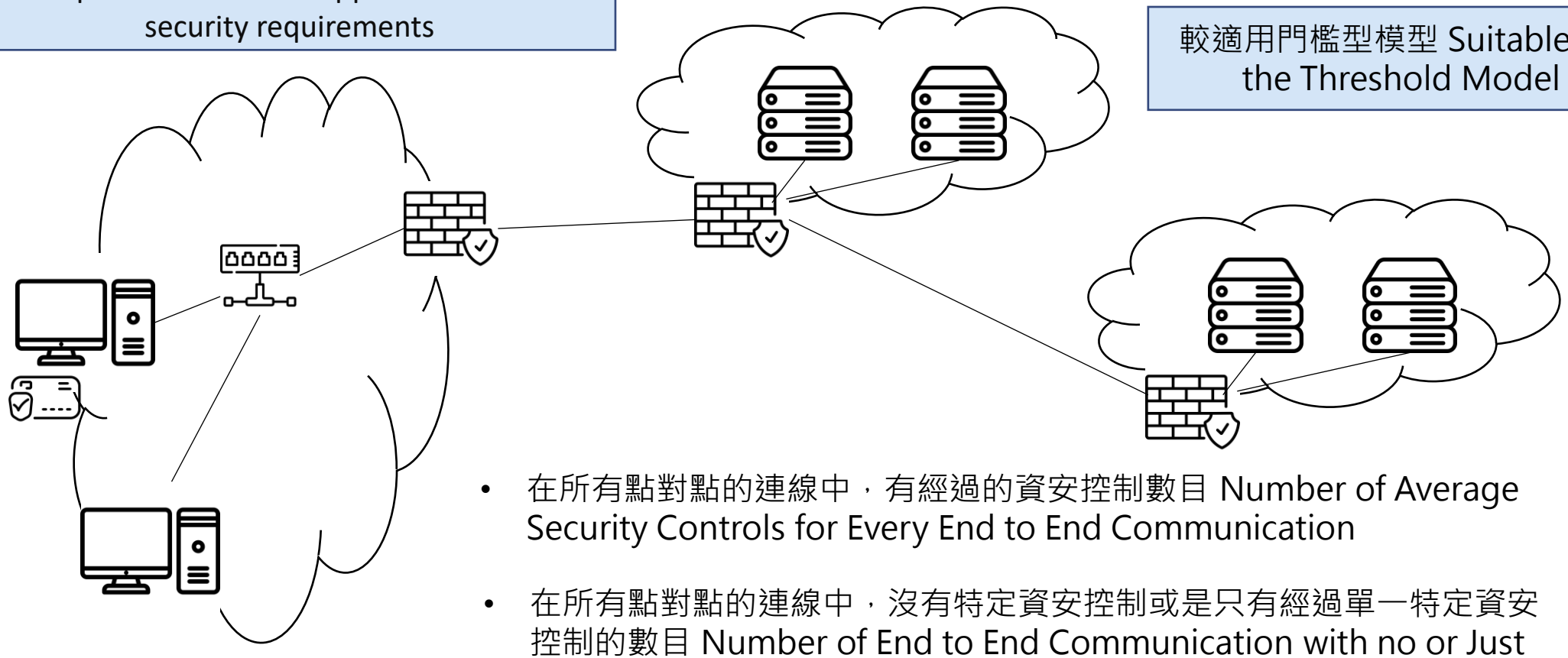


可能的評估指標 Potential Evaluation Metrics

採用最低的成本來符合安全要求
Adopt the lowest cost approach to meet security requirements

- 安全控制的成本 Overhead or cost of security control

較適用門檻型模型 Suitable for the Threshold Model



- 在所有點對點的連線中，有經過的資安控制數目 Number of Average Security Controls for Every End to End Communication
- 在所有點對點的連線中，沒有特定資安控制或是只有經過單一特定資安控制的數目 Number of End to End Communication with no or Just One Security Control for Specific Type of Security Control

可能的評估指標 Potential Evaluation Metrics

- SIEM 與 SOAR 的成本 Cost of SIEM, SOAR, and other Similar Controls

採用最低的成本來符合安全要求
Adopt the lowest cost approach to meet security requirements

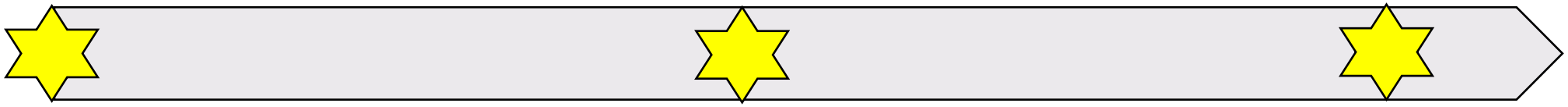
尋找最具 C/P 值的方案
Seek the solution with the best cost-performance ratio

較適用門檻型模型 Suitable for the Threshold Model

- 意外事件被發現的時間 Average Time for Incident to be Discovered
- 意外事件被控制的時間 Average Time for Incident to be Controlled

較適用最佳表現型模型 Suitable for the Optimization Model

- 意外事件被發現的比率 Percentage for Incident to be Discovered
- 意外事件被控制的比率 Percentage for Incident to be Controlled



資安事件發生
Incident Happen

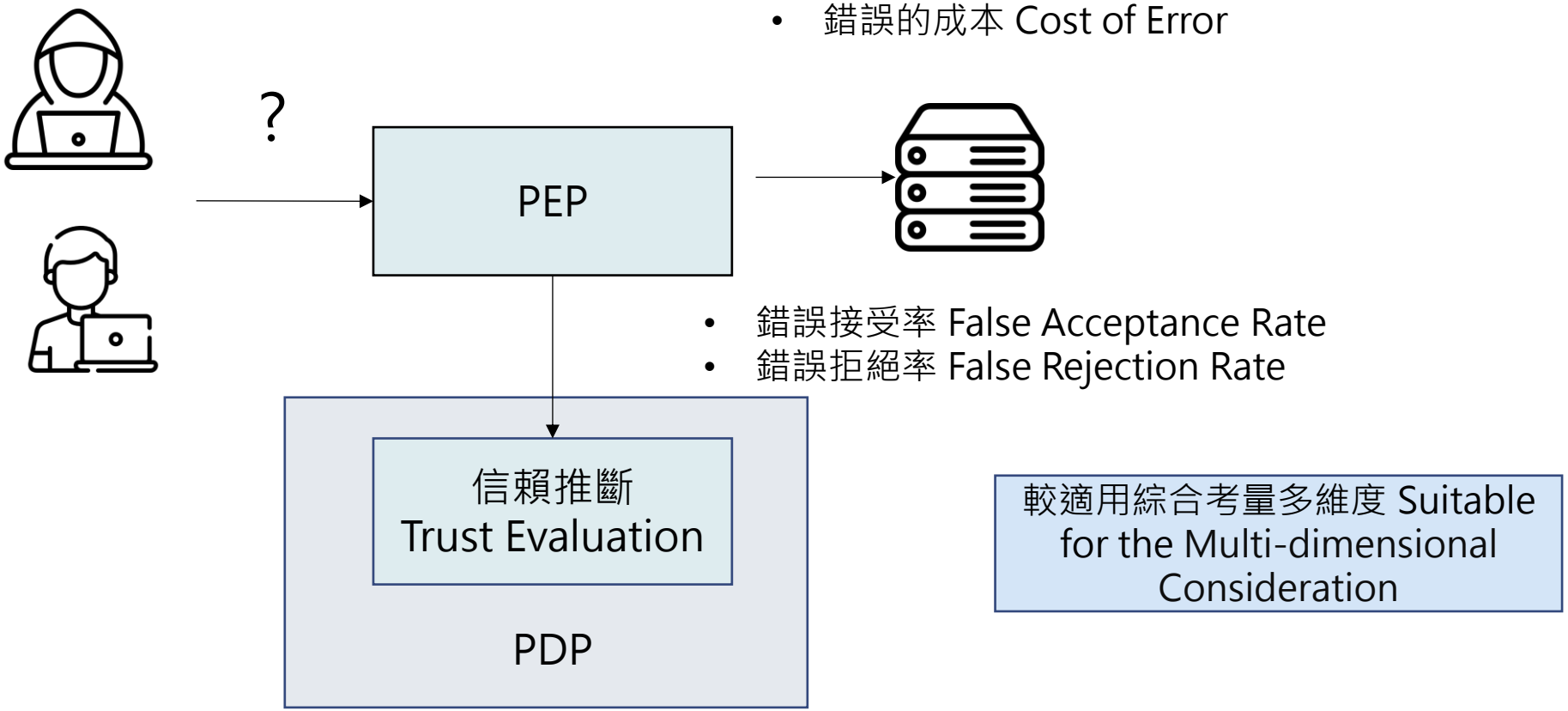
資安事件被發現
Incident is Discovered

資安事件被控制
Incident is Controlled

SIEM 與 IDS 的效率與效果
Effectiveness and Efficiency of SIEM and IDS

SOAR 的效率與效果
Effectiveness and Efficiency of SOAR

可能的評估指標 Potential Evaluation Metrics



- 錯誤的成本 Cost of Error
- 錯誤接受率 False Acceptance Rate
- 錯誤拒絕率 False Rejection Rate

較適用綜合考量多維度 Suitable for the Multi-dimensional Consideration

零信任架構的本質與核心概念

從美國的要求來看各項資安控制的意義

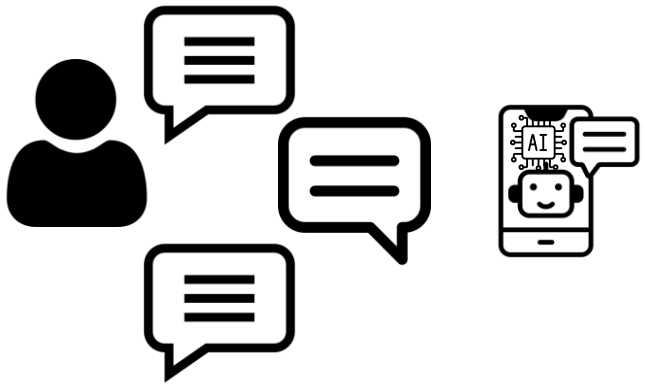
零信任架構的實作架構

AI 代理人與零信任架構

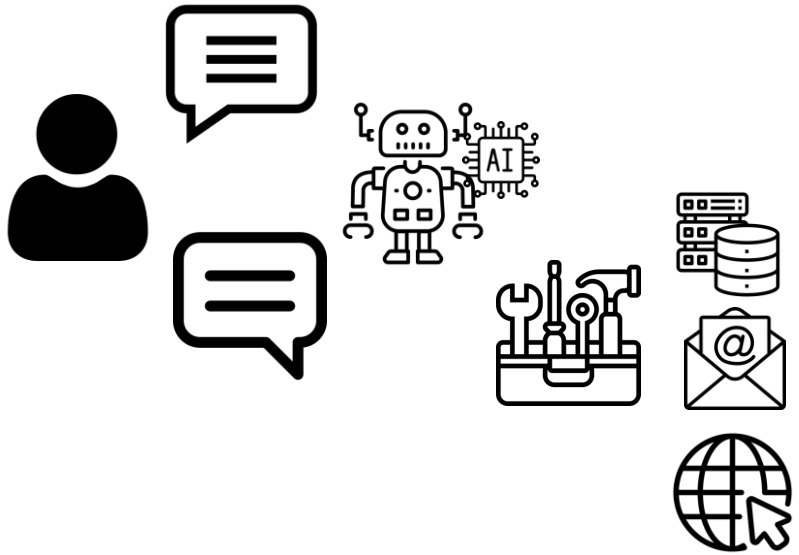
結論

從聊天機器人 (Chatbot) 到 AI 代理人 (AI Agent)

聊天機器人

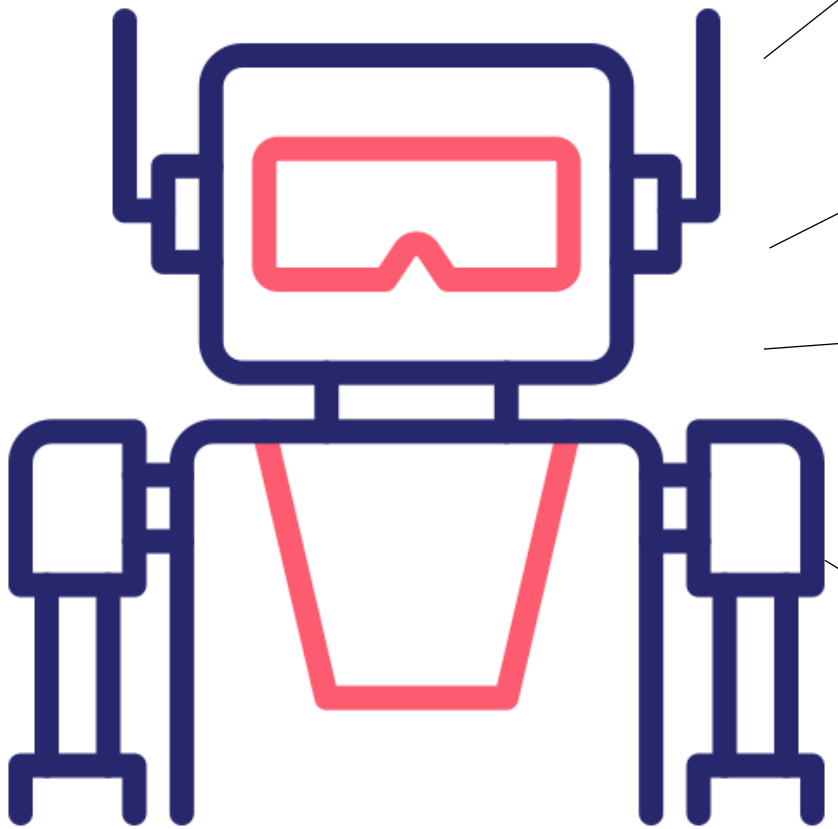


AI 代理人



聊天機器人是回應介面； AI 代理人是行動介面。

AI 代理人的元件



LLM 核心：處理提示，並作為推理引擎

系統提示

記憶：跨連線的上下文關係

流程管理：確保工作流程的執行

工具：可與外界溝通、取得資料，與進行操作

護欄：如輸入過濾與輸出掃描

Join us on October 20 for a 30-minute webinar exploring how AI-driven automation transforms security operations →

The Agentic Trust Framework: Zero Trust Governance for AI Agents

Published 02/02/2026

Written by Josh Woodruff, Founder and CEO, MassiveScale.AI.

This blog post presents the Agentic Trust Framework (ATF), an open governance specification designed specifically for the unique challenges of autonomous AI agents. For security engineers, enterprise architects, and business leaders working with agentic AI systems, ATF provides a structured approach to deploy AI agents that can take meaningful autonomous action while maintaining the governance and controls that enterprises require.

The framework applies established Zero Trust principles to the new domain of AI agents, offering a practical, implementable approach that security teams can adopt using existing tools and infrastructure. By following ATF, organizations can progress agents from initial deployment through increasing levels of autonomy, with clear criteria and controls at each stage.

ATF is published as an open specification under Creative Commons licensing, encouraging adoption and implementation across the industry. The canonical specification and implementation guidance are maintained at the ATF GitHub repository.

Zero Trust

Related Resources

Certificate of Competence in Zero Trust
Zero Trust training and certificate program.

Zero Trust Program Management Guidance
Planning, Implementing, and Sustaining Zero Trust in the Enterprise

Integrating DNS and

https://cloudsecurityalliance.org/blog/2026/02/02/the-agentic-trust-framework-zero-trust-governance-for-ai-agents

代理式 AI 對於傳統假統資安框架假設的衝擊

傳統假設 (Traditional Assumption)	AI 代理人的實際特性 (AI Agent Reality)
人類使用者的行為具有可預測性	具備自主決策能力，並能根據情境與工具回饋調整行為 (通常具有非決定性)
系統規則具有決定性	回應具有機率性，且會隨情境而改變
採用二元存取控制決策(允許 / 拒絕)	存取需求會隨任務動態變化
信任關係建立後即可持續使用	信任關係需要持續驗證

從傳統零信任架構到代理人信任框架 (Agentic Trust Framework)

- 傳統零信任 (Traditional Zero Trust)：無論使用者或系統位於何處、使用何種網路，均不應預設信任任何使用者或系統。
- 代理人零信任 (Agentic Zero Trust)：無論 AI 代理人的目的或其宣稱具備的能力為何，均不應預設信任任何 AI 代理人。信任必須透過實際行為表現來建立，並透過持續監控與驗證來維持。

核心要素(Core Element)	ATF 核心問題	安全功能(Security Function)
身分(Identity)	「你是誰？」	身分驗證、授權、工作階段管理
行為(Behavior)	「你正在做什麼？」	可觀測性、異常偵測、意圖分析
資料治理(Data Governance)	「你接收了什麼資料？你輸出了什麼內容？」	輸入驗證、個人識別資訊(PII)保護、輸出治理
區隔(Segmentation)	「你可以存取哪些地方？」	存取控制、資源邊界、政策強制執行
事件應變(Incident Response)	「如果你發生失控或惡意行為，該怎麼辦？」	斷路器(Circuit Breakers)、緊急停止機制(Kill Switches)、隔離與圍堵

ATF 的核心概念

企業領導者的關鍵問題	ATF 的因應方式
何時可以允許 AI 代理人執行操作？	透過身分、行為、資料治理、區隔及事件應變五項核心要素建立基本安全條件
如何安全地提高 AI 代理人的自主權？	建立自主權等級與晉升門檻，依代理人的實際表現逐步授權
如何證明 AI 代理人受到有效治理？	整合既有零信任與治理機制，建立可監控、可衡量、可稽核的控制措施

要素一：身分 (Identity) —「你是誰？」

- 每個 AI 代理人在存取任何資源之前，都必須具備經過驗證且可稽核的身分。

要求(Requirement)	說明(Description)
唯一識別碼(Unique Identifier)	為每個代理人執行個體配置全域唯一且不可變更的識別碼
憑證綁定(Credential Binding)	將代理人身分與密碼學憑證綁定
所有權關聯鏈(Ownership Chain)	明確記錄代理人的所有權歸屬及營運管理責任
用途聲明(Purpose Declaration)	文件化記錄代理人的預期用途及運作範圍
能力清單(Capability Manifest)	以機器可讀格式列出代理人宣稱具備的能力

要素二：行為(Behavior)—「你正在做什麼？」

- 必須持續監控 AI 代理人的行為，偵測異常情況並標記供後續審查。

要求(Requirement)	說明(Description)
結構化日誌(Structured Logging)	以機器可解析的格式記錄代理人的所有操作行為
行為歸屬(Action Attribution)	將每項操作關聯至代理人身分及工作階段情境
行為基準(Behavioral Baseline)	建立正常運作行為模式，作為異常偵測的比較基準
異常偵測(Anomaly Detection)	識別偏離預期行為模式的異常活動
可解釋性(Explainability)	能夠取得代理人決策的依據與理由

要素三：資料治理(Data Governance)—「你接收什麼資料？你輸出什麼內容？」

- 所有進入 AI 代理人的資料都必須經過驗證，而所有輸出內容也必須受到適當治理。

要求(Requirement)	說明(Description)
結構綱要驗證(Schema Validation)	確保輸入資料符合預期的結構與資料型別
注入攻擊防護(Injection Prevention)	偵測提示詞注入(Prompt Injection)及對抗性輸入
個資 / 醫療資訊保護(PII/PHI Protection)	自動偵測並遮蔽個人識別資訊及受保護的健康資訊
輸出驗證(Output Validation)	確保輸出內容符合預期結構及內容政策
資料沿革追蹤(Data Lineage)	追蹤資料在代理人處理流程中的來源及流向

要素四：區隔(Segmentation)—「你可以存取哪些資源？」

- AI 代理人的存取權限必須嚴格限制在執行當前任務所需的最小範圍內。

要求(Requirement)	說明(Description)
資源允許清單(Resource Allowlist)	明確列舉代理人被允許存取的資源
操作邊界(Action Boundaries)	明確列舉代理人被允許執行的操作
速率限制(Rate Limiting)	限制單位時間內允許執行的最大操作次數
交易限制(Transaction Limits)	限制單次操作可能造成的最大影響
影響範圍控制(Blast Radius Containment)	限制代理人行為的累積影響及連鎖效應

要素五：事件應變(Incident Response)—「如果你失控了，該怎麼辦？」

- 系統必須具備快速限制 AI 代理人活動及恢復正常運作的能力。

要求(Requirement)	說明(Description)
斷路器(Circuit Breaker)	當代理人連續發生錯誤或失敗時，自動停止相關操作
緊急停止開關(Kill Switch)	提供立即手動終止代理人執行的能力(目標小於 1 秒)
工作階段撤銷(Session Revocation)	能夠使代理人的所有工作階段立即失效
狀態回復(State Rollback)	在可行的情況下，撤銷代理人已執行的操作並回復先前狀態
優雅降級(Graceful Degradation)	發生問題時，自動降低代理人的自主程度，以較受限的模式持續運作

四個自治等級 (The Four Levels)

等級 (Level)	名稱 (Name)	自主程度 (Autonomy)	人員參與程度(Human Involvement)	AWS 自主代理範圍對應
1	實習生(Intern)— 僅能觀察	觀察與回報(Observe + Report)	持續監督	Scope 1：無代理自主性(No Agency)
2	初階人員(Junior)— 建議須經核准	提出建議並等待核准(Recommend + Approve)	所有操作均須經人工核准	Scope 2：預先規範的代理自主性(Prescribed Agency)
3	資深人員(Senior)— 執行後通知	自主執行並通知(Act + Notify)	執行操作後通知人員	Scope 3：受監督的代理自主性(Supervised Agency)
4	專家(Principal)— 領域內自主運作	自主執行(Autonomous)	僅需策略性監督	Scope 4：完全代理自主性(Full Agency)

Level 1 — 觀察型： 代理人只能觀察環境、分析資訊並產生報告，不具備執行實際操作的權限。
Level 2 — 核准型： 代理人可以分析情況、規劃操作及提出建議，但所有實際操作均須經人工核准。
Level 3 — 通知型： 代理人可在授權範圍內自行執行操作，但必須在操作完成後通知相關人員。
Level 4 — 自主型： 代理人可在特定業務領域與授權邊界內自主決策及執行任務，人員主要負責策略性監督。

AI 代理人自主權晉升的五項門檻(Five Promotion Gates)

- Gate 1：效能表現(Performance)：評估代理人在指定期間內是否展現足夠的準確性與可靠性。

評估指標	Junior(L2)	Senior(L3)	Principal(L4)
前一等級最低運作期間	2 週	4 週	8 週
建議 / 操作準確率	不適用	>95%	>99%
可用性	>99%	>99.5%	>99.9%

- Gate 2：安全驗證(Security Validation)：必須通過符合目標自主權等級要求的安全稽核與測試。

安全要求	Junior(L2)	Senior(L3)	Principal(L4)
弱點評估(Vulnerability Assessment)	✓	✓	✓
滲透測試(Penetration Testing)	—	✓	✓
對抗性測試(Adversarial Testing)	—	—	✓
組態稽核(Configuration Audit)	✓	✓	✓

- Gate 3：業務價值(Business Value)：代理人必須證明能夠對業務產生可衡量的正面效益。

評估要求	Junior(L2)	Senior(L3)	Principal(L4)
定義成功衡量指標(Defined Success Metrics)	✓	✓	✓
建立基準值(Baseline Established)	✓	✓	✓
投資報酬率計算(ROI Calculation)	—	✓	✓
利害關係人核可(Stakeholder Sign-off)	✓	✓	✓

- Gate 4：事件紀錄(Incident Record)：代理人在目前自主權等級下，必須具備良好的營運紀錄，並妥善處理已發生的事件。

評估要求	Junior(L2)	Senior(L3)	Principal(L4)
無重大資安事件(Zero Critical Incidents)	✓	✓	✓
完成根本原因分析(Root Cause Analysis Complete)	不適用	✓	✓
完成改善措施驗證(Remediation Verified)	不適用	✓	✓

- Gate 5：治理核准(Governance Sign-off)：自主權等級提升必須取得具備授權權限之相關利害關係人的明確核准。

核准要求	Junior(L2)	Senior(L3)	Principal(L4)
技術負責人核准(Technical Owner Approval)	✓	✓	✓
資安團隊核准(Security Team Approval)	—	✓	✓
業務負責人核准(Business Owner Approval)	✓	✓	✓
風險管理委員會核准(Risk Committee Approval)	—	—	✓

第一階段：最小可行產品技術架構(MVP Stack)

- 目標：2–3 週內部署至正式營運環境
- 適用於初階 AI 代理人，以建立基本安全控制能力為目標。

核心要素	建議實作方式
身分(Identity)	基於 JWT 的身分驗證
行為(Behavior)	結構化日誌(Structured Logging) + LLM 可觀測性(Observability)
資料治理(Data Governance)	結構綱要驗證(Schema Validation) + 使用正規表示式(Regex)偵測明顯的個人識別資訊(PII)
區隔(Segmentation)	透過組態設定簡單的資源與操作允許清單(Allowlists)
事件應變(Incident)	退避式重試(Retry with Backoff) + 斷路器(Circuit Breaker) + 日誌記錄

第二階段：正式營運技術架構(Production Stack)

- 目標：4–6 週內達到企業正式營運要求
- 此階段強化存取控制、行為偵測及資料保護，使 AI 代理人能夠在適當的治理機制下自主執行操作。

核心要素	建議實作方式
身分(Identity)	JWT + OAuth 2.0 / OIDC + 角色式 / 屬性式存取控制(RBAC / ABAC)
行為(Behavior)	LLM 可觀測性 + 異常偵測(Anomaly Detection) + 結構化日誌
資料治理(Data Governance)	PII / PHI 偵測 + 結構綱要驗證 + 輸出過濾(Output Filtering)
區隔(Segmentation)	角色式存取政策(Role-based Policies) + 速率限制(Rate Limiting)
事件應變(Incident)	斷路器 + 錯誤追蹤(Error Tracking) + 告警(Alerting)

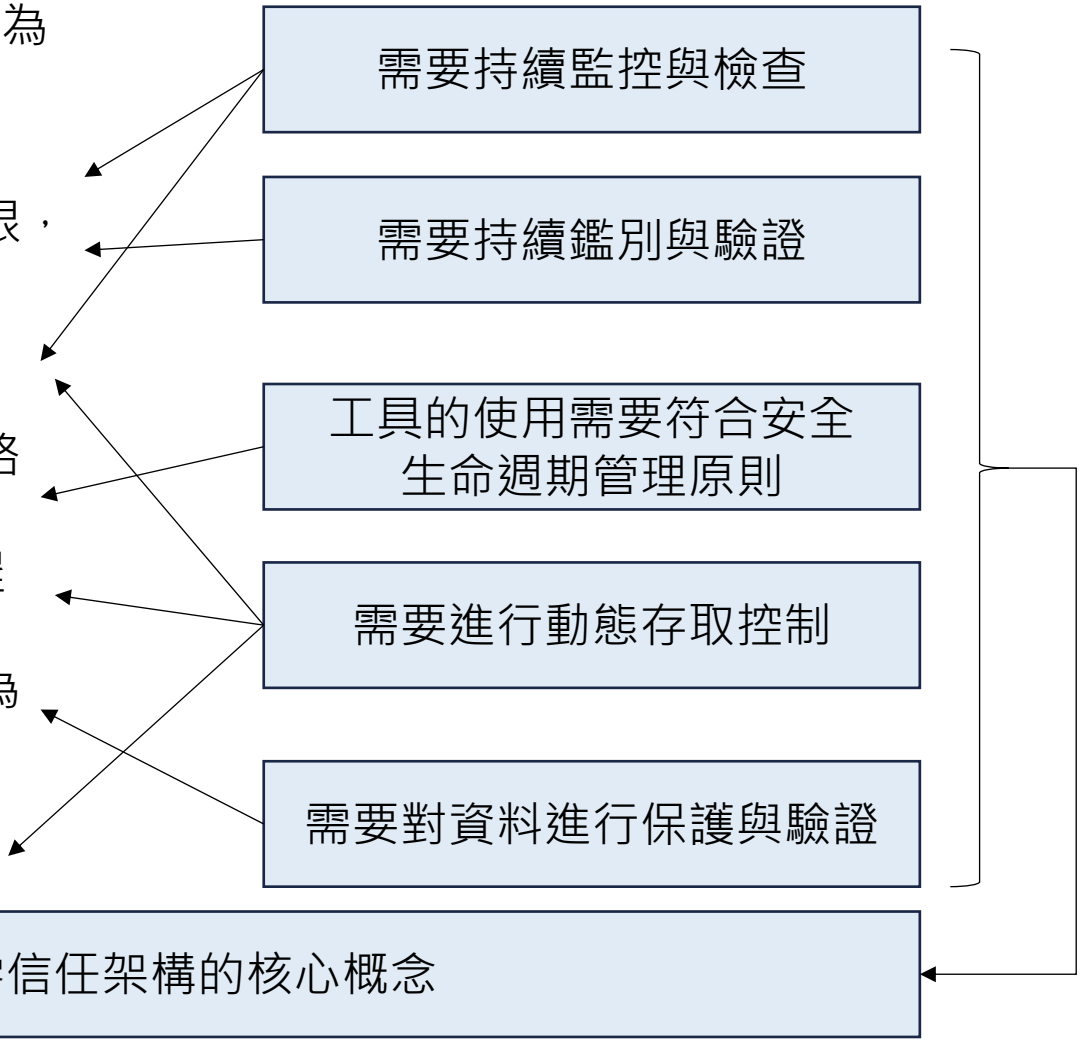
第三階段：企業級技術架構(Enterprise Stack)

- 目標：8–12 週內建立完整治理能力
- 此階段著重於高度自主代理人的安全管理，整合進階存取控制、即時監控及企業資安營運機制。

核心要素	建議實作方式
身分(Identity)	OAuth 2.0 / OIDC + 多因素驗證(MFA) + 屬性式存取控制(ABAC)
行為(Behavior)	LLM 可觀測性 + 串流式異常偵測(Streaming Anomaly Detection) + 自然語言處理分析(NLP Analysis)
資料治理(Data Governance)	PII / PHI 偵測 + 資料品質驗證 + 自訂資料分類(Custom Classification) + 輸出過濾
區隔(Segmentation)	政策即程式碼(Policy-as-Code) + API Gateway 整合
事件應變(Incident)	斷路器 + 錯誤追蹤 + 資安事件應變平台整合 + 監控指標與告警

代理式 AI 非常適合使用零信任架構進行防護

- 首先大語言模型本身可能要變成新的支柱 (因為 AI 生成結果的不確定性)
- 其他包括：
  - 代理人身分混淆：代理人會繼承他人權限，一次性授權易被借權濫用
  - 情境每輪都在變：輸入可能中途被注入，第 1 輪乾淨不代表第 5 輪仍可信
  - 工具可能來自不信任的來源：可能從網路取得開源機制等
  - 工具本身應有不同權限：讀檔 vs. 執行程式碼風險天差地遠，需依情境動態授權
  - 記憶可被持久污染：需視「讀取記憶」為一次應檢查的存取行為
  - 代理人行為難預期：自主決策路徑多變，需即時風險訊號驅動存取控制



那代理人架構要如何套用零信任的概念

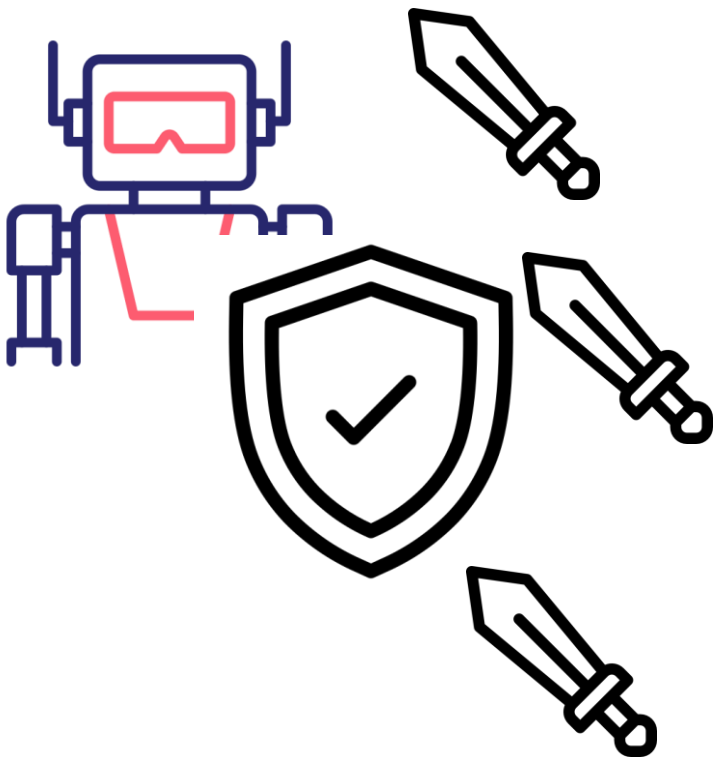
- 首先要思考的是代理人在中間的角色
  - 是被保護的資源？
  - 是扮演保護其他資源的 PDP 或 PEP？
  - 會被視為對於資源的威脅？

- 識別存取者身分、持續身分鑑別
- 驗證存取者狀況
- 動態存取控制
- 監控輸入與輸出，以及異常存取的情況

- 代理人提供存取控制決策
- 挑戰在效率、正確性、可預測性

- 能夠透過護欄限制輸出
- 驗證 Agent 的安全狀態與可信度
- 能夠對其存取進行限制
- 能夠驗證其身份

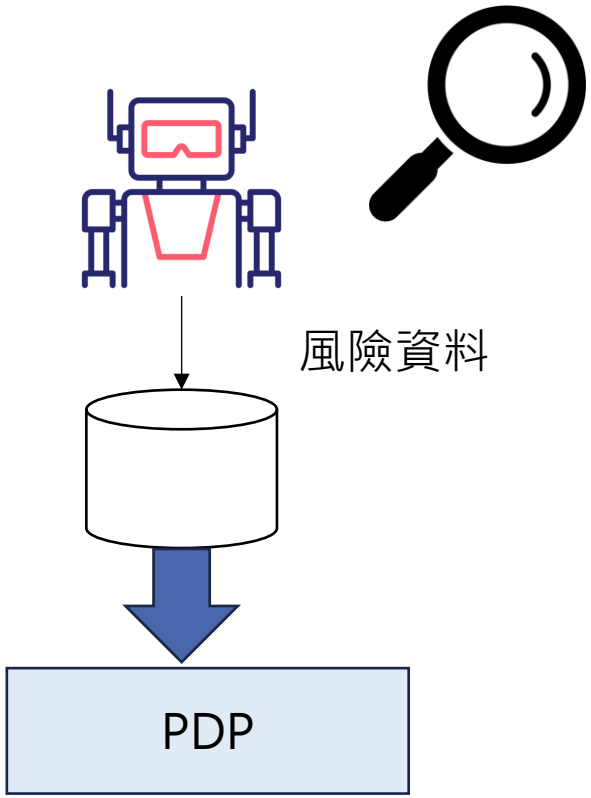
代理人是被保護的資源



身分	除一般身分鑑別機制外，特別需要考慮到其他代理人的驅動存取
裝置	驗證呼叫代理人的其他代理人所在之裝置或平台的安全性
網路	代理人提供 API 與代理人間相互呼叫的安全性
應用程式	代理人程式弱點管理、代理人能力的授權、代理人的監控，以及代理人的測試等
資料	記憶體與Context 資料等代理人特有資料的防護
可視性	監控輸入/輸出外，也會監控代理人的行為
自動化與協作	發現異常時對其他代理人權限的調整

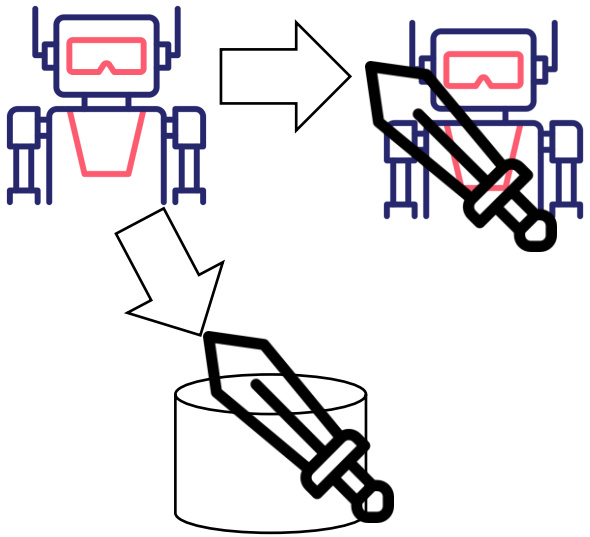
代理人參與存取控制程序

「代理人直接進行存取控制」與「代理人協助進行存取控制」？



身分	主動調查異常身分行為，必要時自行查詢 IAM、歷史紀錄等
裝置	主動取得缺少的安全狀態資訊，而非只接收固定欄位
網路	跨來源調查可疑連線，將關聯身分、裝置，與網路綜合考量
應用程式	理解操作語意與行為目的，協助判斷存取是否異常
資料	理解資料與任務上下文，發現組合後異常的資料使用
可視性	自主檢視與跨支柱推論
自動化與協作	自主規劃回應計畫

代理人是存取者或可能的威脅來源



身分	代理人代表誰？權限從哪裡來？
裝置	代理人即使身分合法，若執行不受信任或有風險之裝置，不應取得相同資源權限
網路	限制代理人自主存取外部服務的範圍
應用程式	能夠限制代理人對工具的使用授權，驗證代理人的信任狀態
資料	對代理人進行存取控制，防止代理人自主蒐集、聚合、轉移敏感資料
可視性	看整體而非只看單一存取
自動化與協作	按代理人風險狀況調整其自治與存取能力

AI 代理人與零信任架構

- AI 技術進步迅速，代理式 AI 是近來的主流，但也有許多新的風險
- 代理式 AI 將資安風險從「內容安全」進一步擴展至「自主行動、權限委派與信任傳遞」
  - 從提示到行動 → 風險從錯誤輸出擴大為目標與行動劫持
  - 從權限到委派 → 產生身分、權限與委派鏈濫用
  - 從 API 到工具鏈 → 產生跨工具組合與過度自主權限風險
  - 從工作階段到長期記憶 → 攻擊可能形成持續性的記憶與脈絡污染
  - 從單一系統到代理生態系 → 單點失陷可能形成跨代理的連鎖式信任失效
- 代理式 AI 的自主性、權限委派與動態互動，不該再有預設的信任，因此需要以零信任持續驗證每一次存取與行動。而可以從以下三個角度來看：
  - 保護代理人 (Protecting Agents with Zero Trust Architecture)
  - 代理人支援零信任架構 (Agents Supporting Zero Trust Architecture)
  - 使用零信任架構控管代理人 (Controlling Agents with ZTA)
- 代理式 AI 讓信任變得動態，更需要情境導向與持續監控，零信任則讓驗證成為持續。

零信任架構的本質與核心概念

從美國的要求來看各項資安控制的意義

零信任架構的實作架構

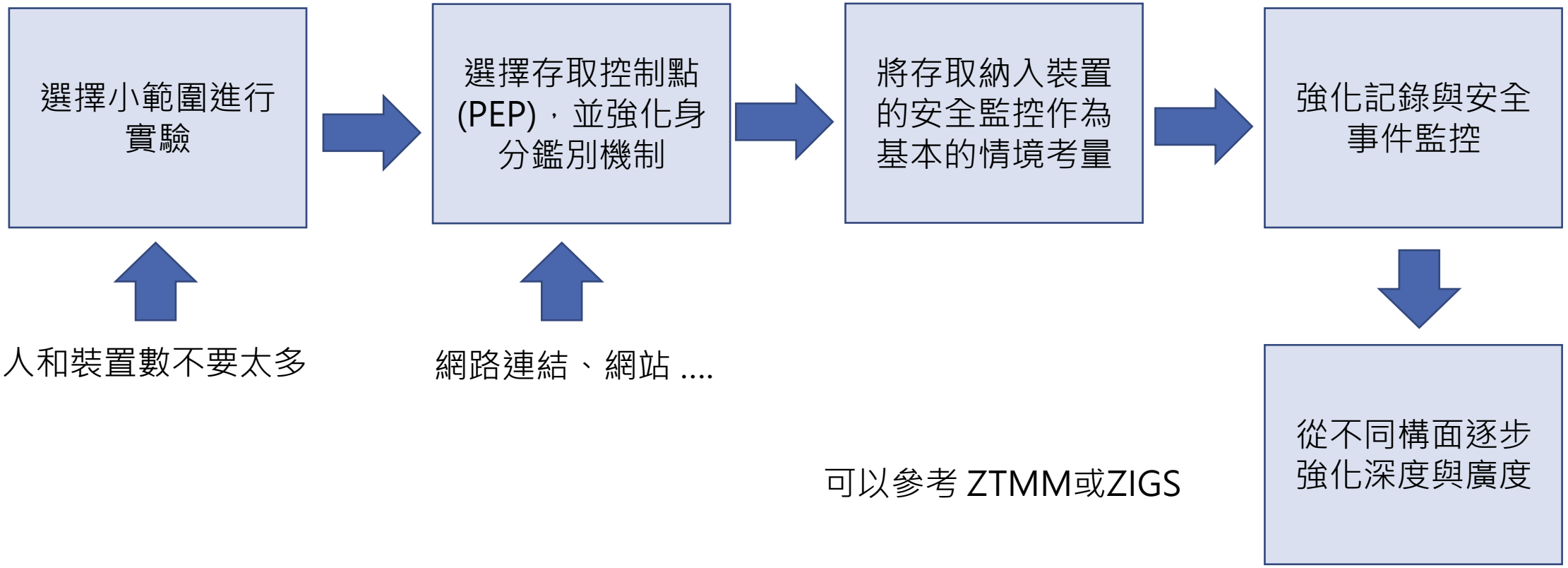
AI 代理人與零信任架構

結論

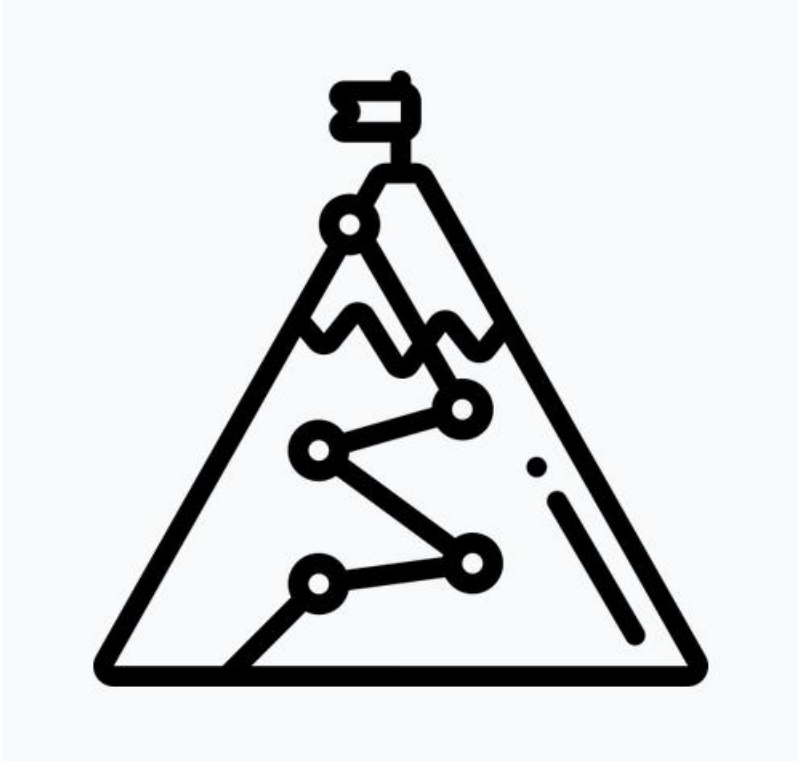
零信任架構的八大基本要求

- 所有的存取都要能夠確認存取者的身分並留下紀錄
- 使用者身分鑑別機制要能夠防止使用者被網路釣魚或撞庫攻擊而認證資訊外洩的情況
- 要能夠掌控所有重要資訊資產的所在位置，並且確保不會被未經授權存取
- 要確保所有服務與應用程式的安全性，以免有可以未經授權而存取的漏洞
- 權限設定要滿足最小需求與交互勾稽原則，以降低存取風險
- 在進行存取控制時，要考量存取者裝置可能被當作跳板的情形
- 確保機密資訊不會在傳輸時被竊取
- 考量到存取控制失效的情境，而建立補償機制

如果想要開始嘗試建立零信任架構



結論



導入零信任架構就像爬山
有些該做的事情要做
但是準備好以後逐步進行
而且要避免疊床架屋

要掌握核心
不是一昧的阻絕，而是要在風險的考量下，兼顧安全與便利

謝謝各位的聆聽

